

2015-07-22

**TECNOLOGÍA DE LA INFORMACIÓN.
TÉCNICAS DE SEGURIDAD. CÓDIGO DE
PRÁCTICA PARA CONTROLES DE SEGURIDAD
DE LA INFORMACIÓN**



E: INFORMATION TECHNOLOGY. SECURITY TECHNIQUES-
CODE OF PRACTICE FOR INFORMATION SECURITY
CONTROLS

CORRESPONDENCIA: esta norma es idéntica por traducción
(IDT) de la norma ISO/IEC 27002:2013
+ Technical Corrigendum 1: 2014

DESCRIPTORES: seguridad de la información, controles
de seguridad, tecnologías de la
información, gestión de la seguridad,
sistemas de gestión.

I.C.S.: 35.040

Editada por el Instituto Colombiano de Normas Técnicas y Certificación (ICONTEC)
Apartado 14237 Bogotá, D.C. - Tel. (571) 6078888 - Fax (571) 2221435

PRÓLOGO

El Instituto Colombiano de Normas Técnicas y Certificación, **ICONTEC**, es el organismo nacional de normalización, según el Decreto 2269 de 1993.

ICONTEC es una entidad de carácter privado, sin ánimo de lucro, cuya Misión es fundamental para brindar soporte y desarrollo al productor y protección al consumidor. Colabora con el sector gubernamental y apoya al sector privado del país, para lograr ventajas competitivas en los mercados interno y externo.

La representación de todos los sectores involucrados en el proceso de Normalización Técnica está garantizada por los Comités Técnicos y el período de Consulta Pública, este último caracterizado por la participación del público en general.

La guía GTC-ISO/IEC 27002 fue ratificada por el Consejo Directivo de 2015-07-22.

Esta guía está sujeta a ser actualizada permanentemente con el objeto de que responda en todo momento a las necesidades y exigencias actuales.

A continuación se relacionan las empresas que colaboraron en el estudio de esta guía a través de su participación en el Comité Técnico 181 Gestión de la tecnología de la información.

ALFREDO LÓPEZ Y CÍA. LTDA.
ARCHIVO GENERAL DE LA NACIÓN
AUDIT TRUST SERVICES S.A.S.
AVIANCA
AZTECA COMUNICACIONES
BANCO AGRARIO DE COLOMBIA
BANCO DE OCCIDENTE
BANCO GNB SUDAMERIS
CENET S.A.
COMPENSAR
CROSS BORDER TECHNOLOGY
ETB
ÉTICA Y TECNOLOGÍA
FLUIDSIGNAL GROUP S.A.
GEMAS S.A.
GEOCONSULT CS LTDA.
GESTION & ESTRATEGIA S.A.S.
GOVERNATI
HALLIBURTON LATINOAMÉRICA
HELM BANK COLOMBIA

IDENTIAN S.A.S.
INSTITUTO COLOMBIANO DEL PETRÓLEO
-ICP ECOPETROL-
ITEAM
LA POLAR -CF-
MINISTERIO DE TECNOLOGÍAS DE LA
INFORMACIÓN Y LAS COMUNICACIONES
-MINTIC-
NET READY SOLUTIONS
NEUNET S.A.
ONAC
PACIFIC RUBIALES
PROJECT ADVANCED MANAGEMENTE
QUALTIC S.A.S.
SCHLUMBERGER
SERVIENTREGA
SOCIETAL SECURITY
THOMAS GREG & SONS
TOP FACTORY S.A.

Además de las anteriores, en Consulta Pública el Proyecto se puso a consideración de las siguientes empresas:

A TODA HORA S.A.
ACDECC
ALIANZA SINERTIC

ASIBANCARIA
ATLAS TRANSVALORES
BANCO DE BOGOTÁ

BANCO DE LA REPÚBLICA
BUSINESS PROCESS SERVICES - BP
SERVICES S.A.S.
CCIT
CHOUCAIR TESTING
CINTEL
COLSUBSIDIO
CORREDOR EMPRESARIAL S.A.
DAKYA
DIJIN
E.T.B
ECOPETROL
INGENIERIA SUSTENTABLE
IPX LTDA.
IQ INFORMATION QUALITY
IQ OUTSOURCING
JTCCIA
MAREIGUA

MEGABANCO
MUSSI
PIRAMIDE ADMINISTRACIÓN DE
INFORMACIÓN LTDA.
PONTIFICIA UNIVERSIDAD JAVERIANA
SGS COLOMBIA
SOCEH
SOCIEDAD COLOMBIANA DE ARCHIVISTAS
SUN GEMINI S.A.
SYNAPSIS
TELEFONICA TELECOM
TELMEX
TMC & CÍA.
UNIVERSIDAD AUTÓNOMA OCCIDENTE
UNIVERSIDAD JAVERIANA
UNIVERSIDAD NACIONAL DE COLOMBIA
UNIVERSIDAD SANTO TOMAS
VISA

ICONTEC cuenta con un Centro de Información que pone a disposición de los interesados normas internacionales, regionales y nacionales y otros documentos relacionados.

DIRECCIÓN DE NORMALIZACIÓN

PRÓLOGO

ISO (Organización Internacional de Normalización) e IEC (Comisión Electrotécnica Internacional) forman el sistema especializado para la estandarización a nivel mundial. Los organismos nacionales que son miembros de ISO o IEC participan en el desarrollo de normas internacionales a través de los comités técnicos establecidos por la organización respectiva para tratar campos particulares de la actividad técnica. Los comités técnicos de ISO e IEC colaboran en los campos de mutuo interés. Otras organizaciones internacionales, gubernamentales y no gubernamentales, en coordinación con ISO e IEC, también participan en el trabajo. En el campo de Tecnología de la Información, ISO e IEC han establecido EL comité técnico conjunto ISO/IEC JTC 1.

Las normas internacionales se redactan de acuerdo con las reglas establecidas en la Parte 2 de las Directivas ISO/IEC.

La ISO/IEC 27002 fue preparada por el comité técnico conjunto ISO/IEC JTC 1, Tecnologías de la Información, subcomité SC 27, Técnicas de Seguridad de T.I.

Se llama la atención sobre la posibilidad de que algunos de los elementos de este documento puedan estar sujetos a derechos de patente. ISO no asume la responsabilidad por la identificación de cualquiera o todos los derechos de patente.

La segunda edición de la norma ISO/IEC 27002 cancela y reemplaza la primera edición (ISO/IEC 27002:2005), la cual ha sido revisada y estructurada técnicamente.

NOTA NACIONAL Esta edición cancela y reemplaza la norma NTC-ISO/IEC 27002:2007, la cual ha sido revisada y estructurada técnicamente.

CONTENIDO

	Página
0. INTRODUCCIÓN.....	i
0.1 ANTECEDENTES Y CONTEXTO	i
0.2 REQUISITOS DE SEGURIDAD DE LA INFORMACIÓN	ii
0.3 SELECCIÓN DE CONTROLES.....	ii
0.4 DESARROLLO DE SUS PROPIAS DIRECTRICES	iii
0.5 CONSIDERACIONES SOBRE EL CICLO DE VIDA	iii
0.6 NORMAS RELACIONADAS	iii
1. OBJETO Y CAMPO DE APLICACIÓN	1
2. REFERENCIAS NORMATIVAS	1
3. TÉRMINOS Y DEFINICIONES	1
4. ESTRUCTURA DE ESTA GUÍA.....	1
4.1 NUMERALES	2
4.2 CATEGORÍAS DE CONTROL.....	2
5. POLÍTICAS DE LA SEGURIDAD DE LA INFORMACIÓN	2
5.1 DIRECTRICES ESTABLECIDAS POR LA DIRECCIÓN PARA LA SEGURIDAD DE LA INFORMACIÓN	2
6. ORGANIZACIÓN DE LA SEGURIDAD DE LA INFORMACIÓN.....	5
6.1 ORGANIZACIÓN INTERNA	5
6.2 DISPOSITIVOS MÓVILES Y TELETRABAJO	8

7.	SEGURIDAD DEL RECURSO HUMANO	11
7.1	ANTES DE ASUMIR EL EMPLEO	11
7.2	DURANTE LA EJECUCIÓN DEL EMPLEO	13
7.3	TERMINACIÓN Y CAMBIO DE EMPLEO	16
8.	GESTIÓN DE ACTIVOS	17
8.1	RESPONSABILIDAD POR LOS ACTIVOS	17
8.2	CLASIFICACIÓN DE LA INFORMACIÓN	19
8.3	MANEJO DE MEDIOS	22
9.	CONTROL DE ACCESO	24
9.1	REQUISITOS DEL NEGOCIO PARA CONTROL DE ACCESO	24
9.2	GESTIÓN DE ACCESO DE USUARIOS	27
9.3	RESPONSABILIDADES DE LOS USUARIOS	32
9.4	CONTROL DE ACCESO A SISTEMAS Y APLICACIONES	33
10.	CRIPTOGRAFÍA	37
10.1	CONTROLES CRIPTOGRÁFICOS	37
11.	SEGURIDAD FÍSICA Y DEL ENTORNO	40
11.1	ÁREAS SEGURAS	40
11.2	EQUIPOS	44
12.	SEGURIDAD DE LAS OPERACIONES	51
12.1	PROCEDIMIENTOS OPERACIONALES Y RESPONSABILIDADES	51
12.2	PROTECCIÓN CONTRA CÓDIGOS MALICIOSOS	54

	Página
12.3 COPIAS DE RESPALDO.....	56
12.4 REGISTRO (<i>LOGGING</i>) Y SEGUIMIENTO	57
12.5 CONTROL DE SOFTWARE OPERACIONAL (<i>Control of Operational Software</i>).....	60
12.6 GESTIÓN DE LA VULNERABILIDAD TÉCNICA.....	61
12.7 CONSIDERACIONES SOBRE AUDITORÍAS DE SISTEMAS DE INFORMACIÓN.....	64
13. SEGURIDAD DE LAS COMUNICACIONES	65
13.1 GESTIÓN DE LA SEGURIDAD DE LAS REDES	65
13.2 TRANSFERENCIA DE INFORMACIÓN	67
14. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE SISTEMAS	71
14.1 REQUISITOS DE SEGURIDAD DE LOS SISTEMAS DE INFORMACIÓN	71
14.2 SEGURIDAD EN LOS PROCESOS DE DESARROLLO Y DE SOPORTE	75
14.3 DATOS DE PRUEBA.....	82
15. RELACIONES CON LOS PROVEEDORES.....	83
15.1 SEGURIDAD DE LA INFORMACIÓN EN LAS RELACIONES CON LOS PROVEEDORES	83
15.2 GESTIÓN DE LA PRESTACIÓN DE SERVICIOS DE PROVEEDORES.....	87
16. GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN.....	89
16.1 GESTIÓN DE INCIDENTES Y MEJORAS EN LA SEGURIDAD DE LA INFORMACIÓN	89
17. ASPECTOS DE SEGURIDAD DE LA INFORMACIÓN DE LA GESTIÓN DE CONTINUIDAD DE NEGOCIO	95

	Página
17.1 CONTINUIDAD DE SEGURIDAD DE LA INFORMACIÓN	95
17.2 REDUNDANCIAS.....	97
18. CUMPLIMIENTO	98
18.1 CUMPLIMIENTO DE REQUISITOS LEGALES Y CONTRACTUALES	98
18.2 REVISIONES DE SEGURIDAD DE LA INFORMACIÓN	102
BIBLIOGRAFÍA	105
DOCUMENTO DE REFERENCIA	107

0. INTRODUCCIÓN

0.1 ANTECEDENTES Y CONTEXTO

La presente guía está diseñada para uso por parte de las organizaciones, como referencia para la selección de controles dentro del proceso de implementación de un Sistema de Gestión de la Seguridad de la Información (SGSI) con base en la NTC-ISO/IEC 27001^[10], o como un documento guía para organizaciones que implementan controles de seguridad de la información comúnmente aceptados. Esta guía está prevista para uso en el desarrollo de directrices de gestión de la seguridad de la información específicas para la industria y las organizaciones, teniendo en cuenta su(s) entorno(s) específico(s) de riesgo de seguridad de la información

Las organizaciones de cualquier tipo y tamaño (incluido el sector público y privado, comercial y sin ánimo de lucro) recolectan, procesan, almacenan y transmiten información en muchas formas, que incluyen los formatos electrónico, físico y las comunicaciones verbales (por ejemplo, conversaciones y presentaciones).

El valor de la información va más allá de las palabras escritas, números e imágenes: el conocimiento, los conceptos, las ideas y las marcas son ejemplos de formas de información intangibles. En un mundo interconectado, la información y los procesos relacionados, los sistemas, las redes y el personal involucrado en su operación, el manejo y la protección de los activos que, como cualquier otro activo importante del negocio, son valiosos para el negocio de una organización, y en consecuencia ameritan o requieren protección contra diversos peligros.

Los activos son objeto de amenazas tanto deliberadas como accidentales, mientras que los procesos, sistemas, redes y personas relacionadas tienen vulnerabilidades inherentes. Los cambios en los procesos y sistemas del negocio u otros cambios externos (como nuevas leyes y reglamentos) pueden crear nuevos riesgos de seguridad de la información. Por tanto, dada la multitud de formas en las que las amenazas pueden aprovecharse de las vulnerabilidades para perjudicar la organización, siempre hay presencia de riesgos de seguridad de la información. Una seguridad de la información eficaz reduce estos riesgos protegiendo a la organización contra amenazas y vulnerabilidades, y en consecuencia reduce los impactos en sus activos.

La seguridad de la información se logra mediante la implementación de un conjunto adecuado de controles, incluidas las políticas, procesos, procedimientos, estructuras organizacionales y las funciones del software y del hardware. Es necesario establecer, implementar, hacer seguimiento, revisar y mejorar estos controles en donde sea necesario, para asegurar que se cumplen los objetivos del negocio y de seguridad específicos de la organización. Un SGSI como el que se especifica en la norma NTC-ISO/IEC 27001^[10] asume una visión holística y coordinada de los riesgos de seguridad de la información para implementar un conjunto amplio de controles de seguridad de la información bajo el marco de referencia global de un sistema de gestión coherente.

Muchos sistemas de información no han sido diseñados para ser seguros, en el sentido de la NTC-ISO/IEC 27001^[10] y de esta guía. La seguridad que se puede lograr por medios técnicos es limitada y debería estar apoyada en gestión y procedimientos apropiados. La identificación

de los controles con los que se debería contar requiere una planificación cuidadosa y atención a los detalles. Un SGSI exitoso requiere el apoyo de todos los empleados de la organización. También requiere la participación de los accionistas, proveedores u otras partes externas. También puede ser necesaria asesoría especializada de las partes externas.

En un sentido más general, una seguridad de la información eficaz también asegura a la dirección y a otras partes interesadas, que los activos de la organización están razonablemente seguros y protegidos contra daño, y de esta manera actúa como un facilitador del negocio.

0.2 REQUISITOS DE SEGURIDAD DE LA INFORMACIÓN

Es esencial que una organización identifique sus requisitos de seguridad. Existen tres fuentes principales de requisitos de seguridad:

- a) la valoración de los riesgos para la organización, teniendo en cuenta la estrategia y los objetivos de negocio globales de la organización. Por medio de una valoración de riesgos se identifican las amenazas a los activos, se evalúa la vulnerabilidad y la posibilidad de que ocurran, y se estima el impacto potencial;
- b) los requisitos legales, estatutarios, de reglamentación y contractuales que una organización, sus socios comerciales, contratistas y proveedores de servicios deben cumplir, y su entorno socio-cultural.
- c) el conjunto de principios, objetivos y requisitos del negocio para el manejo, procesamiento, almacenamiento, comunicación y archivo de información, que una organización ha desarrollado para apoyar sus operaciones.

Es necesario establecer un balance entre los recursos empleados en la implementación de controles, y el daño para el negocio que pudiera resultar de cuestiones de seguridad en ausencia de tales controles. Los resultados de una valoración de los riesgos ayudarán a guiar y a determinar la acción de gestión apropiada y las prioridades para la gestión de los riesgos de seguridad de la información, y para la implementación de los controles seleccionados para protegerse contra estos riesgos.

La norma ISO/IEC 27005^[11] brinda orientación sobre gestión de riesgos de seguridad de la información, e incluye asesoría sobre valoración, tratamiento, aceptación, comunicación, seguimiento y revisión de riesgos.

0.3 SELECCIÓN DE CONTROLES

Los controles se pueden seleccionar de esta guía o de otros grupos de control, o se pueden diseñar nuevos controles para satisfacer necesidades específicas.

La selección de controles depende de las decisiones organizacionales basadas en los criterios para la aceptación de riesgos, las opciones para tratamiento de riesgos y el enfoque general para la gestión de riesgos aplicado a la organización, y debería estar sujeta a toda la legislación y reglamentación nacionales e internacionales pertinentes. La selección de los controles también depende de la forma en la que los controles interactúan para defender en profundidad.

Algunos de los controles de esta guía se pueden considerar como principios de orientación para gestión de la seguridad de la información y aplicables a la mayoría de organizaciones. Los

controles se explican con más detalle más adelante, junto con la guía de implementación. En la norma ISO/IEC 27005^[11] se puede encontrar más información acerca de la selección de controles y de otras opciones para tratamiento de riesgos.

0.4 DESARROLLO DE SUS PROPIAS DIRECTRICES

Esta guía se puede considerar como un punto de partida para el desarrollo de directrices específicas de la organización. No todos los controles y orientación de este código de práctica pueden ser aplicables. Además, se pueden requerir controles y directrices adicionales que no están incluidos en esta guía. Cuando los documentos que se desarrollan contienen directrices o controles adicionales, puede ser útil incluir referencias cruzadas a los numerales de esta guía, en donde sea aplicable, para facilitar la verificación del cumplimiento por parte de los auditores y socios de negocios.

0.5 CONSIDERACIONES SOBRE EL CICLO DE VIDA

La información tiene un ciclo de vida natural, desde su creación y origen, pasando por el almacenamiento, procesamiento, uso y transmisión, hasta su deterioro o destrucción final. El valor de los activos y los riesgos para los activos pueden variar durante su ciclo de vida (por ejemplo, la divulgación no autorizada o el robo de las cuentas financieras de una compañía es mucho menos significativa después de que se han publicado formalmente), pero la seguridad de la información sigue siendo importante en todas las etapas, en alguna medida.

Los sistemas de información tienen ciclos de vida dentro de los cuales se lleva a cabo su concepción, especificación, diseño, desarrollo, pruebas, implementación, uso, mantenimiento y finalmente el retiro de servicio y su disposición. La seguridad de la información se debería tener en cuenta en todas las etapas. Los nuevos desarrollos de sistemas y los cambios en los sistemas existentes presentan oportunidades para que las organizaciones actualicen y mejoren sus controles de seguridad, teniendo en cuenta los incidentes reales y los riesgos de seguridad de la información presentes y proyectados.

0.6 NORMAS RELACIONADAS

Aunque esta guía ofrece orientación sobre una amplia gama de controles de seguridad de la información que se aplican comúnmente en muchas organizaciones, las otras normas de la familia ISO/IEC 27000 brindan asesoría o requisitos complementarios sobre otros aspectos del proceso total de gestión de seguridad de la información.

Consulte la norma ISO/IEC 27000, que presenta una introducción general al SGSI y a la familia de normas. La norma ISO/IEC 27000 presenta un glosario que define formalmente la mayoría de términos usados en la familia de normas ISO/IEC 27000, y describe el objeto, campo de aplicación y los objetivos de cada miembro de la familia.

**TECNOLOGÍA DE LA INFORMACIÓN.
TÉCNICAS DE SEGURIDAD.
CÓDIGO DE PRÁCTICA PARA CONTROLES
DE SEGURIDAD DE LA INFORMACIÓN**

1. OBJETO Y CAMPO DE APLICACIÓN

La presente Guía proporciona directrices para las normas de seguridad de la información organizacional y las prácticas de gestión de la seguridad de la información, incluida la selección, la implementación y la gestión de controles, teniendo en cuenta el(los) entorno(s) del riesgo de seguridad de la información de la organización.

Esta Guía está diseñada por organizaciones que tienen el propósito de:

- a) seleccionar controles dentro del proceso de implementación de un Sistema de Gestión de la Seguridad de la Información con base en la norma NTC-ISO/IEC 27001^[10];
- b) implementar controles de seguridad de la información comúnmente aceptados;
- c) desarrollar sus propias directrices de gestión de la seguridad de la información.

2. REFERENCIAS NORMATIVAS

Los siguientes documentos, en parte o en su totalidad, se referencian normativamente en este documento y son indispensables para su aplicación. Para referencias fechadas sólo se aplica la edición citada. Para referencias no fechadas se aplica la edición más reciente del documento referenciado (incluida cualquier enmienda).

ISO/IEC 27000, *Information Technology. Security Techniques. Information Security Management Systems. Overview and Vocabulary.*

3. TÉRMINOS Y DEFINICIONES

Para los propósitos de este documento se aplican los términos y definiciones presentados en la norma ISO/IEC 27000.

4. ESTRUCTURA DE ESTA GUIA

Esta guía contiene 14 numerales de control de seguridad de la información que en su conjunto contienen más de 35 categorías de seguridad principales y 114 controles.

4.1 NUMERALES

Cada numeral que define controles de seguridad contiene una o más categorías de seguridad principales.

El orden de los numerales en esta guía no tiene que ver con su importancia. Dependiendo de las circunstancias, los controles de seguridad de alguno o de todos los numerales pueden ser importantes; por tanto, cada organización que aplica esta guía debería identificar los controles aplicables, su grado de importancia y su aplicación a los procesos individuales del negocio. Además, las listas de esta guía no se presentan en orden de prioridad.

4.2 CATEGORÍAS DE CONTROL

Cada categoría principal de control de la seguridad contiene:

- a) un objetivo de control que establece lo que se va a lograr;
- b) uno o más controles que se pueden aplicar para lograr el objetivo de control.

Las descripciones de los controles están estructuradas de la siguiente manera:

Control

Define la declaración específica del control para satisfacer el objetivo del control.

Guía de implementación

Brinda información más detallada para apoyar la implementación del control y cumplir el objetivo del control. Es posible que la orientación no sea completamente adecuada ni suficiente en todas las situaciones, y que no cumpla los requisitos de control específicos de la organización.

Información adicional

Brinda información adicional que puede ser necesario considerar, por ejemplo, las consideraciones legales y referencias a otras normas. Si no hay información adicional que suministrar, no se incluye esta parte.

5. POLÍTICAS DE LA SEGURIDAD DE LA INFORMACIÓN

5.1 DIRECTRICES ESTABLECIDAS POR LA DIRECCIÓN PARA LA SEGURIDAD DE LA INFORMACIÓN

Objetivo: Brindar orientación y apoyo por parte de la dirección, para la seguridad de la información de acuerdo con los requisitos del negocio y con las leyes y reglamentos pertinentes.

5.1.1 Políticas para la seguridad de la información

Control

Se debería definir un conjunto de políticas para la seguridad de la información, aprobada por la dirección, publicada y comunicada a los empleados y partes externas pertinentes.

Guía de implementación

Desde el más alto nivel, las organizaciones deberían definir una “política de seguridad de la información” que sea aprobada por la dirección y que establezca el enfoque de la organización para la gestión de sus objetivos de seguridad de la información.

Las políticas de la seguridad de la información deberían abordar los requisitos creados por:

- a) estrategia de negocio;
- b) reglamentaciones, legislación y contratos;
- c) el entorno actual y proyectado de amenazas a la seguridad de la información.

La política de la seguridad de la información debería contener declaraciones concernientes a:

- a) la definición de seguridad de la información, objetivos y principios para orientar todas las actividades relacionadas con la seguridad de la información;
- b) la asignación de las responsabilidades generales y específicas para la gestión de la seguridad de la información, a roles definidos;
- c) procesos para manejar desviaciones y excepciones.

Desde el más bajo nivel, la política de la seguridad de la información debería estar apoyada en políticas específicas por temas, que además exigen la implementación de controles de seguridad de la información y están típicamente estructuradas para tener en cuenta las necesidades de algunos grupos objetivo dentro de una organización, o para tener en cuenta temas determinados.

Algunos ejemplos de estos temas de políticas incluyen:

- a) control de acceso (véase el numeral 9);
- b) clasificación de la información (véase el numeral 8.2);
- c) seguridad física y del entorno (véase el numeral 11);
- d) temas orientados a los usuarios finales, tales como:
 - 1) uso aceptable de los activos (véase el numeral 8.1.3);
 - 2) política de escritorio y pantalla limpia (véase el numeral 11.2.9);
 - 3) transferencia de información (véase el numeral 13.2.1);
 - 4) dispositivos móviles y teletrabajo (véase el numeral 6.2);
 - 5) restricciones sobre instalaciones y uso del software (véase el numeral 12.6.2);
- e) copias de respaldo (véase el numeral 12.3);
- f) transferencia de información (véase el numeral 13.2);

- g) protección contra códigos maliciosos (véase el numeral 12.2);
- h) gestión de las vulnerabilidades técnicas (véase el numeral 12.6.1);
- i) controles criptográficos (véase el numeral 10);
- j) seguridad de las comunicaciones (véase el numeral 13);
- k) privacidad y protección de información de datos personales (véase el numeral 18.1.4);
- l) relaciones con los proveedores (véase el numeral 15);

Estas políticas se deberían comunicar a los empleados y a las partes externas interesadas, en una forma que sea pertinente, accesible y comprensible para el lector previsto, por ejemplo, en el contexto de un “programa de toma de conciencia, educación y formación en la seguridad de la información” (véase el numeral 7.2.2).

Información adicional

La necesidad de políticas internas para la seguridad de la información varía a través de las organizaciones. Las políticas internas son especialmente útiles en organizaciones de mayor tamaño y complejidad, en donde las políticas que definen y aprueban los niveles esperados de control están separadas de las que implementan los controles, o en situaciones en las que una política se aplica a muchas personas o funciones diferentes en la organización. Las políticas para seguridad de la información se pueden publicar en un solo documento de “política de la seguridad de la información” o como un conjunto de documentos individuales pero relacionados.

Si alguna de las políticas de seguridad de la información se distribuye por fuera de la organización, se debería tener cuidado de no revelar información confidencial.

Algunas organizaciones usan otros términos para designar estos documentos de políticas, tales como “Normas”, Directivas” o “Reglas”.

5.1.2 Revisión de las políticas para la seguridad de la información

Control

Las políticas para la seguridad de la información se deberían revisar a intervalos planificados o si ocurren cambios significativos, para asegurar su conveniencia, adecuación y eficacia continuas.

Guía de implementación

Cada política debería tener un propietario que tenga la responsabilidad aprobada por la dirección, para el desarrollo, revisión y evaluación de las políticas. La revisión debería incluir la valoración de las oportunidades de mejora de las políticas de la organización y el enfoque para la gestión de la seguridad de la información en respuesta a los cambios en el entorno organizacional, las circunstancias del negocio, las condiciones legales o el ambiente técnico.

La revisión de las políticas para seguridad de la información debería tener en cuenta los resultados de las revisiones por la dirección.

Se debería obtener la aprobación de la dirección con relación a una política revisada.

6. ORGANIZACIÓN DE LA SEGURIDAD DE LA INFORMACIÓN

6.1 ORGANIZACIÓN INTERNA

Objetivo: Establecer un marco de referencia de gestión para iniciar y controlar la implementación y la operación de la seguridad de la información dentro de la organización.

6.1.1 Roles y responsabilidades para la seguridad de la información

Control

Se deberían definir y asignar todas las responsabilidades de la seguridad de la información.

Guía de implementación

La asignación de las responsabilidades de seguridad de la información se debería hacer de acuerdo con las políticas para la seguridad de la información (véase el numeral 5.1.1). Se deberían identificar las responsabilidades para la protección de los activos individuales y para llevar a cabo procesos de seguridad de la información específicos. Se deberían definir las responsabilidades para las actividades de gestión del riesgo de la seguridad de la información, y en particular, para la aceptación de riesgos residuales. Cuando sea necesario, estas responsabilidades se deberían complementar con orientación detallada para sitios e instalaciones de procesamiento de información específicos. Se deberían definir las responsabilidades locales para la protección de activos y para la realización de procesos de seguridad específicos.

Los individuos a los que se les ha asignado responsabilidades de seguridad de la información pueden delegar a otros las tareas de seguridad de la información. No obstante, siguen siendo responsables y deberían determinar la ejecución correcta de cualquier tarea delegada.

Se deberían establecer las áreas de las cuales son responsables los individuos. En particular, se debería efectuar lo siguiente:

- a) se deberían identificar y definir los activos y los procesos de seguridad de la información;
- b) se debería asignar la entidad responsable de cada activo o proceso de seguridad de la información, y se deberían documentar los detalles de esta responsabilidad (véase el numeral 8.1.2);
- c) se deberían definir y documentar los niveles de autorización;
- d) para tener la capacidad de cumplir las responsabilidades en el área de seguridad de la información, los individuos nombrados deberían ser competentes en el área y se les debería brindar oportunidades de mantenerse actualizados con los avances en este tema;
- e) se deberían identificar y documentar la coordinación y la supervisión de los aspectos de seguridad de la información de las relaciones con los proveedores.

Información adicional

Muchas organizaciones nombran un gerente de seguridad de la información que asuma la responsabilidad total por el desarrollo e implementación de la seguridad de la información y que apoye la identificación de los controles.

Sin embargo, la responsabilidad por la obtención de recursos y la implementación de controles será con frecuencia de los gerentes individuales. Una práctica común es nombrar un propietario para cada activo, quien entonces se convierte en el responsable de su protección diaria.

6.1.2 Segregación de funciones

Control

Las funciones y áreas de responsabilidad en conflicto se deberían separar para reducir las posibilidades de modificación no autorizada o no intencional, o el uso indebido de los activos de la organización.

Guía de implementación

Es conveniente prestar atención a que ninguna persona pueda acceder, modificar o usar activos sin autorización ni detección. El inicio de un evento debería estar separado de su autorización. Al diseñar los controles se debería considerar la posibilidad de confabulación

Para las organizaciones pequeñas la segregación de funciones puede ser difícil de lograr, pero el principio se debería aplicar en tanto sea posible y viable. Siempre que resulte difícil hacer la segregación, se deberían considerar otros controles, tales como el seguimiento de actividades, los rastros de auditoría (*Audit Trails*) y la supervisión de la dirección.

Información adicional

La segregación de funciones es un método para reducir el uso indebido, accidental o deliberado, de los activos de una organización.

6.1.3 Contacto con las autoridades

Control

Se deberían mantener contactos apropiados con las autoridades pertinentes.

Guía de implementación

Las organizaciones deberían tener procedimientos establecidos que especifiquen cuándo y a través de qué autoridades se debería contactar a las autoridades (por ejemplo, las encargadas de hacer cumplir la ley, los organismos de regulación y las autoridades de supervisión), y cómo se deberían reportar de una manera oportuna los incidentes de seguridad de la información identificados (por ejemplo, si se sospecha una violación de la ley).

Información adicional

Las organizaciones que son atacadas por Internet pueden necesitar que las autoridades emprendan acciones contra la fuente del ataque.

El mantenimiento de estos contactos puede ser un requisito para apoyar la gestión de incidentes de seguridad de la información (véase el numeral 16) o el proceso de continuidad de negocio, o el proceso de planificación de contingencias (véase el numeral 17). Los contactos con organismos de regulación son útiles para anticiparse y prepararse para los cambios inminentes en las leyes o reglamentaciones que la organización ha de implementar. Los contactos con otras autoridades incluyen las empresas de servicio públicos, los servicios de emergencia, los proveedores de electricidad y de salud y seguridad, por ejemplo, los

departamentos de bomberos (en relación con la continuidad de negocio), los proveedores de telecomunicaciones (en relación con la disponibilidad y enrutamiento de líneas) y los proveedores de agua (en relación con las instalaciones de enfriamiento de equipos).

6.1.4 Contacto con grupos de interés especial

Control

Se debería mantener contactos apropiados con grupos de interés especial u otros foros y asociaciones profesionales especializadas en seguridad.

Guía de implementación

La membrecía en grupos o foros de interés especial se debería considerar como un medio para:

- a) mejorar el conocimiento acerca de las mejores prácticas y permanecer al día con la información de seguridad pertinente;
- b) asegurar que la comprensión del entorno de la seguridad de la información sea actual y esté completa;
- c) recibir advertencias tempranas de las alertas, avisos y parches acerca de ataques y vulnerabilidades;
- d) obtener acceso a asesoría especializada en seguridad de la información;
- e) compartir e intercambiar información acerca de nuevas tecnologías, productos, amenazas o vulnerabilidades;
- f) brindar puntos de enlace adecuados cuando se trata con incidentes de seguridad de la información (véase el numeral 16).

Información adicional

Se pueden establecer acuerdos acerca de intercambio de información para mejorar la cooperación y coordinación de cuestiones de seguridad. Estos acuerdos deberían identificar los requisitos para la protección de información confidencial.

6.1.5 Seguridad de la información en la gestión de proyectos

Control

La seguridad de la información se debería tratar en la gestión de proyectos, independientemente del tipo de proyecto.

Guía de implementación

La seguridad de la información se debería integrar al(los) método(s) de gestión de proyectos de la organización, para asegurar que los riesgos de seguridad de la información se identifiquen y traten como parte de un proyecto. Esto se aplica generalmente a cualquier proyecto, independientemente de su naturaleza, por ejemplo, un proyecto para un proceso del negocio principal, TI, gestión de instalaciones y otros procesos de soporte. Los métodos de gestión de proyectos que se usen deberían requerir que:

- a) los objetivos de la seguridad de la información se incluyan en los objetivos del proyecto;
- b) la valoración de los riesgos de seguridad de la información se lleva a cabo en una etapa temprana del proyecto, para identificar los controles necesarios;
- c) la seguridad de la información sea parte de todas las fases de la metodología del proyecto aplicada.

Las implicaciones de la seguridad de la información se deberían tener en cuenta y revisar en forma regular en todos los proyectos. Se deberían definir las responsabilidades para seguridad de la información, y asignarlas a roles especificados definidos en los métodos de gestión de proyectos.

6.2 DISPOSITIVOS MÓVILES Y TELETRABAJO

Objetivo: Garantizar la seguridad del teletrabajo y el uso de dispositivos móviles.

6.2.1 Política para dispositivos móviles

Control

Se deberían adoptar una política y unas medidas de seguridad de soporte, para gestionar los riesgos introducidos por el uso de dispositivos móviles.

Guía de implementación

Cuando se usan dispositivos móviles, se debería prestar atención especial a asegurar que no se comprometa la información del negocio. La política de dispositivos móviles debería tener en cuenta los riesgos de trabajar con dispositivos móviles en entornos no protegidos.

La política de dispositivos móviles debería considerar:

- a) el registro de los dispositivos móviles;
- b) los requisitos de la protección física;
- c) las restricciones para la instalación de software;
- d) los requisitos para las versiones de software de dispositivos móviles y para aplicar parches;
- e) la restricción de la conexión a servicios de información;
- f) controles de acceso;
- g) técnicas criptográficas;
- h) protección contra software malicioso;
- i) deshabilitación remota, borrado o cierre
- j) copias de respaldo;
- k) uso de servicios y aplicaciones web.

Se debería tener cuidado cuando se usan dispositivos móviles en lugares públicos, salas de reuniones y otras áreas no protegidas. Se debería contar con protección para evitar el acceso o la divulgación no autorizada de la información almacenada y procesada por estos dispositivos, por ejemplo, usando técnicas criptográficas (véase el numeral 10) e imponiendo el uso de información secreta para la autenticación (véase el numeral 9.2.4).

Los dispositivos móviles también deberían estar protegidos físicamente contra robo, especialmente cuando se dejan en automóviles y otras formas de transporte, habitaciones de hotel, centros de conferencias y lugares de reuniones. Se debería establecer un procedimiento específico teniendo en cuenta los requisitos legales, de seguros y otros requisitos de seguridad de la organización, para los casos de robo o pérdida de dispositivos móviles. Los dispositivos que contienen información importante, sensible o crítica para el negocio no se deberían dejar sin supervisión, y donde sea posible, deberían estar encerrados bajo llave o se deberían usar cerraduras especiales para asegurarlos.

Se debería disponer de entrenamiento para el personal que usa dispositivos móviles, para incrementar el nivel de concienciación sobre los riesgos adicionales que resultan de este tipo de trabajo, y los controles que se deberían implementar.

Cuando la política de dispositivos móviles permite el uso de dispositivos móviles de propiedad personal, la política y las medidas de seguridad relacionadas también deberían considerar:

- a) la separación entre el uso privado y de negocio de los dispositivos, incluido el uso del software para apoyar esta separación y proteger los datos del negocio en un dispositivo privado;
- b) brindar acceso a la información del negocio solo cuando los usuarios hayan firmado un acuerdo de usuario final, en el que se reconocen sus deberes (protección física, actualización del software, etc.), desistir de la propiedad de los datos del negocio, permitir el borrado remoto de datos por parte de la organización en caso de robo o pérdida del dispositivo, o cuando ya no se posee autorización para usar el servicio. Esta política necesita tener en cuenta la legislación sobre privacidad.

Información adicional

Las conexiones inalámbricas para dispositivos móviles son similares a otros tipos de conexión de red, pero tienen diferencias importantes que se deberían considerar cuando se identifican controles. Las diferencias típicas son:

- a) algunos protocolos de seguridad inalámbricos no están desarrollados suficientemente, y tienen debilidades conocidas;
- b) es posible que la información almacenada en los dispositivos móviles no esté copiada en discos de respaldo debido a limitaciones en el ancho de banda o porque los dispositivos móviles no estén conectados en los tiempos en que se programa la elaboración de copias de respaldo.

Los dispositivos móviles generalmente comparten funciones comunes con los dispositivos de uso fijo, por ejemplo, trabajo en red, acceso a internet, correo electrónico y manejo de archivos. Los controles de seguridad de la información para los dispositivos móviles generalmente consisten en los controles adoptados en los dispositivos de uso fijo, y en los controles para tratar las amenazas que surgen por su uso fuera de las instalaciones de la organización.

6.2.2 Teletrabajo

Control

Se deberían implementar una política y unas medidas de seguridad de soporte, para proteger la información a la que se tiene acceso, que es procesada o almacenada en los lugares en los que se realiza teletrabajo.

Guía de implementación

Las organizaciones que permiten actividades de teletrabajo deberían expedir una política que defina las condiciones y restricciones para el uso del teletrabajo. Cuando se considera aplicable y lo permite la ley, se deberían considerar los siguientes asuntos:

- a) la seguridad física existente en el sitio del teletrabajo, teniendo en cuenta la seguridad física de la edificación y del entorno local;
- b) el entorno físico de teletrabajo propuesto;
- c) los requisitos de seguridad de las comunicaciones, teniendo en cuenta la necesidad de acceso remoto a los sistemas internos de la organización, la sensibilidad de la información a la que se tendrá acceso y que pasará a través del enlace de comunicación y la sensibilidad del sistema interno;
- d) el suministro de acceso al escritorio virtual, que impide el procesamiento y almacenamiento de información en equipo de propiedad privada;
- e) la amenaza de acceso no autorizado a información o a recursos, por parte de otras personas que usan el mismo alojamiento, por ejemplo, familia y amigos;
- f) el uso de redes domésticas y requisitos o restricciones sobre la configuración de servicios de red inalámbrica;
- g) las políticas y procedimientos para evitar conflictos relacionados con los derechos de propiedad intelectual sobre desarrollos realizados en equipos de propiedad privada;
- h) el acceso a equipo de propiedad privada (para verificar su seguridad o como parte de una investigación), el cual puede ser prohibido por la legislación;
- i) acuerdos de licenciamiento de software de tal forma que las organizaciones puedan llegar a ser responsables por el licenciamiento de software de los clientes en estaciones de trabajo de propiedad de los empleados o de usuarios externos;
- j) requisitos de firewall y de protección contra software malicioso.

Las directrices y acuerdos que se consideren deberían incluir:

- a) el suministro de equipo adecuado y de muebles de almacenamiento para las actividades de teletrabajo, cuando no se permite el uso del equipo de propiedad privada que no está bajo el control de la organización;
- b) una definición del trabajo permitido, las horas de trabajo, la clasificación de la información que se puede mantener, y los sistemas y servicios internos a los que el teletrabajador está autorizado a acceder;

- c) el suministro de equipos de comunicación adecuados, incluidos los métodos para asegurar el acceso remoto;
- d) seguridad física;
- e) las reglas y orientación sobre el acceso de la familia y los visitantes a los equipos y a la información;
- f) el suministro de soporte y mantenimiento del hardware y el software;
- g) el suministro de seguros;
- h) los procedimientos para copias de respaldo y continuidad del negocio;
- i) auditoría y seguimiento de la seguridad;
- j) la revocación de la autoridad y de los derechos de acceso, y la devolución de los equipos cuando las actividades del teletrabajo finalicen.

Información adicional

El teletrabajo hace referencia a todas las formas de trabajo por fuera de la oficina, incluidos los entornos de trabajo no tradicionales, a los que se denomina "trabajo a distancia", "lugar de trabajo flexible", "trabajo remoto" y ambientes de "trabajo virtual".

7. SEGURIDAD DEL RECURSO HUMANO

7.1 ANTES DE ASUMIR EL EMPLEO

Objetivo: Asegurar que los empleados y contratistas comprenden sus responsabilidades y son idóneos en los roles para los que se consideran.

7.1.1 Selección

Control

Las verificaciones de los antecedentes de todos los candidatos a un empleo se deberían llevar a cabo de acuerdo con las leyes, reglamentos y ética pertinentes, y deberían ser proporcionales a los requisitos de negocio, a la clasificación de la información a que se va a tener acceso, y a los riesgos percibidos.

Guía de implementación

La verificación debería tener en cuenta todo lo relacionado con la privacidad, la protección de la información de datos personales y la legislación laboral, y cuando se permita, debería incluir lo siguiente:

- a) la disponibilidad de referencias satisfactorias, por ejemplo, una comercial y una personal;
- b) una verificación (completa y precisa) de la hoja de vida del solicitante;
- c) confirmación de las calificaciones académicas y profesionales declaradas;

- d) una verificación de identidad independiente (pasaporte o documento similar);
- e) una verificación más detallada, como la de la información crediticia o de antecedentes penales.

Cuando un individuo es contratado para un rol de seguridad de la información específico, las organizaciones deberían asegurar que el candidato:

- a) tenga la competencia necesaria para desempeñar el rol de seguridad;
- b) sea confiable para desempeñar el rol, especialmente si es crítico para la organización.

Cuando un trabajo, ya sea por nombramiento o promoción, implique que la persona tenga acceso a las instalaciones de procesamiento de información, y en particular, si ahí se maneja información confidencial, por ejemplo, información financiera o información muy confidencial, la organización debería también considerar verificaciones adicionales más detalladas.

Los procedimientos deberían definir los criterios y limitantes para las revisiones de verificación, por ejemplo, quién es elegible para seleccionar a las personas, y cómo, cuándo y por qué se llevan a cabo revisiones de verificación.

También se debería asegurar un proceso de selección para contratistas. En estos casos, el acuerdo entre la organización y el contratista debería especificar las responsabilidades por la realización de la selección, y los procedimientos de notificación que es necesario seguir si la selección no se ha finalizado, o si los resultados son motivo de duda o inquietud.

La información de todos los candidatos que se consideran para cargos dentro de la organización, se debería recolectar y manejar apropiadamente de acuerdo con la legislación existente. Dependiendo de la legislación aplicable, se debería informar de antemano a los candidatos acerca de las actividades de selección.

7.1.2 Términos y condiciones del empleo

Control

Los acuerdos contractuales con empleados y contratistas deberían establecer sus responsabilidades y las de la organización en cuanto a la seguridad de la información.

Guía de implementación

Las obligaciones contractuales para empleados o contratistas, deberían reflejar las políticas de la organización en cuanto a seguridad de la información, y además deberían aclarar y establecer:

- a) que todos los empleados y contratistas a los que se brinde acceso a información confidencial deberían firmar un acuerdo de confidencialidad y no divulgación, antes de tener acceso a las instalaciones de procesamiento de información (véase el numeral 13.2.4);
- b) las responsabilidades y derechos legales de empleados o contratistas, por ejemplo, con relación a leyes sobre derecho de autor o legislación sobre protección de datos (véanse los numerales 18.1.2 y 18.1.4);

- c) las responsabilidades para la clasificación de la información y la gestión de información organizacional y otros activos asociados con información, instalaciones de procesamiento de información y servicios de información manejados por el empleado o contratista (véase el numeral 8);
- d) las responsabilidades del empleado o contratista para el manejo de la información recibida de otras compañías o partes externas;
- e) las acciones por tomar, si el empleado o contratista no tiene en cuenta los requisitos de seguridad de la organización (véase el numeral 7.2.3).

Los roles y responsabilidades de seguridad de la información se deberían comunicar a los candidatos al empleo, durante el proceso previo a la vinculación.

La organización se debería asegurar de que los empleados y contratistas acepten los términos y condiciones relativos a la seguridad de la información, referente a la naturaleza y al alcance del acceso que tendrán a los activos de la organización asociados con los sistemas y servicios de información.

Cuando sea apropiado, las responsabilidades contenidas dentro de los términos y condiciones del empleo deberían continuar durante un período definido después de finalizado el empleo (véase el numeral 7.3).

Información adicional

Se puede usar un código de conducta para establecer las responsabilidades de seguridad de la información del empleado o del contratista acerca de confidencialidad, protección de datos, ética, uso apropiado de los equipos e instalaciones de la organización, al igual que las prácticas formales esperadas por la organización. A una parte externa, con la cual está asociado un contratista, se le puede pedir que establezca acuerdos contractuales en nombre del individuo contratado.

7.2 DURANTE LA EJECUCIÓN DEL EMPLEO

Objetivo: Asegurarse de que los empleados y contratistas tomen conciencia de sus responsabilidades de seguridad de la información y las cumplan.

7.2.1 Responsabilidades de la dirección

Control

La dirección debería exigir a todos los empleados y contratistas la aplicación de la seguridad de la información de acuerdo con las políticas y procedimientos establecidos por la organización.

Guía de implementación

Las responsabilidades de la dirección deberían incluir asegurarse de que los empleados y contratistas:

- a) estén debidamente informados sobre sus roles y responsabilidades de seguridad de la información, antes de que se les otorgue el acceso a información o sistemas de información confidenciales;
- b) se les suministren las directrices que establecen las expectativas de seguridad de la información de sus roles dentro de la organización;

- c) estén motivados para cumplir las políticas de seguridad de la información de la organización;
- d) logren un nivel de toma de conciencia sobre seguridad de la información pertinente a sus roles y responsabilidades dentro de la organización (véase el numeral 7.2.2);
- e) cumplan los términos y las condiciones del empleo, que incluyen la política de seguridad de la información y los métodos de trabajo apropiados;
- f) tengan continuamente las habilidades y calificaciones apropiadas y reciban capacitación en forma regular;
- g) cuenten con un canal para reporte anónimo de incumplimiento de las políticas o procedimientos de seguridad de la información (“denuncias internas”).

La dirección debería demostrar apoyo a las políticas, procedimientos y controles de seguridad de la información, y actuar como un modelo a seguir.

Información adicional

Si los empleados y contratistas no toman conciencia de sus responsabilidades de seguridad de la información, pueden causar un daño considerable a una organización. El personal motivado tiende a ser más confiable y a causar menos incidentes de seguridad de la información.

Una gestión deficiente puede hacer que el personal se sienta subvalorado, lo que da como resultado un impacto negativo de la seguridad de la información sobre la organización. Por ejemplo, una gestión deficiente puede conducir a que se descuide la seguridad de la información o a que se usen en forma indebida los activos de la organización.

7.2.2 Toma de conciencia, educación y formación en la seguridad de la información

Control

Todos los empleados de la organización, y en donde sea pertinente, los contratistas, deberían recibir la educación y la formación en toma de conciencia apropiada, y actualizaciones regulares sobre las políticas y procedimientos de la organización pertinentes para su cargo.

Guía de implementación

Un programa de toma de conciencia en seguridad de la información, debería apuntar a que los empleados, y en donde sea pertinente, los contratistas, tomen conciencia de sus responsabilidades de seguridad de la información, y de los medios por los cuales se cumplen estas responsabilidades.

Se debería establecer un programa de toma de conciencia en seguridad de la información, en línea con las políticas y procedimientos pertinentes de seguridad de la información de la organización, teniendo en cuenta la información de la organización que se va proteger, y los controles que se han implementado para proteger la información. El programa de toma de conciencia debería incluir varias actividades para toma de conciencia, tales como campañas (por ejemplo, el “día de la seguridad de la información”) y la elaboración de folletos y boletines de noticias.

El programa de toma de conciencia se debería planificar teniendo en cuenta los roles de los empleados en la organización, y en donde sea pertinente, la expectativa de la organización con

relación a la toma de conciencia de los contratistas. Las actividades del programa de toma de conciencia se deberían programar en el tiempo, de preferencia con regularidad, de manera que las actividades se repitan y abarquen a nuevos empleados y contratistas. El programa de toma de conciencia también se debería actualizar regularmente, de manera que permanezca en línea con las políticas y procedimientos organizacionales, y se debería construir con base en las lecciones aprendidas de incidentes de seguridad de la información.

La formación en toma de conciencia se debería llevar a cabo según lo requiera el programa de toma de conciencia en seguridad de la información de la organización. Para la formación en toma de conciencia se pueden usar diferentes medios, incluyendo clase en aula, aprendizaje a distancia, aprendizaje basado en la web, aprendizaje autónomo, y otros.

La educación y la formación en seguridad de la información también deberían comprender aspectos generales tales como:

- a) la declaración del compromiso de la dirección con la seguridad de la información en toda la organización;
- b) la necesidad de conocer y cumplir con las reglas y obligaciones de seguridad de la información aplicables, tal como se definen en las políticas, normas, leyes, reglamentos, contratos y acuerdos;
- c) la rendición personal de cuentas por las acciones y omisiones propias, y las responsabilidades generales relacionadas con la seguridad y la protección de la información que pertenece a la organización y a las partes externas;
- d) los procedimientos básicos de seguridad de la información (tales como el reporte de incidentes de seguridad de la información) y los controles de línea base (tales como la seguridad de las contraseñas, los controles del software malicioso, y los escritorios limpios);
- e) los puntos de contacto y los recursos para información adicional y asesoría sobre asuntos de seguridad de la información, incluidos los materiales de educación y formación sobre seguridad de la información.

La educación y la formación en seguridad de la información se deberían llevar a cabo periódicamente. La educación y entrenamiento iniciales aplican a quienes se transfieren a nuevos cargos o roles con requisitos de seguridad de la información considerablemente diferentes, no solo para los nuevos empleados, y se deberían llevar a cabo antes de que se active el rol.

La organización debería desarrollar el programa de educación y de formación para impartir la educación y la formación eficazmente. El programa debería estar en línea con las políticas y procedimientos pertinentes de seguridad de la información de la organización, teniendo en cuenta la información de la organización que se va a proteger, y los controles que se han implementado para proteger la información. El programa debería considerar diferentes formas de educación y formación, por ejemplo, conferencias o estudio autónomo.

Información adicional

Cuando se prepara un programa de toma de conciencia es importante enfocarse no solamente en el “qué” y en el “cómo” sino también en el “por qué”. Es importante que los empleados comprendan el objetivo de la seguridad de la información y el impacto potencial, positivo y negativo, que tiene su propio comportamiento para la organización.

La toma de conciencia, la educación y la formación pueden ser parte de otras actividades de formación, por ejemplo, formación general en seguridad o en TI, o se pueden llevar a cabo en colaboración con ellas. Las actividades de toma de conciencia, educación y formación deberían ser adecuadas y pertinentes a los roles, responsabilidades y habilidades de los individuos.

Al finalizar el curso de formación, educación y toma de conciencia, se puede llevar a cabo una evaluación de la comprensión de los empleados para comprobar la transferencia de conocimiento.

7.2.3 Proceso disciplinario

Control

Se debería contar con un proceso disciplinario formal el cual debería ser comunicado, para emprender acciones contra empleados que hayan cometido una violación a la seguridad de la información.

Guía de implementación

El proceso disciplinario no se debería iniciar sin antes verificar que ha ocurrido una violación a la seguridad de la información (véase el numeral 16.1.7).

El proceso disciplinario formal debería asegurar el tratamiento correcto e imparcial a los empleados de quienes se sospecha que han cometido violaciones a la seguridad de la información. El proceso disciplinario formal debería proveer una respuesta gradual que tenga en cuenta factores tales como la naturaleza y la gravedad de la violación y su impacto sobre el negocio; si es o no su primera infracción; si el infractor tenía la formación apropiada; la legislación pertinente; los contratos del negocio y otros factores, según se requiera.

El proceso disciplinario también se debería usar como un elemento disuasivo para prevenir que los empleados violen las políticas y procedimientos de seguridad de la información de la organización, y de cualquier otra violación a la seguridad de la información. Las violaciones deliberadas pueden requerir acciones inmediatas.

Información adicional

El proceso disciplinario también se puede convertir en una motivación, o en un incentivo, si se definen sanciones positivas para un comportamiento destacado con relación a la seguridad de la información.

7.3 TERMINACIÓN Y CAMBIO DE EMPLEO

Objetivo: Proteger los intereses de la organización como parte del proceso de cambio o terminación del empleo.

7.3.1 Responsabilidades en la Terminación o cambio del empleo

Control

Las responsabilidades y los deberes de seguridad de la información que permanecen válidos después de la terminación o cambio de empleo se deberían definir, comunicar al empleado o contratista y se deberían hacer cumplir.

Guía de implementación

La comunicación de las responsabilidades en la terminación debería incluir los requisitos de seguridad de la información y las responsabilidades legales vigentes, y en donde sea apropiado, las responsabilidades contenidas en cualquier acuerdo de confidencialidad (véase el numeral 13.2.4) y los términos y condiciones del empleo (véase el numeral 7.1.2) que continúan después de un período definido, luego de finalizar el empleo del contratista o del empleado.

Las responsabilidades y deberes que siguen siendo válidos después de la terminación del empleo, deberían estar contenidos en los términos y condiciones del empleo del empleado o del contratista (véase el numeral 7.1.2).

Los cambios de responsabilidad o de empleo se deberían manejar como la terminación de la responsabilidad o empleo actual, combinada con el inicio de una nueva responsabilidad o empleo.

Información adicional

Generalmente, Recursos Humanos es responsable del proceso total de terminación del empleo y trabaja en conjunto con el supervisor a cargo de la persona que se retira, para gestionar los aspectos de seguridad de la información de los procedimientos relevantes. En el caso de un contratista suministrado a través de una parte externa, este proceso de terminación lo lleva a cabo dicha parte, de acuerdo con el contrato suscrito entre la organización y la parte externa.

Puede ser necesario informar a los empleados, clientes o contratistas acerca de los cambios de personal y de las disposiciones operativas.

8. GESTIÓN DE ACTIVOS

8.1 RESPONSABILIDAD POR LOS ACTIVOS

Objetivo: Identificar los activos organizacionales y definir las responsabilidades de protección apropiadas.

8.1.1 Inventario de activos

Control

Se deberían identificar la información, otros activos asociados con la información y las instalaciones de procesamiento de información, y se debería elaborar y mantener un inventario de estos activos.

Guía de implementación

Una organización debería identificar los activos pertinentes en el ciclo de vida de la información, y documentar su importancia. El ciclo de vida de la información debería incluir su creación, procesamiento, almacenamiento, transmisión, eliminación y destrucción. La documentación se debería mantener en inventarios dedicados o existentes, según sea apropiado.

El inventario de activos debería ser exacto, actualizado, consistente y alineado con otros inventarios.

Para cada uno de los activos identificados, se debería asignar la propiedad del activo (véase el numeral 8.1.2) y se debería identificar la clasificación (véase el numeral 8.2).

Información adicional

Los inventarios de activos ayudan a asegurar que se cuenta con una protección efectiva, y también pueden ser necesarios para otros propósitos, como por ejemplo razones de salud y seguridad, seguros o asuntos financieros (gestión de activos).

La norma ISO/IEC 27005^[11] proporciona ejemplos de activos que la organización podría tener que considerar cuando se identifican los activos. El proceso de elaborar un inventario de activos es un prerrequisito importante de la gestión del riesgo (véanse también las normas ISO/IEC 27000 e ISO/IEC 27005^[11]).

8.1.2 Propiedad de los activos

Control

Los activos mantenidos en el inventario deberían tener un propietario.

Guía de implementación

Los individuos, así como otras entidades con la responsabilidad delegada sobre la gestión del activo dentro de su ciclo de vida, califican para ser asignados como propietarios de los activos.

Usualmente se implementa un proceso para asegurar la asignación oportuna de la propiedad de los activos. La propiedad se debería asignar cuando los activos se crean o cuando son transferidos a la organización. El propietario de un activo debería ser responsable de su gestión apropiada durante todo su ciclo de vida.

El propietario del activo debería:

- a) asegurarse de que los activos están inventariados;
- b) asegurarse de que los activos están clasificados y protegidos apropiadamente;
- c) definir y revisar periódicamente las restricciones y clasificaciones de acceso a activos importantes, teniendo en cuenta las políticas de control de acceso aplicables;
- d) asegurarse del manejo apropiado del activo cuando es eliminado o destruido.

Información adicional

El propietario identificado puede ser un individuo o una entidad que tenga la responsabilidad delegada sobre la gestión para controlar todo el ciclo de vida de un activo. El propietario identificado no necesariamente tiene algún derecho de propiedad sobre el activo.

Las tareas de rutina pueden ser delegadas, por ejemplo, a un custodio que vela por los activos diariamente, pero la responsabilidad sigue siendo del propietario.

En sistemas de información complejos, puede ser útil designar grupos de activos que actúan conjuntamente para brindar un servicio particular. En este caso, el propietario de este servicio rinde cuentas por la prestación del servicio, incluida la operación de sus activos.

8.1.3 Uso aceptable de los activos

Control

Se deberían identificar, documentar e implementar reglas para el uso aceptable de información y de activos asociados con información e instalaciones de procesamiento de información.

Guía de implementación

Los empleados y usuarios de partes externas que usan activos de la organización o tienen acceso a ellos deberían tomar conciencia de los requisitos de seguridad de la información de la organización, de los activos de la organización asociados con información y con instalaciones y recursos de procesamiento de información. Deberían ser responsables del uso que hacen de cualquier recurso de procesamiento de la información, y de cualquier uso ejecutado bajo su responsabilidad.

8.1.4 Devolución de activos

Control

Todos los empleados y usuarios de partes externas deberían devolver todos los activos de la organización que se encuentren a su cargo, al terminar su empleo, contrato o acuerdo.

Guía de implementación

El proceso de terminación se debería formalizar para incluir la devolución de todos los activos físicos y electrónicos entregados previamente, que son propiedad de la organización o que se le han confiado a ella.

En los casos en que el empleado o parte externa compre el equipo de la organización o use su propio equipo personal, se deberían seguir procedimientos para asegurar que toda la información pertinente sea transferida a la organización y borrada del equipo en forma segura (véase el numeral 11.2.7).

En los casos en que un empleado o usuario de una parte externa tenga conocimientos que son importantes para las operaciones en curso, esa información se debería documentar y transferir a la organización.

Durante el período de notificación de la terminación, la organización debería controlar el copiado no autorizado de la información pertinente (por ejemplo, la propiedad intelectual) por parte de los empleados o contratistas que han finalizado el empleo.

8.2 CLASIFICACIÓN DE LA INFORMACIÓN

Objetivo: Asegurar que la información recibe un nivel apropiado de protección, de acuerdo con su importancia para la organización.

8.2.1 Clasificación de la información

Control

La información se debería clasificar en función de los requisitos legales, valor, criticidad y susceptibilidad a divulgación o a modificación no autorizada.

Guía de implementación

Las clasificaciones y controles de protección de información asociados deberían tener en cuenta las necesidades del negocio en cuanto a intercambio o restricción de información, al igual que los requisitos legales. Los activos diferentes de información también se pueden clasificar de conformidad con la clasificación de la información que se almacena, procesa, maneja o protege el activo.

Los propietarios de los activos de información deberían rendir cuentas por su clasificación.

El esquema de clasificación debería incluir las convenciones para la clasificación y los criterios para la revisión de la clasificación en el tiempo. El nivel de protección en el esquema se debería evaluar analizando la confidencialidad, la integridad y la disponibilidad, y cualquier otro requisito para la información considerada. El esquema se debería alinear con la política de control de acceso (véase el numeral 9.1.1).

Cada nivel debería recibir un nombre que tenga sentido en el contexto de la aplicación del esquema de clasificación.

El esquema debería ser consistente a lo largo y ancho de la organización, de manera que todos clasifiquen la información y los activos relacionados de la misma manera, tengan una comprensión común de los requisitos de protección, y apliquen la protección apropiada.

La clasificación se debería incluir en los procesos de la organización, y debería ser consistente y coherente en toda la organización. Los resultados de la clasificación deberían indicar el valor de los activos dependiendo de su sensibilidad y criticidad para la organización, por ejemplo, en términos de confidencialidad, integridad y disponibilidad. Los resultados de la clasificación se deberían actualizar de acuerdo con los cambios en su valor, sensibilidad y criticidad durante el ciclo de vida.

Información adicional

La clasificación brinda a las personas que tratan con información, una indicación concisa de cómo manejarla y protegerla. Esto se facilita mediante la creación de grupos de información con necesidades de protección similares, y la especificación de procedimientos que se apliquen a toda la información en cada grupo. Este enfoque reduce la necesidad de valorar los riesgos caso por caso, y de diseñar controles a la medida.

La información puede dejar de ser sensible o crítica después de cierto período de tiempo, por ejemplo, cuando la información se ha hecho pública. Estos aspectos se deberían tener en cuenta, ya que la clasificación excesiva puede conducir a la implementación de controles innecesarios que generan gastos adicionales, o por el contrario, clasificación deficiente que pone en peligro el logro de los objetivos del negocio.

Un ejemplo del esquema de clasificación de la confidencialidad de la información se puede basar en los cuatro niveles siguientes:

- a) la divulgación no causa daño;
- b) la divulgación causa algo de vergüenza o un inconveniente operativo menor;
- c) la divulgación tiene un impacto significativo a corto plazo en las operaciones u objetivos tácticos;

- d) la divulgación tiene un serio impacto en los objetivos estratégicos a largo plazo, o pone en riesgo la supervivencia de la organización.

8.2.2 Etiquetado de la información

Control

Se debería desarrollar e implementar un conjunto adecuado de procedimientos para el etiquetado de la información, de acuerdo con el esquema de clasificación de información adoptado por la organización.

Guía de implementación

Los procedimientos para el etiquetado de información necesitan abarcar la información y sus activos relacionados en formatos físicos y electrónicos. El etiquetado debería reflejar el esquema de clasificación establecido en el numeral 8.2.1. Las etiquetas se deberían poder reconocer fácilmente. Los procedimientos deberían brindar orientación acerca de dónde y cómo se colocan las etiquetas, teniendo en cuenta la forma en que se obtiene el acceso a la información o se manejan los activos, dependiendo de los tipos de medio. Los procedimientos pueden definir casos en los que se omite el etiquetado, por ejemplo, el etiquetado de información no confidencial para reducir cargas de trabajo. Los empleados y contratistas deberían tomar conciencia de los procedimientos de etiquetado.

Las salidas de los sistemas que contienen información que se clasifica como sensible o crítica debería portar una etiqueta de clasificación apropiada.

Información adicional

El etiquetado de la información clasificada es un requisito clave para las disposiciones sobre intercambio de información. Las etiquetas físicas y los metadatos son una forma común de etiquetado.

El etiquetado de la información y de sus activos relacionados algunas veces tiene efectos negativos. Los activos clasificados son más fáciles de identificar, y en consecuencia, más fáciles de ser hurtados por atacantes internos o externos.

8.2.3 Manejo de activos

Control

Se deberían desarrollar e implementar procedimientos para el manejo de activos, de acuerdo con el esquema de clasificación de información adoptado por la organización.

Guía de implementación

Se deberían elaborar procedimientos para el manejo, procesamiento, almacenamiento y comunicación de información de conformidad con su clasificación (véase el numeral 8.2.1).

Se deberían considerar los siguientes asuntos:

- a) las restricciones de acceso que soportan los requisitos de protección para cada nivel de clasificación;
- b) el mantenimiento de un registro formal de los receptores autorizados de los activos;

- c) la protección de copias temporales o permanentes de información a un nivel coherente con la protección de la información original;
- d) el almacenamiento de los activos de TI de acuerdo con las especificaciones de los fabricantes;
- e) el marcado claro de todas las copias de medios para el cuidado del receptor autorizado.

Es posible que el esquema de clasificación usado en la organización no sea equivalente a los esquemas usados por otras organizaciones, aunque sus nombres sean similares; además, la información que se transfiere entre las organizaciones puede variar en su clasificación, dependiendo de su contexto en cada organización, aun cuando sus esquemas de clasificación sean idénticos.

Los acuerdos con otras organizaciones que incluyan intercambio de información deberían incluir procedimientos para identificar la clasificación de esa información y para interpretar las etiquetas de clasificación de otras organizaciones.

8.3 MANEJO DE MEDIOS

Objetivo: Evitar la divulgación, la modificación, el retiro o la destrucción no autorizados de información almacenada en los medios.

8.3.1 Gestión de medios removibles

Control

Se deberían implementar procedimientos para la gestión de medios removibles, de acuerdo con el esquema de clasificación adoptado por la organización.

Guía de implementación

Se deberían considerar las siguientes directrices para la gestión de medios removibles:

- a) Si ya no se requiere, el contenido de cualquier medio reusable que se vaya a retirar de la organización se debería remover de forma que no sea recuperable;
- b) cuando resulte necesario y práctico, se debería solicitar autorización para retirar los medios de la organización, y se debería llevar un registro de dichos retiros con el fin de mantener un rastro de auditoría (*Audit Trail*);
- c) todos los medios se deberían almacenar en un ambiente protegido y seguro, de acuerdo con las especificaciones de los fabricantes;
- d) si la confidencialidad o integridad de los datos se consideran importantes, se deberían usar técnicas criptográficas para proteger los datos que se encuentran en los medios removibles;
- e) para mitigar el riesgo de degradación de los medios mientras aún se necesitan los datos almacenados, los datos se deberían transferir a medios diferentes antes de que se vuelvan ilegibles;
- f) se deberían guardar varias copias de los datos valiosos en medios separados, para reducir aún más el riesgo de daño o pérdida simultánea de los datos;

- g) se debería considerar el registro de los medios removibles para reducir la oportunidad de pérdida de datos;
- h) sólo se deberían habilitar unidades de medios removibles si hay una razón de negocio para hacerlo;
- i) en donde hay necesidad de usar medios removibles, se debería hacer seguimiento a la transferencia de información a estos medios.

Los procedimientos y niveles de autorización se deberían documentar.

8.3.2 Disposición de los medios

Control

Se debería disponer en forma segura de los medios cuando ya no se requieran, utilizando procedimientos formales.

Guía de implementación

Se deberían establecer procedimientos formales para la disposición segura de los medios, para minimizar el riesgo de fuga de información confidencial a personas no autorizadas. Los procedimientos para la disposición segura de los medios que contienen información confidencial deberían ser proporcionales a lo sensible de esa información. Se deberían considerar los siguientes asuntos:

- a) los medios que contienen información confidencial se deberían almacenar y disponer en forma segura, por ejemplo, mediante incineración, destrucción, o el borrado de datos antes de ser usado por otra aplicación dentro de la organización;
- b) se debería contar con procedimientos para identificar los elementos que podrían requerir su disposición segura;
- c) puede ser más fácil hacer arreglos para todos los medios que se van a recolectar y disponerlos en forma segura, que intentar separarlos de los elementos críticos
- d) muchas organizaciones ofrecen servicios de recolección y disposición de medios; es conveniente seleccionar cuidadosamente una parte externa adecuada, con controles y experiencia adecuados;
- e) la disposición de los elementos críticos se debería registrar (*Logged*) con el fin de mantener un rastro de auditoría (*Audit Trail*).

Cuando se acumulan los medios para su disposición, se debería tener en cuenta el efecto de agregación, que puede hacer que una gran cantidad de información no sensible se vuelva sensible.

Información adicional

Los dispositivos dañados que contienen datos sensibles pueden requerir una valoración de riesgos para determinar si los elementos se deberían destruir físicamente en vez de enviarlos a reparación o desecharlos (véase el numeral 11.2.7).

8.3.3 Transferencia de medios físicos

Control

Los medios que contienen información se deberían proteger contra acceso no autorizado, uso indebido o corrupción durante el transporte.

Guía de implementación

Las siguientes directrices se deberían considerar para la protección de medios que contienen información, durante el transporte:

- a) se debería usar un transporte o servicios de mensajería confiables;
- b) se debería acordar con la dirección una lista de servicios de mensajería autorizados;
- c) se deberían desarrollar procedimientos para verificar la identificación de los servicios de mensajería;
- d) el embalaje debería ser suficiente para proteger el contenido contra cualquier daño físico que pudiera presentarse durante el tránsito, y de acuerdo con las especificaciones de los fabricantes, por ejemplo, protección contra cualquier factor ambiental que pueda reducir la eficacia de la restauración del medio, tal como exposición al calor, humedad o campos electromagnéticos;
- e) se debería llevar un registro (*Logs*) que identifique el contenido de los medios, la protección aplicada, al igual que los tiempos de transferencia a los responsables durante el transporte, y el recibo en su destino.

Información adicional

La información puede ser vulnerable al acceso no autorizado, al uso indebido o corrupción durante el transporte físico, por ejemplo, cuando se envía por el servicio postal o por un servicio de mensajería. En este control, los medios incluyen documentos en papel.

Cuando la información confidencial en los medios no está cifrada, se debería considerar la protección física adicional de los medios.

9. CONTROL DE ACCESO

9.1 REQUISITOS DEL NEGOCIO PARA CONTROL DE ACCESO

Objetivo: Limitar el acceso a información y a instalaciones de procesamiento de información.

9.1.1 Política de control de acceso

Control

Se debería establecer, documentar y revisar una política de control de acceso con base en los requisitos del negocio y de seguridad de la información.

Guía de implementación

Los propietarios de los activos deberían determinar las reglas de control de acceso apropiadas, los derechos de acceso y las restricciones para los roles de usuario específicos con relación a sus activos, con la cantidad de detalle y severidad de los controles, que reflejen los riesgos de seguridad de la información asociados.

Los controles de acceso son tanto lógicos como físicos (véase el numeral 11) y se deberían considerar en conjunto. Se debería dar a los usuarios y a los proveedores de servicios una indicación clara de los requisitos del negocio que deben cumplir los controles de acceso.

La política debería tener en cuenta lo siguiente:

- a) los requisitos de seguridad para las aplicaciones del negocio;
- b) las políticas para la divulgación y autorización de la información, por ejemplo, el principio de lo que se necesita conocer, y los niveles de seguridad de la información y de clasificación de la información (véase el numeral 8.2);
- c) la coherencia entre los derechos de acceso y las políticas de clasificación de información de los sistemas y redes;
- d) la legislación pertinente y cualquier obligación contractual concerniente a la limitación del acceso a datos o servicios (véase el numeral 18.1);
- e) la gestión de los derechos de acceso en un entorno distribuido y en red, que reconoce todos los tipos de conexiones disponibles;
- f) la segregación de los roles de control de acceso, por ejemplo, solicitud de acceso, autorización de acceso, administración del acceso;
- g) los requisitos para la autorización formal de las solicitudes de acceso (véanse los numerales 9.2.1 y 9.2.2);
- h) los requisitos para la revisión periódica de los derechos de acceso (véase el numeral 9.2.5);
- i) el retiro de los derechos de acceso (véase el numeral 9.2.6);
- j) el almacenamiento de los registros de todos los eventos significativos concernientes al uso y gestión de identificación de los usuarios, e información secreta para la autenticación;
- k) los roles de acceso privilegiado (véase el numeral 9.2.3);

Información adicional

Cuando se especifican las reglas de control de acceso se debería considerar:

- a) establecer reglas basadas en la premisa “En general, todo está prohibido, a menos que se permita expresamente”, y no en la menos estricta: “En general, todo está permitido, a menos que se prohíba expresamente”;

- b) los cambios en las etiquetas de información (véase el numeral 8.2.2) que son iniciados automáticamente por las instalaciones de procesamiento de información, y los que se inician a discreción del usuario.
- c) los cambios en los permisos de usuario que son iniciados automáticamente por el sistema de información, y los iniciados por un administrador;
- d) las reglas que requieren aprobación específica antes de su promulgación, y las que no requieren aprobación.

Las reglas de control de acceso deberían ir soportadas en procedimientos formales (véanse los numerales 9.2, 9.3, 9.4) y en responsabilidades definidas (véanse los numerales 6.1.1, y 9.3)

El control de acceso basado en roles es un enfoque usado con éxito por muchas organizaciones para establecer un vínculo entre los derechos de acceso y los roles del negocio.

Dos de los principios frecuentes que dirigen la política de control de acceso son:

- a) lo que necesita conocer: solamente se concede acceso a la información que la persona necesita para la realización de sus tareas (diferentes tareas/roles significan diferentes cosas que se necesita saber, y en consecuencia, diferentes perfiles de acceso);
- b) lo que necesita usar: solamente se le concede acceso a las instalaciones de procesamiento de información (equipos de TI, aplicaciones, procedimientos, recintos) que la persona necesita para la realización de su tarea/trabajo/rol.

9.1.2 Acceso a redes y a servicios en red

Control

Solo se debería permitir acceso de los usuarios a la red y a los servicios de red para los que hayan sido autorizados específicamente.

Guía de implementación

Se debería formular una política acerca del uso de redes y de servicios de red. Esta política debería cubrir:

- a) las redes y servicios de red a los que se permite el acceso;
- b) los procedimientos de autorización para determinar a quién se permite el acceso a qué redes y servicios de red;
- c) los controles y procedimientos de gestión para proteger el acceso a las conexiones de red y a los servicios de red;
- d) los medios usados para acceder a las redes y servicios de red (por ejemplo, el uso de VPN o redes inalámbricas);
- e) los requisitos de autenticación de usuarios para acceder a diversos servicios de red;
- f) el monitoreo del uso de servicios de red.

La política sobre el uso de los servicios de red debería ser coherente con la política de control de acceso de la organización (véase el numeral 9.1.1).

Información adicional

Las conexiones no autorizadas y no seguras a los servicios de red pueden afectar a toda la organización. Este control es particularmente importante para conexiones de red o aplicaciones de negocios críticas o sensibles o para usuarios en sitios de alto riesgo, por ejemplo, áreas públicas o externas que se encuentran por fuera de la gestión y control de seguridad de la información de la organización.

9.2 GESTIÓN DE ACCESO DE USUARIOS

Objetivo: Asegurar el acceso de los usuarios autorizados y evitar el acceso no autorizado a sistemas y servicios.

9.2.1 Registro y cancelación del registro de usuarios

Control

Se debería implementar un proceso formal de registro y de cancelación de registro de usuarios, para posibilitar la asignación de los derechos de acceso.

Guía de implementación

El proceso para gestionar la identificación de los usuarios debería incluir:

- a) Usar identificaciones únicas que permitan asociar a los usuarios con sus actividades y hacerlos responsables de sus acciones; el uso de identificaciones compartidas solo se deberían permitir cuando sea necesario por razones operativas o del negocio, y se deberían aprobar y documentar;
- b) deshabilitar o retirar inmediatamente las identificaciones de los usuarios que han dejado la organización (véase el numeral 9.2.6);
- c) identificar y eliminar o deshabilitar periódicamente las identificaciones de usuario redundantes;
- d) asegurar que las identificaciones de usuario redundantes no se asignen a otros usuarios.

Información adicional

Suministrar o revocar el acceso a la información o a las instalaciones de procesamiento de información es habitualmente un procedimiento de dos pasos:

- a) asignar y habilitar o revocar una identificación de usuario;
- b) suministrar o revocar los derechos de acceso a esta identificación de usuario (véase el numeral 9.2.2).

9.2.2 Suministro de acceso de usuarios

Control

Se debería implementar un proceso de suministro de acceso formal de usuarios para asignar o revocar los derechos de acceso para todo tipo de usuarios para todos los sistemas y servicios.

Guía de implementación

El proceso de suministro para asignar o revocar los derechos de acceso otorgados a las identificaciones de usuario debería incluir:

- a) obtener autorización del propietario del sistema de información o servicio para el uso del sistema de información o servicio (véase el control 8.1.2); también puede ser apropiada la aprobación separada de los derechos de acceso por parte de la dirección;
- b) verificar que el nivel de acceso otorgado es apropiado a las políticas de acceso (véase el numeral 9.1) y es coherente con otros requisitos, tales como la segregación de funciones (véase el numeral 6.1.2);
- c) asegurar que los derechos de acceso no estén activados (por ejemplo, por proveedores de servicio) antes de que los procedimientos de autorización estén completos;
- d) mantener un registro central de los derechos de acceso suministrados a una identificación de usuario para acceder a sistemas de información y servicios;
- e) adaptar los derechos de acceso de usuarios que han cambiado de roles o de empleo, y retirar o bloquear inmediatamente los derechos de acceso de los usuarios que han dejado la organización;
- f) revisar periódicamente los derechos de acceso con los propietarios de los sistemas de información o servicios (véase el numeral 9.2.5).

Información adicional

Se debería considerar el establecimiento de los roles de acceso de usuarios con base en los requisitos del negocio que resumen varios derechos de acceso en perfiles típicos de acceso de usuario. Las solicitudes y revisiones de acceso (véase el numeral 9.2.4) se gestionan más fácilmente al nivel de estos roles que al nivel de derechos particulares.

Se debería considerar la inclusión, en los contratos del personal y en los contratos de servicio, numerales que especifiquen sanciones si miembros del personal o contratistas intentan acceso no autorizado (véanse los numerales 7.1.2, 7.2.3, 13.2.4, 15.1.2).

9.2.3 Gestión de derechos de acceso privilegiado

Control

Se debería restringir y controlar la asignación y uso de derechos de acceso privilegiado.

Guía de implementación:

La asignación de derechos de acceso privilegiado se debería controlar mediante un proceso de autorización formal de acuerdo con la política de control de acceso pertinente (véase el control 9.1.1). Se deberían considerar los siguientes pasos:

- a) se deberían identificar los derechos de acceso privilegiado asociados con cada sistema o proceso, por ejemplo, sistema operativo, sistema de gestión de bases de datos, y cada aplicación y los usuarios a los que es necesario asignar;
- b) los derechos de acceso privilegiado se deberían asignar a usuarios con base en la necesidad de uso y caso por caso, en línea con la política de control de acceso (véase el numeral 9.1.1), es decir, con base en el requisito mínimo para sus roles funcionales;
- c) se debería mantener un proceso de autorización y un registro de todos los privilegios asignados. Sólo se deberían suministrar derechos de acceso cuando el proceso de autorización esté completo;
- d) se deberían definir los requisitos para la expiración de los derechos de acceso privilegiado;
- e) los derechos de acceso privilegiado se deberían asignar a una identificación de usuario diferente de la usada para las actividades regulares del negocio. Las actividades regulares del negocio no se deberían ejecutar desde una identificación privilegiada;
- f) las competencias de los usuarios con derechos de acceso privilegiado se deberían revisar con regularidad para verificar si están en línea con sus deberes;
- g) se deberían establecer y mantener procedimientos específicos para evitar el uso no autorizado de identificaciones de usuario de administración genérica, de acuerdo con las capacidades de configuración del sistema;
- h) para las identificaciones de usuario de administración genérica, se debería mantener la confidencialidad de la información secreta para la autenticación cuando se comparta (por ejemplo, cambiar las contraseñas con frecuencia, y tan pronto como sea posible cuando un usuario privilegiado ha dejado el trabajo o cambia de trabajo, comunicarlas entre los usuarios privilegiados con los mecanismos apropiados).

Información adicional

El uso inapropiado de los privilegios del sistema de administración (cualquier característica o función de un sistema de información que posibilita que el usuario anule el sistema o los controles de aplicación) es un factor que contribuye a las fallas o violaciones a los sistemas.

9.2.4 Gestión de información secreta para la autenticación de usuarios (*Management of Secret Authentication Information of Users*)Control

La asignación de información de autenticación secreta se debería controlar por medio de un proceso de gestión formal.

Guía de implementación

Este proceso debería incluir los siguientes requisitos:

- a) se debería pedir a los usuarios que firmen una declaración para mantener confidencial la información secreta para la autenticación personal, y mantener la información secreta para la autenticación del grupo (es decir, compartida) únicamente dentro de los miembros del grupo; esta declaración firmada se puede incluir en los términos y condiciones del empleo (véase el numeral 7.1.2);
- b) cuando se les pide a los usuarios mantener su propia información secreta para la autenticación, inicialmente se les debería suministrar información secreta y segura, que sea temporal para dicha autenticación, y se debería obligarles a cambiar dicha información, al usarla por primera vez;
- c) se deberían establecer procedimientos para verificar la identidad de un usuario antes de reemplazar la información secreta para la autenticación o proporcionar una nueva o temporal;
- d) la información secreta para la autenticación temporal se le debería suministrar a los usuarios de una manera segura; se debería evitar el uso de partes externas o de mensajes de correo electrónico no protegidos (texto claro);
- e) la información secreta para la autenticación temporal debería ser única para un individuo y no debería ser fácil de adivinar;
- f) los usuarios deberían acusar recibo de la información secreta para la autenticación;
- g) la información secreta para la autenticación por defecto, del fabricante, se debería modificar después de la instalación de los sistemas o software.

Información adicional

Las contraseñas son un tipo de información secreta para la autenticación usadas comúnmente, y son un medio común para verificar la identidad del usuario. Otros tipos de información secreta para la autenticación son las llaves criptográficas y otros datos almacenados en *tokens* de hardware (por ejemplo, tarjetas inteligentes) que producen códigos de autenticación.

9.2.5 Revisión de los derechos de acceso de usuariosControl

Los propietarios de los activos deberían revisar los derechos de acceso de los usuarios, a intervalos regulares.

Guía de implementación

La revisión de los derechos de acceso debería considerar lo siguiente:

- a) los derechos de acceso de los usuarios se deberían revisar a intervalos regulares y después de cualquier cambio, promoción, cambio a un cargo a un nivel inferior, o terminación del empleo (véase el numeral 7);

- b) los derechos de acceso de usuario se deberían revisar y reasignar cuando pasan de un rol a otro dentro de la misma organización;
- c) las autorizaciones para los derechos de acceso privilegiado se deberían revisar a intervalos más frecuentes;
- d) las asignaciones de privilegios se deberían verificar a intervalos regulares para asegurar que no se hayan obtenido privilegios no autorizados;
- e) los cambios a las cuentas privilegiadas se deberían registrar (*Logged*) para revisión periódica.

Información adicional

Este control compensa las posibles debilidades en la ejecución de los controles 9.2.1, 9.2.2 y 9.2.6.

9.2.6 Retiro o ajuste de los derechos de acceso

Control

Los derechos de acceso de todos los empleados y de usuarios externos a la información y a las instalaciones de procesamiento de información se deberían retirar al terminar su empleo, contrato o acuerdo, o se deberían ajustar cuando se hagan cambios.

Guía de implementación

Al terminar, los derechos de acceso de un individuo a información o a activos asociados con las instalaciones y servicios de procesamiento de la información se deberían retirar o suspender. Esto determinará si es necesario retirar los derechos de acceso. Los cambios de empleo se deberían reflejar en el retiro de todos los derechos de acceso que no fueron aprobados para el nuevo empleo. Los derechos de acceso que se deberían retirar o ajustar incluyen los de acceso físico y lógico. El retiro o ajuste se puede hacer mediante el retiro, revocación o reemplazo de llaves, tarjetas de identificación, instalaciones de procesamiento de información o suscripciones. Cualquier documentación que identifique los derechos de acceso de empleados y contratistas debería reflejar el retiro o ajuste de los derechos de acceso. Si un empleado o usuario de una parte externa que deja la empresa tiene contraseñas conocidas de usuarios que continúan activos, se deberían cambiar al terminar o cambiar de cargo o empleo, contrato o acuerdo.

Los derechos de acceso a la información y a los activos asociados con instalaciones de procesamiento de información se deberían reducir o retirar antes de que el empleo termine o cambie, dependiendo de la evaluación de factores de riesgo tales como:

- a) si la terminación o cambio lo inicia el empleado, el usuario de la parte externa o la dirección, y la razón de la terminación;
- b) las responsabilidades actuales del empleado, el usuario de la parte externa o cualquier otro usuario;
- c) el valor de los activos accesibles en la actualidad.

Información adicional

En algunas circunstancias, los derechos de acceso se pueden asignar con base en la disponibilidad para más personas, además del empleado o el usuario de la parte externa que deja la organización, por ejemplo, identificaciones de grupo. En estas circunstancias, los individuos que dejan la organización se deberían retirar de cualquier lista de acceso de grupo, y se debería contar con disposiciones para advertir a todos los otros empleados y usuarios de partes externas involucrados, para que dejen de compartir esta información con estos individuos.

En los casos de terminación iniciada por la dirección, los empleados o usuarios de partes externas que se encuentren descontentos pueden corromper la información deliberadamente o sabotear las instalaciones de procesamiento de información. En el caso de personas que renuncian o que son despedidas, se pueden sentir tentadas a recolectar información para uso futuro.

9.3 RESPONSABILIDADES DE LOS USUARIOS

Objetivo: Hacer que los usuarios rindan cuentas por la salvaguarda de su información de autenticación.

9.3.1 Uso de información secreta para la autenticación.Control

Se debería exigir a los usuarios que cumplan las prácticas de la organización para el uso de información secreta para la autenticación.

Guía de implementación

Se debería notificar a todos los usuarios que:

- a) Mantengan la confidencialidad de la información secreta para la autenticación, asegurándose de que no sea divulgada a ninguna otra parte, incluidas las personas con autoridad;
- b) eviten llevar un registro (por ejemplo, en papel, en un archivo de software o en un dispositivo portátil) de la información secreta para la autenticación, a menos que se pueda almacenar en forma segura y que el método de almacenamiento haya sido aprobado (por ejemplo, una bóveda para contraseñas);
- c) cambien la información secreta para la autenticación siempre que haya cualquier indicio de que se pueda comprometer la información;
- d) cuando se usan contraseñas como información secreta para la autenticación, seleccione contraseñas de calidad con una longitud mínima suficiente que:
 - 1) sean fáciles de recordar;
 - 2) no estén basadas en algo que otra persona pueda adivinar fácilmente u obtener usando información relacionada con la persona, por ejemplo, nombres, números de teléfono y fechas de nacimiento, etc.;
 - 3) no sean vulnerables a ataques de diccionario (es decir, no contienen palabras incluidas en los diccionarios);

- 4) estén libres de caracteres completamente numéricos o alfabéticos idénticos consecutivos;
- 5) si son temporales, cambiarlas la primera vez que se ingrese;
- e) no compartan información secreta para la autenticación del usuario individual;
- f) aseguren la protección apropiada de contraseñas cuando se usan éstas como Información secreta para la autenticación en procedimientos automatizados de ingreso (*Log-On*) y estén almacenadas
- g) no usen la misma información secreta para la autenticación para propósitos de negocio y otros diferentes de éstos.

Información adicional

El suministro de un *Single Sign On* (SSO) u otras herramientas de gestión de información secreta para la autenticación reduce la cantidad de información secreta para la autenticación que los usuarios deben proteger, y de esta manera se incrementa la eficacia de este control. Sin embargo, estas herramientas también pueden incrementar el impacto de la divulgación de información secreta para la autenticación.

9.4 CONTROL DE ACCESO A SISTEMAS Y APLICACIONES

Objetivo: Evitar el acceso no autorizado a sistemas y aplicaciones.

9.4.1 Restricción de acceso a la información

Control

El acceso a la información y a la funcionalidad de las aplicaciones se debería restringir de acuerdo con la política de control de acceso.

Guía de implementación

Las restricciones de acceso se deberían basar en los requisitos de la aplicación individual del negocio y de acuerdo con la política de control de acceso definida.

Se debería considerar lo siguiente como soporte a los requisitos de restricción de acceso:

- a) suministrar menús para controlar el acceso a la funcionalidad de las aplicaciones;
- b) controlar a qué datos puede tener acceso un usuario particular;
- c) controlar los derechos de acceso de los usuarios, por ejemplo, a leer, escribir, borrar y ejecutar;
- d) controlar los derechos de acceso de otras aplicaciones;
- e) limitar la información contenida en las salidas;
- f) proveer controles de acceso físico o lógico para el aislamiento de aplicaciones, datos de aplicaciones o sistemas críticos.

9.4.2 Procedimiento de ingreso (*Log-On*) seguro

Control

Cuando lo requiere la política de control de acceso, el acceso a sistemas y aplicaciones se debería controlar mediante un proceso de ingreso seguro.

Guía de implementación

Se debería escoger una técnica de autenticación adecuada para corroborar la identidad declarada de un usuario.

En donde se requiere una verificación de la identidad y autenticación fuerte, se deberían usar métodos de autenticación alternativos a las contraseñas, tales como medios criptográficos, tarjetas inteligentes, *tokens* o medios biométricos.

Se debería diseñar el procedimiento para ingresar (*Logging*) a un sistema o aplicación, para minimizar la oportunidad de acceso no autorizado. Por tanto, el procedimiento de ingreso (*Log-On*) debería divulgar la mínima información acerca del sistema o aplicación, con el fin de evitar que se suministre asistencia innecesaria a un usuario no autorizado.

Un procedimiento de ingreso (*Log-On*) adecuado debería:

- a) no visualizar los identificadores del sistema o de la aplicación sino hasta que el proceso de ingreso (*Log-On*) se haya completado exitosamente;
- b) visualizar una advertencia general acerca de que sólo los usuarios autorizados pueden acceder al computador;
- c) evitar los mensajes de ayuda durante el procedimiento de ingreso (*log-on*), que ayudarían a un usuario no autorizado;
- d) validar la información de ingreso (*Log-On*) solamente al completar todos los datos de entrada. Si surge una condición de error, el sistema no debería indicar qué parte de los datos es correcta o incorrecta;
- e) proteger contra intentos de ingreso (*Log-On*) mediante fuerza bruta;
- f) llevar un registro (*Log*) con los intentos exitosos y fallidos;
- g) declarar un evento de seguridad si se detecta un intento potencial o una violación exitosa de los controles de ingreso (*Log-On*) seguro;
- h) visualizar la siguiente información al terminar un ingreso (*log-on*) exitoso:
 - 1) la fecha y la hora del ingreso (*Log-On*) previo exitoso;
 - 2) los detalles de cualquier intento de ingreso (*Log-On*) no exitoso desde el último ingreso (*Log-On*) exitoso;
- i) no visualizar una contraseña que se esté ingresando;
- j) no transmitir contraseñas en texto claro en una red;

- k) terminar sesiones inactivas después de un período de inactividad definido, especialmente en lugares de alto riesgo tales como áreas públicas o externas por fuera de la gestión de seguridad de la organización o en dispositivos móviles;
- l) restringir los tiempos de conexión para brindar seguridad adicional para aplicaciones de alto riesgo y para reducir la ventana de oportunidad para acceso no autorizado.

Información adicional

Las contraseñas son una forma común para brindar identificación y autenticación con base en un secreto que solamente conoce el usuario. Lo mismo se puede lograr con medios criptográficos y protocolos de autenticación. La fortaleza de la autenticación de usuario debería ser apropiada para la clasificación de la información a la que se va a acceder.

Si las contraseñas se transmiten en texto claro (*Clear Text*) durante la sesión de ingreso a la red, pueden ser capturadas por un programa “sniffer” de redes.

9.4.3 Sistema de gestión de contraseñas

Control

Los sistemas de gestión de contraseñas deberían ser interactivos y deberían asegurar la calidad de las contraseñas.

Guía de implementación

Un sistema de gestión de contraseñas debería:

- a) hacer cumplir el uso de identificaciones y contraseñas de usuarios individuales para mantener la rendición de cuentas;
- b) permitir que los usuarios seleccionen y cambien sus propias contraseñas e incluyan un procedimiento de confirmación para permitir los errores de entrada;
- c) Exigir que se escojan contraseñas de calidad;
- d) Forzar a los usuarios a cambiar sus contraseñas cuando ingresan por primera vez;
- e) exigir que se cambien las contraseñas en forma regular, según sea necesario;
- f) llevar un registro de las contraseñas usadas previamente, e impedir su reuso;
- g) no visualizar contraseñas en la pantalla cuando se está ingresando;
- h) almacenar los archivos de las contraseñas separadamente de los datos del sistema de aplicación (*Application System Data*);
- i) almacenar y transmitir las contraseñas en forma protegida.

Información adicional

Algunas aplicaciones exigen que una autoridad independiente asigne las contraseñas de usuario; en estos casos, no se aplican los literales b), d) y e) anteriores. En la mayoría de casos, los usuarios son quienes seleccionan y mantienen las contraseñas.

9.4.4 Uso de programas utilitarios privilegiados

Control

Se debería restringir y controlar estrictamente el uso de programas utilitarios que podrían tener capacidad de anular el sistema y los controles de las aplicaciones.

Guía de implementación

Se deberían considerar las siguientes directrices para el uso de programas utilitarios que pudieran tener capacidad de anular los controles de sistemas y de aplicaciones.

- a) el uso de procedimientos de identificación, autenticación y autorización para los programas utilitarios;
- b) la segregación de los programas utilitarios del software de aplicaciones;
- c) la limitación del uso de programas utilitarios al número mínimo práctico de usuarios confiables y autorizados (véase el numeral 9.2.3);
- d) la autorización para el uso adhoc de programas utilitarios;
- e) la limitación de la disponibilidad de los programas utilitarios, por ejemplo, para la duración de un cambio autorizado;
- f) el registro (*logging*) de uso de los programas utilitarios;
- g) la definición y documentación de los niveles de autorización para los programas utilitarios;
- h) el retiro o deshabilitación de todos los programas utilitarios innecesarios;

No poner a disposición los programas utilitarios a los usuarios que tengan acceso a aplicaciones en sistemas, en donde se requiera la segregación de funciones

Información adicional

La mayoría de instalaciones de cómputo tienen uno o más programas utilitarios que podrían tener capacidad para anular los controles de sistemas y aplicaciones.

9.4.5 Control de acceso a códigos fuente de programas

Control

Se debería restringir el acceso a los códigos fuente de los programas.

Guía de implementación

Se debería controlar estrictamente el acceso a los códigos fuente de programas y elementos asociados (tales como diseños, especificaciones, planes de verificación y planes de validación), con el fin de evitar la introducción de funcionalidad no autorizada y para evitar cambios involuntarios y mantener la confidencialidad de propiedad intelectual valiosa.

Para los códigos fuente de los programas, esto se puede lograr mediante el almacenamiento central controlado de estos códigos, preferiblemente en librerías de fuentes de programas. Se deberían considerar las siguientes directrices para controlar el acceso a dichas librerías de fuentes de programa, para reducir el potencial de corrupción de los programas de computador:

- a) Donde sea posible, las librerías de programas fuente, no deberían estar contenidas en los ambientes de producción
- b) la gestión de los códigos fuente de los programas y las librerías de las fuentes de los programas se debería hacer de acuerdo con procedimientos establecidos;
- c) el personal de soporte debería tener acceso restringido a las librerías de las fuentes de los programas;
- d) la actualización de las librerías de fuentes de programas y elementos asociados, y la entrega de fuentes de programas a los programadores sólo se debería hacer una vez que se haya recibido autorización apropiada;
- e) los listados de programas se deberían mantener en un entorno seguro;
- f) se debería conservar un registro de auditoría (*Audit Log*) de todos los accesos a la librería de fuentes de programas;
- g) el mantenimiento y copia de las librerías de fuentes de programas deberían estar sujetos a procedimientos estrictos de control de cambios (véase el numeral 14.2.2).

Si los códigos fuente de los programas están previstos para ser publicados, se deberían considerar controles adicionales para ayudar a asegurar su integridad (por ejemplo, firma digital).

10. CRIPTOGRAFÍA

10.1 CONTROLES CRIPTOGRÁFICOS

Objetivo: Asegurar el uso apropiado y eficaz de la criptografía para proteger la confidencialidad, la autenticidad y/o la integridad de la información.

10.1.1 Política sobre el uso de controles criptográficos

Control

Se debería desarrollar e implementar una política sobre el uso de controles criptográficos para la protección de la información.

Guía de implementación

Cuando se desarrolla una política sobre el uso de la criptografía, es conveniente tener en cuenta lo siguiente:

- a) el enfoque de la dirección con relación al uso de controles criptográficos en toda la organización, incluyendo los principios generales bajo los cuales se debería proteger la información del negocio;

- b) con base en la valoración de riesgos, se debería identificar el nivel de protección requerida, teniendo en cuenta el tipo, fortaleza y calidad del algoritmo de cifrado requerido.
- c) el uso de cifrado para la protección de información transportada por dispositivos móviles o removibles, o a través de líneas de comunicación;
- d) el enfoque para la gestión de llaves, incluidos los métodos para la protección de llaves criptográficas y la recuperación de información cifrada, en el caso de llaves perdidas, llaves cuya seguridad está comprometida, o que están dañadas;
- e) roles y responsabilidades, por ejemplo, quién es responsable por:
 - 1) la implementación de la política.
 - 2) la gestión de llaves, incluida la generación de llaves (véase el numeral 10.1.2);
- f) las normas que se van a adoptar para la implementación efectiva en toda la organización (qué solución se usa para los procesos del negocio);
- g) el impacto de usar información cifrada en los controles que dependen de la inspección del contenido (por ejemplo, detección de software malicioso).

Cuando se implementa la política del uso de controles criptográficos de la organización, se deberían considerar las reglamentaciones y las restricciones nacionales que podrían aplicarse al uso de técnicas criptográficas en diferentes partes del mundo, y a las cuestiones de flujo de información cifrada entre fronteras, en diferentes partes del mundo (véase el numeral 18.1.5).

Los controles criptográficos se pueden usar para cumplir diferentes objetivos de seguridad de la información, por ejemplo:

- a) confidencialidad; uso de información cifrada para proteger información sensible o crítica, ya sea almacenada o transmitida;
- b) integridad/autenticidad: uso de firmas digitales o códigos de autenticación de mensajes para verificar la autenticidad o integridad de la información sensible o crítica almacenada o transmitida;
- c) no-repudio: uso de técnicas criptográficas para suministrar evidencia de que un evento o acción ocurre o no ocurre;
- d) autenticación: uso de técnicas criptográficas para autenticar usuarios y otras entidades del sistema que solicitan acceso a usuarios, entidades o recursos del sistema, o tener transacciones con ellos.

Información adicional

Tomar una decisión acerca de si una solución criptográfica es apropiada se debería considerar como parte de un proceso más amplio de valoración de riesgos y de selección de controles. Esta valoración se puede usar entonces para determinar si un control criptográfico es apropiado, qué tipo de control se debería aplicar y para qué propósito y procesos de negocio.

Es necesaria una política sobre el uso de controles criptográficos para maximizar los beneficios y minimizar los riesgos de usar técnicas criptográficas y para evitar el uso inapropiado o incorrecto.

Se debería buscar asesoría especializada para seleccionar controles criptográficos apropiados que cumplan los objetivos de la política de seguridad de la información.

10.1.2 Gestión de llaves

Control

Se debería desarrollar e implementar una política sobre el uso, protección y tiempo de vida de las llaves criptográficas durante todo su ciclo de vida.

Guía de implementación

La política debería incluir requisitos para la gestión de llaves criptográficas durante todo su ciclo de vida, incluida la generación, almacenamiento, archivo, recuperación, distribución, retiro y destrucción de las llaves.

Los algoritmos criptográficos, la longitud de las llaves y las prácticas de uso se deberían seleccionar de acuerdo con las mejores prácticas. Una gestión apropiada de las llaves requiere procesos seguros para la generación, almacenamiento, archivo, recuperación, distribución, retiro y destrucción de llaves criptográficas.

Todas las llaves criptográficas se deberían proteger contra modificación y pérdida. Además, las llaves secretas y privadas necesitan protección contra uso y divulgación no autorizados. Los equipos usados para generar, almacenar y archivar las llaves, deberían estar protegidos físicamente.

Un sistema de gestión de llaves debería estar basado en un grupo establecido de normas, procedimientos y métodos seguros para:

- a) generar llaves para diferentes sistemas criptográficos y diferentes aplicaciones;
- b) generar y obtener certificados de llaves públicas;
- c) distribuir llaves a las entidades previstas, incluyendo la forma de recibir y activar las llaves;
- d) almacenar las llaves, incluyendo la forma en que los usuarios autorizados obtienen acceso a ellas;
- e) cambiar o actualizar las llaves, incluyendo las reglas sobre cuándo se deberían cambiar y cómo hacerlo;
- f) dar tratamiento a las llaves cuya seguridad está comprometida;
- g) revocar las llaves, incluyendo la forma de retirarlas o desactivarlas, por ejemplo, cuando la seguridad de las llaves ha estado comprometida, o cuando un usuario deja la organización (en cuyo caso las llaves también se deberían archivar);
- h) recuperar las llaves que estén perdidas o dañadas (*Corrupted*);

- i) hacer copias de respaldo de las llaves o archivarlas;
- j) destruir las llaves;
- k) registrar (*Logging*) y auditar las actividades relacionadas con gestión de llaves.

Para reducir la posibilidad de uso inapropiado, se deberían definir fechas de activación y desactivación de las llaves, de manera que solo puedan usarse durante un periodo de tiempo definido en la política asociada de gestión de llaves.

Además de hacer la gestión segura de las llaves secretas y privadas, también se debería considerar la autenticidad de las llaves públicas. Este proceso de autenticación se puede hacer usando certificados de llaves públicas que normalmente expide una autoridad de certificación, que debería ser una organización reconocida con controles y procedimientos adecuados para suministrar el grado de confianza requerido.

El contenido de los acuerdos o contratos de nivel de servicio con los proveedores externos de servicios criptográficos, por ejemplo, con una autoridad de certificación, debería comprender cuestiones de responsabilidad civil, confiabilidad de los servicios y tiempos de respuesta para la prestación de los servicios (véase el numeral 15.2).

Información adicional

La gestión de las llaves criptográficas es esencial para el uso eficaz de las técnicas criptográficas. La ISO/IEC 11770^{[2][3][4]} brinda información sobre gestión de llaves.

Las técnicas criptográficas también se pueden usar para proteger las llaves criptográficas. Puede ser necesario considerar procedimientos para el manejo de solicitudes legales para acceder a las llaves criptográficas, por ejemplo, se puede requerir que la información cifrada se ponga a disposición en forma no cifrada, como evidencia en un juicio.

11. SEGURIDAD FÍSICA Y DEL ENTORNO

11.1 ÁREAS SEGURAS

Objetivo: Prevenir el acceso físico no autorizado, el daño y la interferencia a la información y a las instalaciones de procesamiento de información de la organización.

11.1.1 Perímetro de seguridad física

Control

Se deberían definir y usar perímetros de seguridad, y usarlos para proteger áreas que contengan información sensible o crítica, e instalaciones de manejo de información.

Guía de implementación

Las siguientes directrices se deberían considerar e implementar cuando sea adecuado para los perímetros de seguridad física:

- a) se deberían definir los perímetros de seguridad, y la ubicación y la fortaleza de cada uno de los perímetros deberían depender de los requisitos de seguridad de los activos dentro del perímetro y de los resultados de una valoración de riesgos;

- b) los perímetros de una edificación o sitio que contenga instalaciones de procesamiento de la información deberían ser físicamente seguros (es decir, no debería haber brechas en el perímetro o áreas donde fácilmente pueda ocurrir una intrusión ; el techo exterior, las paredes y los pisos del sitio deberían ser de construcción sólida, y todas las puertas externas deberían estar protegidas adecuadamente contra acceso no autorizado con mecanismos de control (por ejemplo, barras, alarmas, cerraduras); las puertas y ventanas deberían estar cerradas con llave cuando no hay supervisión, y se debería considerar protección externa para ventanas, particularmente al nivel del suelo;
- c) debería haber un área de recepción con vigilancia u otro medio para controlar el acceso físico al sitio o edificación; el acceso a los sitios y edificaciones debería estar restringido únicamente para personal autorizado;
- d) en donde sea aplicable, se deberían construir barreras físicas para impedir el acceso físico no autorizado y la contaminación ambiental;
- e) todas las puertas contra incendio en un perímetro de seguridad deberían tener alarmas, estar monitoreadas y probadas junto con las paredes, para establecer el nivel requerido de resistencia de acuerdo con normas regionales, nacionales e internacionales adecuadas; deberían funcionar de manera segura de acuerdo al código local de incendios
- f) se deberían instalar sistemas adecuados para detección de intrusos de acuerdo con normas nacionales, regionales o internacionales y se deberían poner a prueba regularmente para abarcar todas las puertas externas y ventanas accesibles; las áreas no ocupadas deberían tener alarmas en todo momento; también deberían abarcar otras áreas, tales como las salas de cómputo o las salas de comunicaciones;
- g) las instalaciones de procesamiento de información gestionadas por la organización deberían estar separadas físicamente de las gestionadas por partes externas.

Información adicional

La protección física se puede lograr creando una o más barreras físicas alrededor de los predios y de las instalaciones de procesamiento de información de la organización. El uso de múltiples barreras brinda protección adicional, en donde la falla de una sola barrera no significa que la seguridad se vea comprometida inmediatamente.

Un área segura puede ser una oficina que se pueda cerrar con llave, o varios recintos rodeados por una barrera de seguridad física interna. Se pueden necesitar perímetros y barreras adicionales para controlar el acceso físico entre las áreas con diferentes requisitos de seguridad dentro del perímetro de seguridad. Se debería prestar especial atención a la seguridad del acceso físico, en el caso de edificaciones que albergan activos para múltiples organizaciones.

La aplicación de los controles físicos, especialmente para las áreas seguras, se debería adaptar a las circunstancias técnicas y económicas de la organización, como se establece en la valoración de riesgos.

11.1.2 Controles de acceso físicos

Control

Las áreas seguras se deberían proteger mediante controles de acceso apropiados para asegurar que solo se permite el ingreso a personal autorizado.

Guía de implementación

Se deberían considerar las siguientes directrices:

- a) se debería llevar un registro de la fecha y hora de entrada y salida de los visitantes, y todos los visitantes deberían ser supervisados a menos que su acceso haya sido aprobado previamente; solo se les debería otorgar acceso para propósitos específicos autorizados y se deberían emitir instrucciones sobre los requisitos de seguridad del área y de los procedimientos de emergencia. La identidad de los visitantes se debería autenticar por los medios apropiados;
- b) el acceso a las áreas en las que se procesa o almacena información confidencial se debería restringir a los individuos autorizados solamente mediante la implementación de controles de acceso apropiados, por ejemplo, mediante la implementación de un mecanismo de autenticación de dos factores, tales como una tarjeta de acceso y un PIN secreto;
- c) se debería mantener y hacer seguimiento de un libro de registro (*Physical Log Book*) físico o un rastro de auditoría (*Audit Trail*) electrónica de todos los accesos;
- d) todos los empleados, contratistas y partes externas deberían portar algún tipo de identificación visible, y se debería notificar de inmediato al personal de seguridad si se encuentran visitantes no acompañados, y sin la identificación visible;
- e) al personal de servicio de soporte de una parte externa se le debería otorgar acceso restringido a áreas seguras o a instalaciones de procesamiento de información confidencial solo cuando se requiera; este acceso se debería autorizar y se le debería hacer seguimiento;
- f) los derechos de acceso a áreas seguras se deberían revisar y actualizar regularmente, y revocar cuando sea necesario (véanse los numerales 9.2.5 y 9.2.6).

11.1.3 Seguridad de oficinas, recintos e instalacionesControl

Se debería diseñar y aplicar seguridad física a oficinas, recintos e instalaciones.

Guía de implementación

Las siguientes directrices se deberían considerar para brindar seguridad a oficinas, recintos e instalaciones:

- a) las instalaciones clave deberían estar ubicadas de manera que se impida el acceso del público;
- b) en donde sea aplicable, las edificaciones deberían ser discretas y dar un indicio mínimo de su propósito, sin señales obvias externas o internas, que identifiquen la presencia de actividades de procesamiento de información;
- c) las instalaciones deberían estar configuradas para evitar que las actividades o información confidenciales sean visibles y audibles desde el exterior. El blindaje electromagnético también se debería considerar apropiado;

- d) los directorios y guías telefónicas internas que identifican los lugares de las instalaciones de procesamiento de información confidencial no deberían ser accesibles a ninguna persona no autorizada.

11.1.4 Protección contra amenazas externas y ambientales

Control

Se debería diseñar y aplicar protección física contra desastres naturales, ataques maliciosos o accidentes.

Guía de implementación

Se debería obtener asesoría especializada acerca de cómo evitar daños a causa de incendios, inundaciones, terremotos, explosiones, disturbios civiles y otras formas de desastres naturales o causados por el hombre.

11.1.5 Trabajo en áreas seguras

Control

Se deberían diseñar y aplicar procedimientos para trabajo en áreas seguras.

Guía de implementación

Se deberían considerar las siguientes directrices:

- a) el personal solo debería conocer de la existencia de un área segura o de actividades dentro de un área segura, con base en lo que necesita conocer;
- b) el trabajo no supervisado en áreas seguras se debería evitar tanto por razones de seguridad como para evitar oportunidades para actividades malintencionadas;
- c) las áreas seguras vacías deberían estar cerradas con llave y se deberían revisar periódicamente;
- d) no se debería permitir equipo fotográfico, de video, audio u otro equipo de grabación, tales como cámaras en dispositivos móviles, a menos que se cuente con autorización para ello.

Las disposiciones para trabajo en áreas seguras incluyen controles para los empleados y usuarios de partes externas que trabajan en el área segura, y cubren todas las actividades que ocurren en el área segura.

11.1.6 Áreas de despacho y carga

Control

Se deberían controlar los puntos de acceso tales como áreas de despacho y de carga, y otros puntos en donde pueden entrar personas no autorizadas, y si es posible, aislarlos de las instalaciones de procesamiento de información para evitar el acceso no autorizado.

Guía de implementación

Se deberían considerar las siguientes directrices:

- a) el acceso al área de despacho y de carga desde el exterior de la edificación se debería restringir al personal identificado y autorizado;
- b) el área de despacho y carga se debería diseñar de manera que los suministros se puedan cargar y descargar sin que el personal de despacho tenga acceso a otras partes de la edificación;
- c) las puertas externas de un área de despacho y carga se deberían asegurar cuando las puertas internas están abiertas;
- d) el material que ingresa se debería inspeccionar y examinar para determinar la presencia de explosivos, químicos u otros materiales peligrosos, antes de que se retiren del área de despacho y carga;
- e) el material que ingresa se debería registrar de acuerdo con los procedimientos de gestión de activos (véase el numeral 8) al entrar al sitio;
- f) los despachos entrantes y salientes se deberían separar físicamente, en donde sea posible;
- g) el material entrante se debería inspeccionar para determinar evidencia de alteración durante el viaje. Si se descubre tal alteración, se debería reportar de inmediato al personal de seguridad.

11.2 EQUIPOS

Objetivo: Prevenir la pérdida, daño, robo o compromiso de activos, y la interrupción de las operaciones de la organización.

11.2.1 Ubicación y protección de los equipos

Control

Los equipos deberían estar ubicados y protegidos para reducir los riesgos de amenazas y peligros del entorno, y las posibilidades de acceso no autorizado.

Guía de implementación

Se deberían considerar las siguientes directrices para proteger los equipos:

- a) los equipos se deberían ubicar de manera que se minimice el acceso innecesario a las áreas de trabajo;
- b) las instalaciones de procesamiento de la información que manejan datos sensibles deberían estar ubicadas cuidadosamente para reducir el riesgo de que personas no autorizadas puedan ver la información durante su uso;
- c) las instalaciones de almacenamiento se deberían asegurar para evitar el acceso no autorizado;

- d) los elementos que requieren protección especial se deberían salvaguardar para reducir el nivel general de protección requerida;
- e) se deberían adoptar controles para minimizar el riesgo de amenazas físicas y ambientales potenciales, por ejemplo, robo, incendio, explosivos, humo, agua (o falla en el suministro de agua), polvo, vibración, efectos químicos, interferencia en el suministro eléctrico, interferencia en las comunicaciones, radiación electromagnética y vandalismo;
- f) se deberían establecer directrices acerca de comer, consumir líquidos y fumar en cercanías de las instalaciones de procesamiento de información;
- g) se debería hacer seguimiento de las condiciones ambientales tales como temperatura y humedad, para determinar las condiciones que puedan afectar adversamente la operación de las instalaciones de procesamiento de información;
- h) la protección contra descargas eléctricas atmosféricas se debería aplicar a todas las edificaciones y se deberían colocar filtros a todas las líneas de comunicaciones y de potencia entrantes, para la protección contra dichas descargas;
- i) se debería considerar el uso de métodos de protección especial, tales como membranas para teclados, para equipos en ambientes industriales;
- j) los equipos para procesamiento de información confidencial se deberían proteger para minimizar el riesgo de fuga de información debido a emanaciones electromagnéticas.

11.2.2 Servicios de suministro

Control

Los equipos se deberían proteger contra fallas de energía y otras interrupciones causadas por fallas en los servicios de suministro.

Guía de implementación

Los servicios de suministro (por ejemplo, electricidad, telecomunicaciones, suministro de agua, gas, alcantarillado, ventilación y aire acondicionado) deberían:

- a) cumplir con las especificaciones de los fabricantes de equipos y con los requisitos legales locales;
- b) evaluarse regularmente en cuanto a su capacidad para estar al ritmo del crecimiento e interacciones del negocio con otros servicios de soporte;
- c) inspeccionarse y probarse regularmente para asegurar su funcionamiento apropiado;
- d) si es necesario, contar con alarmas para detectar mal funcionamiento;
- e) si es necesario, tener múltiples alimentaciones con diverso enrutado físico.

Se debería suministrar iluminación y comunicaciones de emergencia. Los interruptores y válvulas de emergencia para interrumpir la energía, el agua, el gas u otros servicios deberían estar localizados cerca de las salidas de emergencia o recintos de equipos.

Información adicional

Se puede obtener redundancia adicional para conectividad de redes por medio de múltiples rutas desde uno o más proveedores de servicios.

11.2.3 Seguridad del cableadoControl

El cableado de energía eléctrica y de telecomunicaciones que porta datos o brinda soporte a los servicios de información debería estar protegido contra interceptación, interferencia o daño.

Guía de implementación

Se deberían considerar las siguientes directrices para seguridad del cableado:

- a) las líneas de energía eléctrica y de telecomunicaciones que entran a instalaciones de procesamiento de información deberían ser subterráneas en donde sea posible, o deberían contar con una protección alternativa adecuada;
- b) los cables de energía eléctrica deberían estar separados de los cables de comunicaciones para evitar interferencia;
- c) para sistemas sensibles o críticos los controles adicionales que se debería considerar incluyen:
 - 1) la instalación de tuberías blindadas y recintos o cajas con llave en los puntos de inspección y de terminación;
 - 2) el uso de blindaje electromagnético para proteger los cables;
 - 3) el inicio de barridos técnicos e inspecciones físicas de dispositivos no autorizados que se conectan a los cables;
 - 4) el acceso controlado a los paneles de conexión y recintos de cables.

11.2.4 Mantenimiento de equiposControl

Los equipos se deberían mantener correctamente para asegurar su disponibilidad e integridad continuas.

Guía de implementación

Se deberían considerar las siguientes directrices para mantenimiento de equipos:

- a) los equipos se deberían mantener de acuerdo con los intervalos y especificaciones de servicio recomendados por el proveedor;
- b) solo el personal de mantenimiento autorizado debería llevar a cabo las reparaciones y el servicio a los equipos;

- c) se deberían llevar registros de todas las fallas reales o sospechadas, y de todo el mantenimiento preventivo y correctivo;
- d) se deberían implementar controles apropiados cuando el equipo está programado para mantenimiento, teniendo en cuenta si éste lo lleva a cabo el personal en el sitio o personal externo a la organización; en donde sea necesario, la información confidencial se debería remover (*Cleared*) del equipo, o el personal de mantenimiento debería ser suficientemente revisado (*Cleared*);
- e) se deberían cumplir todos los requisitos de mantenimiento impuestos por las políticas de seguros (*Insurance Policies*);
- f) antes de volver a poner el equipo en operación después de mantenimiento, se debería inspeccionar para asegurarse de que no ha sido alterado y que su funcionamiento es adecuado.

11.2.5 Retiro de activos

Control

Los equipos, información o software no se deberían retirar de su sitio sin autorización previa.

Guía de implementación

Se deberían considerar las siguientes directrices:

- a) se deberían identificar a los empleados y usuarios de partes externas que tienen autoridad para permitir el retiro de activos del sitio;
- b) se deberían establecer los límites de tiempo para el retiro de activos y se debería verificar que se cumplen las devoluciones;
- c) cuando sea necesario y apropiado, se debería registrar cuando los activos se retiran del sitio y cuando se hace su devolución;
- d) se debería documentar la identidad, el rol y la filiación de cualquiera que maneje o use activos, y devolver esta documentación con el equipo, la información y el software.

Información adicional

Los chequeos puntuales (*Spot Check*), que se realizan para detectar el retiro no autorizado de activos, también se pueden llevar a cabo para detectar dispositivos de registro no autorizados, armas, etc., y para impedir su entrada y salida del sitio. Estos chequeos puntuales (*Spot Check*) se deberían llevar a cabo de acuerdo con la legislación y reglamentaciones pertinentes. Se debería informar a los individuos que se realizan chequeos puntuales (*Spot Check*), y las verificaciones se deberían llevar a cabo solo con la autorización apropiada para los requisitos legales y de reglamentación.

11.2.6 Seguridad de equipos y activos fuera de las instalaciones

Control

Se deberían aplicar medidas de seguridad a los activos que se encuentran fuera de las instalaciones de la organización, teniendo en cuenta los diferentes riesgos de trabajar fuera de dichas instalaciones.

Guía de implementación

El uso de cualquier equipo de almacenamiento y procesamiento de información por fuera de las instalaciones de la organización debería ser aprobado por la dirección. Esto se aplica a equipos de propiedad de la organización y a equipos de propiedad privada y usados a nombre de la organización.

Se deberían considerar las siguientes directrices para proteger los equipos fuera de las instalaciones:

- a) los equipos y medios retirados de las instalaciones no se deberían dejar sin vigilancia en lugares públicos;
- b) en todo momento se deberían seguir las instrucciones del fabricante para proteger los equipos, por ejemplo, contra exposición a campos electromagnéticos fuertes;
- c) los controles para lugares fuera de las instalaciones, tales como trabajo en la casa, teletrabajo y sitios temporales se deberían determinar mediante una valoración de riesgos y se deberían aplicar los controles adecuados según sean apropiados, por ejemplo, gabinetes de archivo con llave, política de escritorio limpio, controles de acceso para computadores y comunicación segura con la oficina (véase también la norma ISO/IEC 27033^{[15][16][17][18][19]});
- d) cuando el equipo que se encuentra afuera de las instalaciones es transferido entre diferentes individuos o partes externas, se debería llevar un registro (*log*) que defina la cadena de custodia para el equipo, que incluya al menos los nombres y las organizaciones de los responsables del equipo.

Los riesgos, por ejemplo, de daño, robo o interceptación de conversaciones pueden variar considerablemente entre ubicaciones, y se deberían tener en cuenta al determinar los controles más apropiados.

Información adicional

El equipo de procesamiento y almacenamiento de información incluye todas las formas de computadores personales, organizadores, teléfonos móviles, tarjetas inteligentes, papel u otro formato, que se mantenga para trabajo en la casa o que se transporte lejos del lugar de trabajo normal.

En el numeral 6.2 se puede encontrar más información acerca de otros aspectos de la protección de equipos móviles.

Puede ser apropiado evitar el riesgo, desalentando a algunos empleados para que no trabajen fuera del sitio, o restringiendo el uso de equipos de TI portátiles;

11.2.7 Disposición segura o reutilización de equiposControl

Se deberían verificar todos los elementos de equipos que contengan medios de almacenamiento, para asegurar que cualquier dato sensible o software licenciado haya sido retirado o sobreescrito en forma segura antes de su disposición o reuso.

Guía de implementación

Antes de la disposición o reúso de los equipos, se debería verificar que estos no contengan medios de almacenamiento.

Los medios de almacenamiento que contienen información confidencial o protegida por derechos de autor se deberían destruir físicamente, o la información debería ser destruida, eliminada o sobrescrita usando técnicas para hacer que la información original no sea recuperable, en vez de usar la función estándar borrar o formatear.

Información adicional

Los equipos dañados que contienen medios de almacenamiento pueden requerir una valoración de riesgos para determinar si los elementos se deberían destruir físicamente en vez de enviarlos a reparar o desechar. La información se puede comprometer debido a una disposición descuidada o reúso de equipos.

Además de asegurar el borrado de discos, el cifrado del disco entero reduce el riesgo de que se divulgue información confidencial cuando se dispone del equipo o se le da un destino diferente, siempre y cuando:

- a) el proceso de cifrado sea suficientemente fuerte y abarque el disco (incluido el espacio libre (*Slack Space*), archivos de intercambio (*Swap File*), etc.);
- b) las llaves criptográficas sean lo suficientemente largas para resistir ataques de fuerza bruta;
- c) las llaves criptográficas se mantengan confidenciales (por ejemplo, nunca se almacenan en el mismo disco).

Para asesoría adicional sobre criptografía, véase el numeral 10.

Las técnicas para sobreescribir en forma segura medios de almacenamiento son diferentes de acuerdo con la tecnología del medio de almacenamiento. Las herramientas de sobreescritura se deberían revisar para asegurarse de que son aplicables a la tecnología de los medios de almacenamiento.

11.2.8 Equipos de usuario desatendidosControl

Los usuarios deberían asegurarse de que a los equipos desatendidos se les da protección apropiada.

Guía de implementación

Todos los usuarios deberían tomar conciencia de los requisitos y procedimientos de seguridad para proteger los equipos desatendidos, al igual que sus responsabilidades para la implementación de esta protección. Se debería notificar a los usuarios que:

- a) terminen las sesiones activas cuando hayan finalizado, a menos que se puedan asegurar mediante un mecanismo de bloqueo apropiado, por ejemplo, un protector de pantalla protegido con contraseña;

- b) cierren (*Log-Off*) las aplicaciones o servicios de red cuando ya no los necesiten;
- c) aseguren los computadores o dispositivos móviles contra uso no autorizado mediante el bloqueo de teclas o un control equivalente, por ejemplo, acceso con contraseña, cuando no están en uso.

11.2.9 Política de escritorio limpio y pantalla limpia

Control

Se debería adoptar una política de escritorio limpio para los papeles y medios de almacenamiento removibles, y una política de pantalla limpia en las instalaciones de procesamiento de información.

Guía de implementación

La política de escritorio limpio y de pantalla limpia debería tener en cuenta las clasificaciones de información (véase el numeral 8.2), los requisitos legales y contractuales (véase el numeral 18.1) y los riesgos y aspectos culturales correspondientes de la organización. Se deberían considerar las siguientes directrices:

- a) la información sensible o crítica del negocio, por ejemplo, sobre papel o en un medio de almacenamiento electrónico, se debería guardar (idealmente, en una caja fuerte o en un gabinete u otro mueble de seguridad) cuando no se requiera, especialmente cuando la oficina esté desocupada.
- b) cuando están desatendidos, los computadores y terminales se deberían dejar fuera del sistema (*Logged Off*) o proteger con un sistema de bloqueo de la pantalla y el teclado, controlado por una contraseña, *token* o mecanismo similar de autenticación de usuario, y deberían estar protegidos por bloqueo de teclas u otros controles, cuando no están en uso;
- c) se debería evitar el uso no autorizado de fotocopadoras y otra tecnología de reproducción (por ejemplo, escáneres, cámaras digitales);
- d) los medios que contienen información sensible o clasificada se deberían retirar de las impresoras inmediatamente.

Información adicional

Una política de escritorio limpio / pantalla limpia reduce los riesgos de acceso no autorizado, pérdida y daño de información durante y por fuera de las horas laborales normales. Las cajas fuertes u otras formas de instalaciones de almacenamiento seguro podrían proteger la información almacenada en ellas contra desastres tales como incendios, terremotos, inundaciones o explosión.

Considere el uso de impresoras con función de código con PIN, de manera que los originadores sean los únicos que pueden hacer impresiones y solo cuando están al lado de la impresora.

12. SEGURIDAD DE LAS OPERACIONES

12.1 PROCEDIMIENTOS OPERACIONALES Y RESPONSABILIDADES

Objetivo: Asegurar las operaciones correctas y seguras de las instalaciones de procesamiento de información.

12.1.1 Procedimientos de operación documentados

Control

Los procedimientos de operación se deberían documentar y poner a disposición de todos los usuarios que los necesitan.

Guía de implementación

Se deberían preparar procedimientos documentados para las actividades operacionales asociadas con las instalaciones de procesamiento y comunicación, tales como los procedimientos de encendido y apagado, copias de respaldo, mantenimiento de equipos, manejo de medios, salas de cómputo y gestión y seguridad del manejo de correo.

Los procedimientos de operación deberían especificar las instrucciones operacionales, que incluyen:

- a) la instalación y configuración de sistemas;
- b) el procesamiento y manejo de información, tanto automático como manual;
- c) las copias de respaldo (véase el numeral 12.3);
- d) los requisitos de programación, incluidas las interdependencias con otros sistemas, los tiempos de finalización del primer y último trabajos;
- e) las instrucciones para manejo de errores u otras condiciones excepcionales que podrían surgir durante la ejecución del trabajo, incluidas las restricciones sobre el uso de utilidades del sistema (véase el numeral 9.4.4);
- f) contactos de apoyo y de una instancia superior (escalamiento), incluidos los contactos de soporte externo, en el caso de dificultades operacionales o técnicas inesperadas;
- g) instrucciones sobre manejo de medios y elementos de salida especiales, tales como el uso de papelería especial o la gestión de elementos de salida confidenciales, incluidos procedimientos para la disposición segura de elementos de salida de trabajos fallidos (véanse los numerales 8.3 y 11.2.7);
- h) procedimientos de reinicio y recuperación del sistema para uso en el caso de falla del sistema;
- i) la gestión de rastros de auditoría (*Audit Trail*) y de la información de registro del sistema (*System Log*) (véase el numeral 12.4);
- j) procedimientos de seguimiento.

Los procedimientos de operación y los procedimientos documentados para actividades del sistema se deberían tratar como documentos formales y cambios autorizados por la dirección. En donde sea viable técnicamente, la gestión de los sistemas de información se debería hacer de forma coherente, usando los mismos procedimientos, herramientas y utilitarios.

12.1.2 Gestión de cambios

Control

Se deberían controlar los cambios en la organización, en los procesos de negocio, en las instalaciones y en los sistemas de procesamiento de información que afectan la seguridad de la información.

Guía de implementación

En particular, se deberían considerar los siguientes asuntos:

- a) la identificación y registro de cambios significativos;
- b) la planificación y puesta a prueba de los cambios;
- c) la valoración de los impactos potenciales, incluidos los impactos de estos cambios en la seguridad de la información;
- d) el procedimiento de aprobación formal para los cambios propuestos;
- e) la verificación de que se han cumplido los requisitos de seguridad de la información;
- f) la comunicación de todos los detalles de los cambios a todas las personas pertinentes;
- g) los procedimientos de apoyo, incluidos procedimientos y responsabilidades para abortar cambios no exitosos y recuperarse de ellos, y eventos no previstos;
- h) el suministro de un proceso de cambio de emergencia que permita la implementación rápida y controlada de los cambios necesarios para resolver un incidente (véase el numeral 16.1).

Deberían existir responsabilidades y procedimientos de gestión formales para asegurar el control satisfactorio de todos los cambios. Cuando se hacen los cambios, se debería conservar un registro de auditoría (*Audit Log*) que contenga toda la información pertinente.

Información adicional

El control inadecuado de los cambios en las instalaciones y sistemas de procesamiento de la información es una causa común de fallas en el sistema o en la seguridad. Los cambios en el ambiente de producción, especialmente cuando se transfiere un sistema de la etapa de desarrollo a la de producción, puede tener impacto sobre la confiabilidad de las aplicaciones (véase el numeral 14.2.2).

12.1.3 Gestión de capacidad

Control

Se debe hacer seguimiento al uso de recursos, hacer los ajustes, y hacer proyecciones de los requisitos de capacidad futura, para asegurar el desempeño requerido del sistema.

Guía de implementación

Los requisitos de capacidad se deberían identificar teniendo en cuenta la criticidad que tiene para el negocio el sistema involucrado. Se deberían aplicar el ajuste y seguimiento del sistema, para asegurar y, cuando sea necesario, mejorar la disponibilidad y la eficiencia de los sistemas. Se deberían aplicar controles de detección que indiquen los problemas oportunamente. Las proyecciones de los requisitos sobre la capacidad futura deberían tener en cuenta los requisitos de los nuevos negocios y sistemas, y las tendencias actuales y proyectadas en las capacidades de procesamiento de información de la organización.

Es necesario prestar atención particular a cualquier recurso con tiempos prolongados de espera para su adquisición, o costos altos; por tanto, los gerentes deberían hacer seguimiento de la utilización de los recursos clave del sistema; Deberían identificar tendencias en el uso, particularmente en relación con aplicaciones del negocio o herramientas de gestión de sistemas de la información.

Los gerentes deberían usar esta información para identificar y evitar cuellos de botella potenciales y dependencia del personal clave, que podrían presentar una amenaza para la seguridad o servicios del sistema, y planificar la acción apropiada.

Se puede suministrar capacidad suficiente incrementando la capacidad o reduciendo la demanda. Algunos ejemplos de gestión de la demanda de capacidad incluyen:

- a) eliminación de datos obsoletos (espacio en disco);
- b) el cierre definitivo de aplicaciones, sistemas, bases de datos o ambientes;
- c) la optimización de cronogramas y procesamiento de lotes;
- d) la optimización de las consultas de bases de datos o lógicas de las aplicaciones;
- e) la negación o restricción de ancho de banda a servicios ávidos de recursos, si estos no son críticos para el negocio (por ejemplo, video en tiempo real).

Se debería considerar un plan de gestión de capacidad documentado para sistemas críticos de la misión.

Información adicional

Este control también tiene en cuenta la capacidad de los recursos humanos, al igual que las oficinas e instalaciones.

12.1.4 Separación de los ambientes de desarrollo, pruebas y producciónControl

Se deberían separar los ambientes de desarrollo, prueba y producción, para reducir los riesgos de acceso o cambios no autorizados al ambiente de producción.

Guía de implementación

Se debería identificar e implementar el nivel de separación entre los ambientes de desarrollo, prueba y producción que es necesario para evitar problemas operacionales.

Se deberían considerar los siguientes asuntos:

- a) se deberían definir y documentar las reglas para la transferencia de software del estatus de desarrollo al de producción.
- b) el software de desarrollo y de producción debería funcionar en diferentes sistemas o procesadores de cómputo y en diferentes dominios o directorios;
- c) los cambios en los sistemas de producción y aplicaciones se deberían poner a prueba en un ambiente de pruebas antes de aplicarlos a los sistemas en producción.;
- d) solo en circunstancias excepcionales, las pruebas no se deberían llevar a cabo en los sistemas en producción;
- e) los compiladores, editores y otras herramientas de desarrollo o utilidades del sistema (*System Utilities*) no deberían ser accesibles desde sistemas en producción cuando no se requiere;
- f) los usuarios deberían usar diferentes perfiles para sistemas en producción y de pruebas, y los menús deberían desplegar mensajes de identificación apropiados para reducir el riesgo de error;
- g) los datos sensibles no se deberían copiar en el ambiente de pruebas, a menos que se suministren controles equivalentes para el sistema de pruebas (véase el numeral 14.3).

Información adicional

Las actividades de desarrollo y de pruebas pueden causar problemas graves, por ejemplo, la modificación involuntaria de archivos o del ambiente del sistema o falla del sistema. Es necesario mantener un ambiente conocido y estable en el cual se realicen pruebas significativas, e impedir el acceso de un desarrollador inapropiado, al ambiente de producción.

En donde el personal de desarrollo y pruebas tiene acceso al sistema en producción y a su información, puede estar en capacidad de introducir códigos no autorizados y no probados, o de alterar los datos de producción. En algunos sistemas, esta capacidad se puede utilizar indebidamente para cometer fraude o para introducir códigos no probados o maliciosos, que pueden causar serios problemas de operación.

El personal de desarrollo y pruebas también representa una amenaza a la confidencialidad de la información operacional. Las actividades de desarrollo y de pruebas pueden causar cambios imprevistos en el software o en la información, si comparten el mismo ambiente de cómputo. Por tanto, es recomendable separar los ambientes de desarrollo, prueba y producción, para reducir el riesgo de cambio accidental o acceso no autorizado al software operacional y a datos del negocio (véase el numeral 14.3 para la protección de los datos de prueba).

12.2 PROTECCIÓN CONTRA CÓDIGOS MALICIOSOS

Objetivo: Asegurarse de que la información y las instalaciones de procesamiento de información estén protegidas contra códigos maliciosos.

12.2.1 Controles contra códigos maliciosos

Control

Se deberían implementar controles de detección, de prevención y de recuperación, combinados con la toma de conciencia apropiada de los usuarios, para proteger contra códigos maliciosos.

Guía de implementación

La protección contra los códigos maliciosos se debería basar en software de detección de códigos maliciosos y de reparación, en toma de conciencia sobre la seguridad de la información, y en controles apropiados de gestión de cambios y de acceso al sistema. Se deberían considerar las siguientes directrices:

- a) establecer una política formal que prohíba el uso de software no autorizado (véanse los numerales 12.6.2 y 14.2.);
- b) implementar controles para evitar o detectar el uso de software no autorizado (por ejemplo, listas blancas de aplicaciones);
- c) implementar controles para evitar o detectar el uso de sitios web malicioso o que se sospecha que lo son (por ejemplo, listas negras);
- d) establecer una política formal para proteger contra riesgos asociados con la obtención de archivos y de software ya sea mediante redes externas o cualquier otro medio, indicando qué medidas externas se deberían tomar;
- e) reducir las vulnerabilidades de las que pueda aprovecharse el software malicioso, por ejemplo, por medio de la gestión de la vulnerabilidad técnica (véase el numeral 12.6);
- f) llevar a cabo revisiones regulares del software y del contenido de datos de los sistemas que apoyan los procesos críticos del negocio; se debería investigar formalmente la presencia de archivos no aprobados o de enmiendas no autorizadas;
- g) la instalación y actualización regular del software de detección y reparación del software malicioso para analizar los computadores y medios como una medida de control o en forma rutinaria; el análisis realizado debería incluir:
 - 1) el análisis de cualquier archivo recibido por la red o por cualquier forma de medio de almacenamiento, para detectar el software malicioso, antes de uso;
 - 2) el análisis de los adjuntos y descargas de los correos electrónicos, para determinación del software malicioso antes de uso; este análisis se debería llevar a cabo en diferentes lugares, por ejemplo, en los servidores de los correos electrónicos, en los computadores de escritorio y cuando se ingresa a la red de la organización;
 - 3) el análisis de páginas web, para determinar el software malicioso;
- h) la definición de procedimientos y responsabilidades relacionadas con la protección contra el software malicioso en los sistemas, formación acerca del uso de dichos procedimientos, reporte y recuperación de ataques de software malicioso;

- i) la preparación de planes de continuidad del negocio apropiados, para la recuperación de ataques de software malicioso, incluidos todos los datos necesarios, copias de respaldo del software y disposiciones para recuperación (véase el numeral 12.3);
- j) la implementación de procedimientos para recolectar información en forma regular, como por ejemplo la suscripción a listas de correos o la verificación de sitios web que suministran información acerca de nuevo software malicioso;
- k) la implementación de procedimientos para verificar información relacionada con el software malicioso, y asegurarse de que los boletines de advertencia sean exactos e informativos; los gerentes se deberían asegurar de que se usan fuentes calificadas, por ejemplo, publicaciones respetables, sitios o proveedores en Internet confiables que producen software de protección contra software malicioso, para diferenciar entre falsas alarmas (*Hoaxes*) y software malicioso real; todos los usuarios deberían tomar conciencia del problema de las falsas alarmas (*Hoaxes*) y de qué hacer en caso de recibirlas;
- l) el aislamiento de ambientes en donde se pueden obtener impactos catastróficos.

Información adicional

El uso de dos o más productos de software que protegen contra software malicioso a través del ambiente de procesamiento de información, de diferentes vendedores y tecnología pueden mejorar la eficacia de la protección contra el software malicioso.

Es necesario protegerse contra la introducción de software malicioso durante los procesos de mantenimiento y de emergencia, el cual puede evitar los controles normales de protección contra software malicioso.

Bajo condiciones determinadas, la protección contra software malicioso podría causar perturbaciones dentro de las operaciones.

Habitualmente no es adecuado el uso por sí solo de software de detección y reparación de software malicioso, y comúnmente necesita estar acompañado de procedimientos de operación que impiden la introducción de software malicioso.

12.3 COPIAS DE RESPALDO

Objetivo: Proteger contra la pérdida de datos.

12.3.1 Respaldo de la información

Control

Se deberían hacer copias de respaldo de la información, software e imágenes de los sistemas, y ponerlas a prueba regularmente de acuerdo con una política de copias de respaldo acordadas.

Guía de implementación

Se debería establecer una política de copias de respaldo para definir los requisitos de la organización para copias de respaldo de información, software y sistemas.

La política de copias de respaldo debería definir los requisitos de retención y de protección.

Se deberían proporcionar instalaciones adecuadas para copias de respaldo, para asegurar que la información y el software esenciales se puedan recuperar después de un desastre o falla del medio.

Cuando se diseña un plan de copias de respaldo, se deberían tener en cuenta los siguientes aspectos:

- a) se deberían producir registros exactos y completos de las copias de respaldo, y procedimientos de restauración documentados;
- b) el alcance (por ejemplo, copias de respaldo completas o diferenciales) y la frecuencia con que se hagan las copias de respaldo deberían reflejar los requisitos del negocio de la organización, los requisitos de la seguridad de la información involucrada, y la criticidad de la información para la operación continua de la organización;
- c) las copias de respaldo se deberían almacenar en un lugar remoto, a una distancia suficiente que permita escapar de cualquier daño que pueda ocurrir en el sitio principal;
- d) a la información de respaldo se le debería dar un nivel apropiado de protección física y del entorno (véase el numeral 11), de coherencia con las normas aplicadas en el sitio principal;
- e) los medios de respaldo se deberían poner a prueba regularmente para asegurar que se puede depender de ellos para uso de emergencia en caso necesario; esto se debería combinar con una prueba de los procedimientos de restauración, y se debería verificar contra el tiempo de restauración requerido. La prueba de la capacidad para restaurar datos de los que se ha hecho una copia de respaldo se debería hacer en medios de prueba dedicados, no sobreescribiendo el medio original, en caso de que el proceso de elaboración de copias de respaldo o de restauración falle y cause daño o pérdida de datos irreparable;
- f) en situaciones en las que la confidencialidad tiene importancia, las copias de respaldo deberían estar protegidas por medio de cifrado.

Los procedimientos de operación deberían monitorear la ejecución de las copias de respaldo y darle tratamiento a las fallas de las copias de respaldo programadas, para asegurar que se realiza de manera completa y de acuerdo con las políticas de copias establecidas para las mismas.

Las disposiciones relativas a copias de respaldo para sistemas y servicios individuales se deberían probar con regularidad para asegurar que cumplan los requisitos de los planes de continuidad de negocio. En el caso de sistemas y servicios críticos, las disposiciones relativas a copias de respaldo deberían abarcar toda la información de sistemas, aplicaciones y datos necesarios para recuperar el sistema completo en caso de desastre.

Se debería determinar el período de retención de la información esencial del negocio, teniendo en cuenta cualquier requisito para copias de archivo que se van a retener permanentemente.

12.4 REGISTRO (LOGGING) Y SEGUIMIENTO

Objetivo: Registrar eventos y generar evidencia.

12.4.1 Registro de eventos

Control

Se deberían elaborar, conservar y revisar regularmente los registros acerca de actividades del usuario, excepciones, fallas y eventos de seguridad de la información.

Guía de implementación

Los registros de eventos (*Event Logs*) deberían incluir, cuando es pertinente:

- a) identificación de usuarios;
- b) actividades del sistema;
- c) fechas, horas y detalles de los eventos clave, por ejemplo, entrada y salida;
- d) identidad del dispositivo o ubicación, si es posible, e identificador del sistema;
- e) registros de intentos de acceso al sistema exitosos y rechazados;
- e) registros de datos exitosos y rechazados y otros intentos de acceso a recursos;
- g) cambios a la configuración del sistema;
- h) uso de privilegios;
- i) uso de utilidades y aplicaciones del sistema;
- j) archivos a los que se tuvo acceso, y el tipo de acceso;
- k) direcciones y protocolos de red;
- l) alarmas accionadas por el sistema de control de acceso;
- m) activación y desactivación de los sistemas de protección, tales como sistemas antivirus y sistemas de detección de intrusión;
- n) registros de las transacciones ejecutadas por los usuarios en las aplicaciones.

El registro de eventos (*Events Logging*) establece las bases para los sistemas de seguimiento automatizados que están en capacidad de generar informes consolidados y alertas sobre la seguridad del sistema.

Información adicional

Los registros de eventos (*Event Logs*) pueden contener datos sensibles e información identificable personalmente. Se deberían tomar medidas apropiadas para la protección de la privacidad (véase el numeral 18.1.4).

En donde sea posible, los administradores de sistemas no deberían tener permiso para borrar o desactivar registros (*Logs*) de sus propias actividades (véase el numeral 12.4.3).

12.4.2 Protección de la información de registro (*log information*)

Control

Los sistemas de gestión de registros (*Logging Facilities*) y la información de registro (*Log Information*) se deberían proteger contra alteración y acceso no autorizado.

Guía de implementación

Los controles deberían estar dirigidos a proteger contra cambios no autorizados de la información del registro (*Log Information*) y contra problemas operacionales con los sistemas de gestión de registros (*logging facilities*), inclusive:

- a) alteraciones a los tipos de mensaje que se registran;
- b) archivos de registro (*Log Files*) que son editados o eliminados;
- c) se excede la capacidad de almacenamiento del medio de archivo de registro (*Log File Media*), lo que da como resultado falla en el registro de eventos, o sobreescritura de eventos pasados registrados.

Puede ser necesario archivar algunos registros de auditoría (*Audit Log*), como parte de la política de retención de registros o debido a requisitos acerca de recolectar y retener evidencia (véase el numeral 16.1.7).

Información adicional

Los registros del sistema (*System Logs*) a menudo contienen un gran volumen de información, mucha de la cual es ajena al seguimiento de la seguridad de la información. Para ayudar a identificar los eventos significativos con propósitos de seguimiento de la seguridad de la información, se debería considerar el copiado automático de tipos de mensajes apropiados a un segundo registro (*log*), o el uso de utilidades del sistema (*System Utilities*) o herramientas de auditoría adecuados para llevar a cabo la interrogación y racionalización de los archivos.

Es necesario proteger los registros del sistema (*System Logs*), ya que si los datos se pueden modificar o los datos en ellos se pueden borrar, su existencia puede crear una sensación falsa de seguridad. El copiado de registros (*Logs*) en tiempo real a un sistema por fuera del control de un administrador u operador del sistema se puede usar para salvaguardar los registros (*Logs*).

12.4.3 Registros (*Logs*) del administrador y del operador

Control

Las actividades del administrador y del operador del sistema se deberían registrar (*Logged*), y los registros (*Logs*) se deberían proteger y revisar con regularidad.

Guía de implementación

Los titulares de cuenta de usuario privilegiado pueden estar en capacidad de manipular los registros (*Logs*) en instalaciones de procesamiento de información bajo su control directo; por esto, es necesario proteger y revisar los registros (*Logs*) para mantener la rendición de cuentas para los usuarios privilegiados.

Información adicional

Un sistema de detección de intrusión gestionado por fuera del control del sistema y de los administradores de la red se puede usar para hacer seguimiento del sistema y de las actividades de administración de la red, para determinar su cumplimiento.

12.4.4 Sincronización de relojesControl

Los relojes de todos los sistemas de procesamiento de información pertinentes dentro de una organización o ámbito de seguridad se deberían sincronizar con una única fuente de referencia de tiempo.

Guía de implementación

Se deberían documentar los requisitos externos e internos para la representación de tiempo, sincronización y exactitud. Estos requisitos pueden ser legales, de reglamentación, contractuales, de cumplimiento con normas o requisitos para seguimiento interno. Se debería definir un tiempo de referencia estándar para uso dentro de la organización.

Se debería documentar e implementar el enfoque de la organización para obtener un tiempo de referencia de una(s) fuente(s) externas y como sincronizar confiablemente los relojes internos.

Información adicional

El ajuste correcto de los relojes de computador es importante para asegurar la exactitud de los registros de auditoría (*Audit Logs*), que pueden ser necesarios para investigaciones o como evidencia legal en casos legales o casos disciplinarios. Los registros de auditoría (*Audit Logs*) inexactos pueden dificultar estas investigaciones y afectar la credibilidad de esta evidencia. Un reloj vinculado a una transmisión de tiempo por radio desde un reloj atómico nacional se puede usar como el reloj maestro para los sistemas de registro (*Logging Systems*). Se puede usar un protocolo de tiempo de red para mantener todos los servidores sincronizados con el reloj maestro.

12.5 CONTROL DE SOFTWARE OPERACIONAL

Objetivo: Asegurar la integridad de los sistemas operativos (*Operational Systems*)

12.5.1 Instalación de software en sistemas operativos (*Operational Systems*)Control

Se deberían implementar procedimientos para controlar la instalación de software en sistemas operativos (*Operational Systems*).

Guía de implementación

Se deberían considerar las siguientes directrices para controlar los cambios de software en sistemas operativos:

- a) la actualización del software operacional, aplicaciones y librerías de programas solo la deberían llevar a cabo administradores entrenados, con autorización apropiada de la dirección (véase el numeral 9.4.5);

- b) los sistemas operativos sólo deberían contener códigos ejecutables aprobados, no el código de desarrollo o compiladores;
- c) las aplicaciones y el software del sistema operativo solo se deberían implementar después de pruebas extensas y exitosas; los ensayos deberían abarcar la usabilidad, la seguridad, los efectos sobre otros sistemas y la facilidad de uso, y se deberían llevar a cabo en sistemas separados (véase el numeral 12.1.4); se debería asegurar que todas las librerías de fuentes de programas correspondientes hayan sido actualizadas;
- d) se debería usar un sistema de control de la configuración para mantener el control de todo el software implementado, al igual que la documentación del sistema;
- e) se debería establecer una estrategia de retroceso (*Rollback*) antes de implementar los cambios;
- f) se debería mantener un registro de auditoría (*Audit Log*) de todas las actualizaciones de las librerías de programas operacionales;
- g) las versiones anteriores del software de aplicación se deberían conservar como una medida de contingencia;
- h) las versiones de software anteriores se deberían archivar, junto con toda la información y parámetros, procedimientos, detalles de configuración y software de soporte anteriores, en tanto los datos permanezcan en el archivo.

El software suministrado por el vendedor, usado en los sistemas operacionales, se debería mantener a un nivel apoyado por el proveedor. Con el tiempo, los fabricantes de software dejarán de brindar soporte a las versiones de software anteriores. La organización debería considerar los riesgos de depender de software sin soporte.

Cualquier decisión de actualizarse a una nueva versión debería tener en cuenta los requisitos del negocio para el cambio y la seguridad de la versión, por ejemplo, la introducción de una nueva funcionalidad de seguridad de la información, o el número y severidad de los problemas de seguridad de la información que afectan a esta versión. Se deberían aplicar parches de software cuando pueden ayudar a eliminar o reducir debilidades de seguridad de la información (véase el numeral 12.6).

Sólo se debería conceder acceso lógico y físico a los proveedores para propósitos de apoyo cuando es necesario, y con aprobación de la dirección. Se debería hacer seguimiento a las actividades de los proveedores (véase el numeral 15.2.1).

El software informático puede depender de software y módulos suministrados externamente, a lo cual se debería hacer seguimiento y se debería controlar para evitar cambios no autorizados que puedan introducir debilidades en la seguridad.

12.6 GESTIÓN DE LA VULNERABILIDAD TÉCNICA

Objetivo: Prevenir el aprovechamiento de las vulnerabilidades técnicas.

12.6.1 Gestión de las vulnerabilidades técnicas

Control

Se debería obtener oportunamente información acerca de las vulnerabilidades técnicas de los sistemas de información que se usen; evaluar la exposición de la organización a estas vulnerabilidades, y tomar las medidas apropiadas para tratar el riesgo asociado.

Guía de implementación

Un inventario actualizado y completo de los activos (véase el numeral 8) es un prerequisite para una gestión eficaz de la vulnerabilidad técnica. La información específica necesaria para apoyar la gestión de la vulnerabilidad técnica incluye al vendedor del software, los números de las versiones, el estado actual de despliegue (por ejemplo, qué software se instaló en qué sistemas), y la(s) persona(s) dentro de la organización responsables por el software.

Se deberían tomar acciones apropiadas y oportunas en respuesta a la identificación de vulnerabilidades técnicas potenciales. Los siguientes aspectos se deberían seguir para establecer un proceso de gestión eficaz para las vulnerabilidades técnicas:

- a) la organización debería definir y establecer los roles y responsabilidades asociados con la gestión de la vulnerabilidad técnica, incluido el seguimiento de la vulnerabilidad, la valoración de riesgos de vulnerabilidad, la colocación de parches, el seguimiento de activos y cualquier responsabilidad de coordinación requerida;
- b) los recursos de información que se usarán para identificar las vulnerabilidades técnicas pertinentes y para mantener la toma de conciencia acerca de ellos se deberían identificar para el software y otra tecnología (con base en la lista de inventario de activos, véase 8.1.1); estos recursos de información se deberían actualizar con base en los cambios en el inventario o cuando se encuentran otros recursos nuevos o útiles;
- c) se debería definir una línea de tiempo para reaccionar a las notificaciones de vulnerabilidades técnicas pertinentes potencialmente;
- d) una vez que se haya identificado una vulnerabilidad técnica potencial, la organización debería identificar los riesgos asociados y las acciones por tomar; esta acción puede involucrar la colocación de parches de sistemas vulnerables o la aplicación de otros controles;
- e) dependiendo de la urgencia con la que se necesite tratar una vulnerabilidad técnica, la acción tomada se debería llevar a cabo de acuerdo con los controles relacionados con la gestión de cambios (véase el numeral 12.1.2), o siguiendo los procedimientos de respuesta a incidentes de seguridad de la información (véase el numeral 16.1.5);
- f) si está disponible un parche de una fuente legítima, se deberían valorar los riesgos asociados con la instalación del parche (los riesgos que acarrea la vulnerabilidad se deberían comparar con el riesgo de instalar el parche);
- g) los parches se deberían probar y evaluar antes de su instalación, para asegurarse de que son eficaces y no producen efectos secundarios que no se puedan tolerar; si no hay parches disponibles, se deberían considerar otros controles como:
 - 1) dejar de operar (*Turning Off*) los servicios o capacidades relacionados con la vulnerabilidad;

- 2) adaptar o adicionar controles de acceso, por ejemplo, firewalls, en los límites de la red (véase el numeral 13.1);
- 3) incrementar el seguimiento para detectar ataques reales;
- 4) hacer tomar conciencia sobre la vulnerabilidad;
- h) se debería llevar un registro de auditoría (*Audit Log*) para todos los procedimientos realizados;
- i) se debería hacer seguimiento y evaluación regulares del proceso de gestión de vulnerabilidad técnica, con el fin de asegurar su eficacia y eficiencia;
- j) se deberían abordar primero los sistemas que están en alto riesgo;
- k) un proceso de gestión eficaz de la vulnerabilidad técnica debería estar alineado con las actividades de gestión de incidentes para comunicar los datos sobre vulnerabilidades a la función de respuesta a incidentes y suministrar los procedimientos técnicos para realizarse si llegara a ocurrir un incidente;
- l) definir un procedimiento para hacer frente a una situación en la que se ha identificado una vulnerabilidad, pero no hay una contramedida adecuada. En esta situación, la organización debería evaluar los riesgos relacionados con la vulnerabilidad conocida y definir las acciones de detección y correctivas apropiadas.

Información adicional

La gestión de la vulnerabilidad técnica se puede considerar como una subfunción de la gestión de cambios, y como tal puede tomar ventaja de los procesos y procedimientos de gestión del cambio (véanse los numerales 12.1.2 y 14.2.2).

Con frecuencia, los vendedores experimentan una presión significativa para que liberen los parches lo más pronto posible. Por tanto, existe una posibilidad de que un parche no aborde el problema adecuadamente, y que tenga efectos negativos. Además, en algunos casos no es fácil desinstalar un parche una vez que se ha aplicado.

Si no es posible hacer una prueba adecuada de los parches, por ejemplo, debido a los costos o a la falta de recursos, se puede considerar un retraso en la colocación del parche para evaluar los riesgos asociados con base en la experiencia reportada por otros usuarios. El uso de la norma ISO/IEC 27031^[14] puede ser beneficioso.

12.6.2 Restricciones sobre la instalación de software

Control

Se deberían establecer e implementar las reglas para la instalación de software por parte de los usuarios.

Guía de implementación

La organización debería definir una política estricta, y hacerla cumplir, con relación a qué tipo de software pueden instalar los usuarios.

Se debería aplicar el principio del menor privilegio. Si se les han otorgado algunos privilegios, los usuarios pueden tener la capacidad de instalar software. La organización debería identificar qué tipos de instalaciones de software se permiten (por ejemplo, actualizaciones y parches de seguridad al software existente) y qué tipo de instalaciones están prohibidas (por ejemplo, que sea solamente para uso personal cuya idoneidad con relación a que sea potencialmente malicioso se conoce o se sospecha). Estos privilegios se deberían conceder con relación a los roles de los usuarios involucrados.

Información adicional

La instalación no controlada de software en dispositivos de computo puede conducir a que se introduzcan vulnerabilidades y posteriormente a fuga de información, pérdida de integridad u otros incidentes de seguridad de la información, o a la violación de derechos de propiedad intelectual.

12.7 CONSIDERACIONES SOBRE AUDITORÍAS DE SISTEMAS DE INFORMACIÓN

Objetivo: Minimizar el impacto de las actividades de auditoría sobre los sistemas operativos (*Operational Systems*).

12.7.1 Controles sobre auditorías de sistemas de información

Control

Los requisitos y actividades de auditoría que involucren la verificación de los sistemas operativos se deberían planificar y acordar cuidadosamente para minimizar las interrupciones en los procesos del negocio.

Guía de implementación

Se deberían observar las siguientes directrices:

- a) los requisitos de auditoría para acceso a sistemas y a datos se deberían acordar con la dirección apropiada;
- b) el alcance de las pruebas técnicas de auditoría se debería acordar y controlar;
- c) las pruebas de auditoría se deberían limitar a acceso a software y datos únicamente para lectura;
- d) el acceso diferente al de solo lectura solamente se debería prever para copias aisladas de los archivos del sistema (*System Files*), que se deberían borrar una vez que la auditoría haya finalizado, o se debería proporcionar protección apropiada si hay obligación de mantener estos archivos bajo los requisitos de documentación de auditoría;
- e) los requisitos para procesos especiales o adicionales se deberían identificar y acordar;
- f) las pruebas de auditoría que puedan afectar la disponibilidad del sistema se deberían realizar fuera de horas laborales;
- g) se debería hacer seguimiento de todos los accesos y regístralos (*Logged*) para producir un rastro de referencia (*Reference Trail*).

13. SEGURIDAD DE LAS COMUNICACIONES

13.1 GESTIÓN DE LA SEGURIDAD DE LAS REDES

Objetivo: Asegurar la protección de la información en las redes, y sus instalaciones de procesamiento de información de soporte.

13.1.1 Controles de redes

Control

Las redes se deberían gestionar y controlar para proteger la información en sistemas y aplicaciones.

Guía de implementación

Se deberían implementar controles para asegurar la seguridad de la información en las redes, y la protección de servicios relacionados, contra acceso no autorizado. En particular, se deberían considerar los siguientes elementos:

- a) se deberían establecer las responsabilidades y procedimientos para la gestión de equipos de redes;
- b) la responsabilidad operacional por las redes se debería separar de las operaciones de computo, en donde sea apropiado (véase el numeral 6.1.2);
- c) se deberían establecer controles especiales para salvaguardar la confidencialidad e integridad de los datos que pasan sobre redes públicas o sobre redes inalámbricas, y para proteger los sistemas y aplicaciones conectados (véanse los numerales 10 y 13.2); también se pueden requerir controles especiales para mantener la disponibilidad de los servicios de red y computadores conectados;
- d) se deberían aplicar el registro (*Logging*) y el seguimiento adecuados para posibilitar el registro y detección de acciones que pueden afectar, o son pertinentes a la seguridad de la información;
- e) las actividades de gestión se deberían coordinar estrechamente tanto para optimizar el servicio de la organización, como para asegurar que los controles se apliquen en forma coherente a través de la infraestructura de procesamiento de información;
- f) los sistemas en la red se deberían autenticar;
- g) se debería restringir la conexión de los sistemas a la red.

Información adicional

En la ISO/IEC 27033. ^{[15][16][17][18][19]} se puede encontrar información adicional sobre la seguridad de la red.

13.1.2 Seguridad de los servicios de red

Control

Se deberían identificar los mecanismos de seguridad, los niveles de servicio y los requisitos de gestión de todos los servicios de red, e incluirlos en los acuerdos de servicios de red, ya sea que los servicios se presten internamente o se contraten externamente.

Guía de implementación

La capacidad del proveedor de servicios de red para gestionar en forma segura los servicios acordados se debería determinar y hacerle seguimiento con regularidad, y se debería acordar el derecho a la auditoría.

Se deberían identificar los acuerdos de seguridad necesarios para los servicios particulares, tales como las características de seguridad, los niveles de servicio y los requisitos de gestión. La organización se debería asegurar de que los proveedores de servicio de redes implementen estas medidas.

Información adicional

Los servicios de red incluyen el suministro de conexiones, servicios de redes privadas y redes de valor agregado, y soluciones gestionadas de seguridad de redes tales como firewalls y sistemas de detección de intrusión. Estos servicios pueden comprender desde un ancho de banda no gestionado, a ofertas complejas de valor agregado.

Las características de seguridad de las redes de servicio pueden ser:

- a) tecnología aplicada a la seguridad de servicios de red, tales como autenticación, criptografía y controles de conexión de red;
- b) los parámetros técnicos requeridos para la conexión segura con los servicios de red de acuerdo con las reglas de conexión de seguridad y de red;
- c) los procedimientos para el uso de servicios de red para restringir el acceso a los servicios o aplicaciones de red, cuando sea necesario.

13.1.3 Separación en las redes

Control

Los grupos de servicios de información, usuarios y sistemas de información se deberían separar en las redes.

Guía de implementación

Un método para gestionar la seguridad de las redes grandes es dividir las en dominios de red separados. Los dominios se pueden escoger con base en los niveles de confianza (por ejemplo, dominio de acceso público, dominio de computador de escritorio, dominio de servidor), junto con unidades organizacionales (por ejemplo, recursos humanos, finanzas, mercadeo) o alguna combinación (por ejemplo, un dominio de servidor que se conecta a múltiples unidades organizacionales). La separación se puede hacer usando diferentes redes físicas o diferentes redes lógicas (por ejemplo, redes privadas virtuales).

El perímetro de cada dominio se debería definir bien. Se permite el acceso entre dominios de redes, pero se debería controlar en el perímetro usando un portal (por ejemplo, firewalls, enrutado de filtrado). Los criterios para la separación de redes en dominios, y el acceso permitido a través de los portales se debería basar en una valoración de los requisitos de seguridad de cada dominio. La valoración se debería hacer de acuerdo con la política de control de acceso (véase el numeral 9.1.1), los requisitos de acceso, el valor y la clasificación de la información procesada, y también tener en cuenta el costo relativo y el impacto que tiene para el desempeño la incorporación de tecnología de portal (*Gateway Portal*) adecuada.

Las redes inalámbricas requieren tratamiento especial debido a la pobre definición del perímetro de red. Para entornos sensibles, antes de conceder el acceso a los sistemas internos, se debería considerar tratar todos los accesos inalámbricos como conexiones externas y separar este acceso de las redes internas, hasta que el acceso haya pasado a través de un portal de acuerdo con la política de controles de redes (véase el numeral 13.1.1).

La autenticación, la criptografía y las tecnologías de control de acceso de redes a nivel de usuario, de las redes inalámbricas modernas basadas en estándares, pueden ser suficientes para dirigir la conexión directa a la red interna de la organización, cuando se implementa apropiadamente.

Información adicional

Con frecuencia las redes van más allá de los límites de la organización, ya que se forman sociedades de negocio que requieren la interconexión o intercambio de instalaciones para trabajo en red y procesamiento de información. Estas extensiones pueden incrementar el riesgo de acceso no autorizado a los sistemas de información de la organización que usan la red, algunos de los cuales requieren protección contra otros usuarios de la red, debido a su sensibilidad o criticidad.

13.2 TRANSFERENCIA DE INFORMACIÓN

Objetivo: Mantener la seguridad de la información transferida dentro de una organización y con cualquier entidad externa.

13.2.1 Políticas y procedimientos de transferencia de información

Control

Se debería contar con políticas, procedimientos y controles de transferencia formales para proteger la transferencia de información mediante el uso de todo tipo de instalaciones de comunicación.

Guía de implementación

Los procedimientos y controles que se siguen cuando se usan instalaciones de comunicación para la transferencia de información deberían tener en cuenta los siguientes elementos:

- a) los procedimientos diseñados para proteger la información transferida contra interceptación, copiado, modificación, enrutado y destrucción;
- b) los procedimientos para la detección de software malicioso y protección contra éste, que puede ser transmitido mediante el uso de comunicaciones electrónicas (véase el numeral 12.2.1);

- c) los procedimientos para proteger información electrónica sensible comunicada que está en forma de adjunto;
- d) la política o directrices que presentan el uso aceptable de las instalaciones de comunicación (véase el numeral 8.1.3);
- e) las responsabilidades del personal, las partes externas y cualquier otro usuario no comprometen a la organización, por ejemplo, por difamación, acoso, suplantación, envío de cadenas, compras no autorizadas, etc.;
- f) el uso de técnicas criptográficas, por ejemplo, proteger la confidencialidad, la integridad y la autenticidad de la información (véase el numeral 10).
- g) las directrices sobre retención y disposición para toda la correspondencia del negocio, incluidos mensajes, de acuerdo con la legislación y reglamentaciones locales y nacionales;
- h) los controles y restricciones asociadas con las instalaciones de comunicación, por ejemplo, el reenvío automático de correo electrónico a direcciones de correo externas;
- i) brindar asesoría al personal para que tome las precauciones apropiadas acerca de no revelar información confidencial;
- j) no dejar mensajes que contengan información confidencial, en las máquinas contestadoras, ya que éstos pueden ser escuchados por personas no autorizadas, almacenados en sistemas comunales o almacenados incorrectamente como resultado de una marcación incorrecta;
- k) brindar asesoría al personal acerca de los problemas de usar máquinas o servicios de fax, a saber:
 - 1) acceso no autorizado para recuperar mensajes almacenados;
 - 2) programar las máquinas en forma deliberada o accidental para enviar mensajes a números específicos;
 - 3) enviar documentos y mensajes a un número equivocado, ya sea por marcación errada o por marcar un número almacenado equivocado.

Además, se le debería recordar al personal que no debería tener conversaciones confidenciales en lugares públicos, o mediante canales de comunicación no seguros, oficinas abiertas y lugares de reunión.

Los servicios de transferencia de información deberían cumplir todos los requisitos legales pertinentes (véase el numeral 18.1).

Información adicional

Puede ocurrir transferencia de información mediante el uso de varios tipos diferentes de instalaciones de comunicación, incluido el correo electrónico, voz, fax y video.

La transferencia de software puede ocurrir a través de varios medios diferentes, incluida la descarga desde internet y la adquisición de productos en el comercio.

Se deberían considerar las implicaciones para el negocio, y las implicaciones legales y de seguridad asociadas con el intercambio electrónico de datos, el comercio electrónico y las comunicaciones electrónicas, y los requisitos para los controles.

13.2.2 Acuerdos sobre transferencia de información

Control

Los acuerdos deberían tratar la transferencia segura de información del negocio entre la organización y las partes externas.

Guía de implementación

Los acuerdos de transferencia de información deberían incluir lo siguiente:

- a) las responsabilidades de la dirección para controlar y notificar la transmisión, despacho y recibo;
- b) los procedimientos para asegurar trazabilidad y no repudio;
- c) los estándares técnicos mínimos para empaquetado y transmisión;
- d) certificados de depósito de títulos en garantía;
- e) estándares de identificación de mensajería;
- f) las responsabilidades y obligaciones en el caso de incidentes de seguridad de la información, tales como pérdidas de datos;
- g) el uso de un sistema de etiquetado acordado para información sensible o crítica, que asegure que el significado de la etiqueta se entiende de inmediato, y que la información está protegida apropiadamente (véase el numeral 8.2);
- h) las normas técnicas para registro y lectura de información y software;
- i) cualquier control especial que se requiera para proteger elementos sensibles, tales como criptografía (véase el numeral 10);
- j) mantener una cadena de custodia para la información mientras está en tránsito;
- k) los niveles aceptables de control de acceso.

Se deberían establecer y mantener las políticas, procedimientos y estándares para proteger la información y los medios físicos en tránsito (véase el numeral 8.3.3), y se deberían referenciar en los acuerdos de transferencia.

El contenido de seguridad de la información de cualquier acuerdo debería reflejar el carácter sensible de la información del negocio involucrada.

Información adicional

Los acuerdos pueden ser electrónicos o manuales y pueden tomar la forma de contratos formales. Para información confidencial, los mecanismos específicos usados para la

transferencia de esta información deberían ser coherentes para todas las organizaciones y tipos de acuerdos.

13.2.3 Mensajería electrónica

Control

Se debería proteger adecuadamente la información incluida en la mensajería electrónica.

Guía de implementación

Las consideraciones de seguridad de la información para mensajería electrónica deberían incluir las siguientes:

- a) la protección de mensajes contra acceso no autorizado, modificación o denegación del servicio proporcionales al esquema de clasificación adoptado por la organización;
- b) asegurar el direccionamiento y transporte correctos del mensaje;
- c) la confiabilidad y disponibilidad del servicio;
- d) las consideraciones legales, por ejemplo, los requisitos para firmas electrónicas;
- e) la obtención de aprobación antes de usar servicios públicos externos como mensajería instantánea, redes sociales o intercambio de información;
- f) niveles más fuertes de autenticación para control del acceso desde redes accesibles públicamente.

Información adicional

Hay muchos tipos de mensajería electrónica, tales como correo electrónico, intercambio electrónico de datos y redes sociales, que desempeñan un rol en las comunicaciones del negocio.

13.2.4 Acuerdos de confidencialidad o de no divulgación

Control

Se deberían identificar, revisar regularmente y documentar los requisitos para los acuerdos de confidencialidad o no divulgación que reflejen las necesidades de la organización para la protección de la información.

Guía de implementación

Los acuerdos de confidencialidad o de no divulgación deberían tener en cuenta el requisito de proteger la información confidencial usando términos ejecutables legalmente. Los acuerdos de confidencialidad o de no divulgación son aplicables a las partes externas o a empleados de la organización. Se deberían seleccionar o adicionar elementos teniendo en cuenta el tipo de la otra parte y su acceso o manejo permisible de la información confidencial. Con el fin de identificar los requisitos para los acuerdos de confidencialidad o de no divulgación, se deberían considerar los siguientes elementos:

- a) una definición de la información que se va a proteger (información confidencial);

- b) la duración esperada de un acuerdo, incluidos los casos en los que podría ser necesario mantener la confidencialidad indefinidamente;
- c) las acciones requeridas cuando termina el acuerdo;
- d) las responsabilidades y acciones de los firmantes para evitar la divulgación no autorizada de información;
- e) la propiedad de la información, los secretos comerciales y la propiedad intelectual, y cómo esto se relaciona con la protección de información confidencial;
- f) el uso permitido de información confidencial y los derechos del firmante para usar la información;
- g) el derecho a actividades de auditoría y de seguimiento que involucren información confidencial;
- h) el proceso de notificación y reporte de divulgación no autorizada o fuga de información confidencial;
- i) los plazos para que la información sea devuelta o destruida al cesar el acuerdo;
- j) las acciones que se espera tomar en caso de violación del acuerdo.

Con base en los requisitos de seguridad de la información de la organización, en un acuerdo de confidencialidad o de no divulgación pueden ser necesarios otros elementos.

Los acuerdos de confidencialidad y de no divulgación deberían cumplir todas las leyes y reglamentaciones aplicables para la jurisdicción pertinente (véase el numeral 18.1).

Los requisitos para los acuerdos de confidencialidad y de no divulgación se deberían revisar periódicamente, y cuando ocurran cambios que influyan en estos requisitos.

Información adicional

Los acuerdos de confidencialidad y de no divulgación protegen la información de la organización e informan a los firmantes acerca de su responsabilidad para proteger, usar y divulgar información de una manera autorizada y responsable.

La organización puede necesitar diferentes formas de acuerdos de confidencialidad o de no divulgación, en diferentes circunstancias.

14. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE SISTEMAS

14.1 REQUISITOS DE SEGURIDAD DE LOS SISTEMAS DE INFORMACIÓN

Objetivo: Asegurar que la seguridad de la información sea una parte integral de los sistemas de información durante todo el ciclo de vida. Esto incluye también los requisitos para sistemas de información que prestan servicios sobre redes públicas.

14.1.1 Análisis y especificación de requisitos de seguridad de la información

Control

Los requisitos relacionados con seguridad de la información se deberían incluir en los requisitos para nuevos sistemas de información o para mejoras a los sistemas de información existentes.

Guía de implementación

Los requisitos de seguridad de la información se deberían identificar usando varios métodos, tales como la obtención de requisitos de cumplimiento a partir de políticas y reglamentación, modelado de amenazas, revisiones de incidentes, o uso de umbrales de vulnerabilidad. Los resultados de la identificación se deberían documentar y revisar por todas las partes interesadas.

Los requisitos y los controles de seguridad de la información deberían reflejar el valor que tiene para el negocio la información involucrada (véase el numeral 8.2) y el impacto negativo potencial para el negocio que podría resultar de la falta de seguridad adecuada.

La identificación y gestión de los requisitos de seguridad de la información y los procesos asociados se deberían integrar en las primeras etapas de los proyectos de sistemas de información. La consideración temprana de los requisitos de seguridad de la información, por ejemplo, en la etapa de diseño, puede conducir a soluciones más eficaces y eficientes en cuanto a costos.

Los requisitos de seguridad de la información también deberían considerar:

- a) el nivel de confianza requerido con relación a la identificación declarada de los usuarios, para obtener los requisitos de autenticación de usuario.
- b) los procesos de suministro de acceso y de autorización para usuarios del negocio, al igual que para usuarios privilegiados o técnicos;
- c) informar a los usuarios y operadores sobre sus deberes y responsabilidades;
- d) las necesidades de protección requeridas de activos involucrados, en particular acerca de disponibilidad, confidencialidad, integridad;
- e) los requisitos derivados de los procesos del negocio, tales como registros de transacciones (*Transaction Loggings*) y seguimiento, y de no repudio;
- f) los requisitos exigidos por otros controles de seguridad, por ejemplo, interfaces con el ingreso (*Logging*) o seguimiento, o los sistemas de detección de fuga de datos.

Para aplicaciones que suministran servicios en redes públicas o que implementan transacciones, se deberían considerar los controles dedicados 14.1.2 y 14.1.3.

Si los productos se adquieren, se debería seguir un proceso formal de adquisición y pruebas. Los contratos con los proveedores deberían tener en cuenta los requisitos de seguridad de la información. En donde la funcionalidad de la seguridad en un producto propuesto no satisface el requisito especificado, antes de comprar el producto se deberían reconsiderar el riesgo introducido y los controles asociados.

Se debería evaluar e implementar una guía disponible para configuración de la seguridad del producto, alineada con el software / servicio final (*Service Stack*) de ese sistema.

Los criterios para aceptar productos se deberían definir, por ejemplo, en términos de su funcionalidad, lo que dará seguridad de que los requisitos de seguridad identificados se cumplen. Los productos se deberían evaluar contra estos criterios, antes de su adquisición. Se debería revisar la funcionalidad adicional para asegurarse de que no introduce riesgos adicionales no aceptables.

Información adicional

La norma ISO/IEC 27005^[11] y la norma NTC-ISO 31000^[27] brindan orientación sobre el uso de procesos de gestión del riesgo para identificar los controles, para cumplir los requisitos de seguridad de la información.

14.1.2 Seguridad de servicios de las aplicaciones en redes públicas

Control

La información involucrada en los servicios de aplicaciones que pasan sobre redes públicas se debería proteger de actividades fraudulentas, disputas contractuales y divulgación y modificación no autorizadas.

Guía de implementación

Las consideraciones de seguridad de la información para servicios de aplicaciones que pasan sobre redes públicas deberían incluir las siguientes:

- a) el nivel de confianza que cada parte requiere con relación a la identidad declarada por la otra parte, por ejemplo, por medio de autenticación;
- b) los procesos de autorización asociados con quien puede aprobar el contenido o expedir o firmar documentos transaccionales clave;
- c) asegurar que los socios de comunicación estén completamente informados de sus autorizaciones para suministro o uso del servicio;
- d) determinar y cumplir los requisitos para confidencialidad, integridad, prueba de despacho y recibo de documentos clave y el no repudio de los contratos, por ejemplo, asociados con procesos de ofertas y contratos;
- e) el nivel de confianza requerido en la integridad de los documentos clave;
- f) los requisitos de protección de cualquier información confidencial;
- g) la confidencialidad e integridad de cualquier transacción de pedidos, información de pagos, detalles de la dirección de entrega y confirmación de recibos;
- h) el grado de verificación apropiado para verificar la información de pago suministrada por un cliente;
- i) seleccionar la forma de arreglo de pago más apropiado para protegerse contra fraude;

- j) el nivel de protección requerido para mantener la confidencialidad e integridad de la información del pedido;
- k) evitar la pérdida o duplicación de información de la transacción;
- l) la responsabilidad civil asociada con cualquier transacción fraudulenta;
- m) los requisitos de seguros.

Muchas de las consideraciones anteriores se pueden abordar mediante la aplicación de controles criptográficos (véase numeral 10), teniendo en cuenta el cumplimiento de los requisitos legales (véase el numeral 18, véase especialmente 18.1.5 con relación a la legislación sobre criptografía).

Las disposiciones sobre servicio de aplicaciones (*Application Service Arrangements*) entre socios deberían estar apoyadas por un acuerdo documentado que comprometa a ambas partes bajo los términos de los servicios acordados, incluidos los detalles de la autorización (véase b) arriba).

Se deberían considerar los requisitos de resiliencia contra los ataques, que pueden incluir requisitos para proteger los servidores de las aplicaciones involucradas o asegurar la disponibilidad de las interconexiones de red requeridas para entregar el servicio.

Información adicional

Las aplicaciones accesibles por medio de redes públicas están sujetas a una variedad de amenazas relacionadas con la red, tales como actividades fraudulentas, disputas acerca de contratos, o divulgación de información al público. Por tanto, son indispensables las valoraciones de riesgo detalladas y la selección apropiada de controles. Los controles requeridos incluyen con frecuencia métodos criptográficos para la autenticación y seguridad en la transferencia de datos.

Los servicios de las aplicaciones (*Application Services*) pueden usar métodos de autenticación seguros, por ejemplo, el uso de una llave criptográfica pública y firmas digitales (véase el numeral 10) para reducir los riesgos. Además, cuando se necesiten estos servicios, se pueden usar terceras partes confiables.

14.1.3 Protección de transacciones de los servicios de las aplicaciones (*Application Services*)

Control

La información involucrada en las transacciones de los servicios de las aplicaciones (*Application Services*) se debería proteger para evitar la transmisión incompleta, el enrutamiento errado, la alteración no autorizada de mensajes, la divulgación no autorizada, y la duplicación o reproducción de mensajes no autorizada.

Guía de implementación

Las consideraciones de seguridad de la información para las transacciones de los servicios de las aplicaciones (*Application Service*) deberían incluir las siguientes:

- a) el uso de firmas electrónicas por cada una de las partes involucradas en la transacción;

- b) todos los aspectos de la transacción, es decir, asegurar que:
 - 1) la información de autenticación secreta de usuario (*User's Secret Authentication Information*), de todas las partes, se valide y verifique;
 - 2) la transacción permanezca confidencial;
 - 3) se mantenga la privacidad asociada con todas las partes involucradas;
- c) la trayectoria de las comunicaciones entre todas las partes involucradas esté cifrada;
- d) los protocolos usados para comunicarse entre todas las partes involucradas estén asegurados;
- e) asegurarse de que el almacenamiento de los detalles de la transacción esté afuera de cualquier entorno accesible públicamente, por ejemplo, en una plataforma de almacenamiento existente en la intranet de la organización, y no retenido ni expuesto en un medio de almacenamiento accesible directamente desde Internet;
- f) en donde se use una autoridad confiable (por ejemplo, para los propósitos de emitir y mantener firmas digitales o certificados digitales), la seguridad está integrada e incluida en todo el proceso de gestión de certificados/firmas de un extremo a otro.

Información adicional

El alcance de los controles adoptados necesita ser proporcional al nivel de riesgo asociado con cada forma de transacción de los servicios de las aplicaciones (*Application Service Transaction*).

Es posible que las transacciones tengan que cumplir requisitos legales y de reglamentaciones en la jurisdicción en la que se genera, se procesa, completa o almacena la transacción.

14.2 SEGURIDAD EN LOS PROCESOS DE DESARROLLO Y DE SOPORTE

Objetivo: Asegurar de que la seguridad de la información esté diseñada e implementada dentro del ciclo de vida de desarrollo de los sistemas de información.

14.2.1 Política de desarrollo seguro

Control

Se deberían establecer y aplicar reglas para el desarrollo de software y de sistemas, a los desarrollos dentro de la organización.

Guía de implementación

El desarrollo seguro es un requisito para crear un servicio, arquitectura, software o sistema seguros.

Dentro de una política de desarrollo seguro, se deberían considerar los siguientes aspectos:

- a) la seguridad del ambiente de desarrollo;

- b) la orientación sobre la seguridad en el ciclo de vida de desarrollo del software:
 - 1) la seguridad en la metodología de desarrollo de software;
 - 2) las directrices de codificación seguras para cada lenguaje de programación usado;
- c) los requisitos de seguridad en la fase diseño;
- d) los puntos de chequeo de seguridad dentro de los hitos del proyecto;
- e) los depósitos seguros;
- f) la seguridad en el control de la versión;
- g) el conocimiento requerido sobre seguridad de la aplicación;
- h) la capacidad de los desarrolladores para evitar, encontrar y resolver las vulnerabilidades.

Se deberían usar técnicas de programación seguras tanto para los nuevos desarrollos como para escenarios de reúso de códigos, en donde es posible que no se conozcan los estándares aplicados al desarrollo, o no sean coherentes con las mejores prácticas actuales. Se deberían considerar los estándares de codificación, y en donde sea pertinente, exigir su uso. Los desarrolladores deberían recibir formación para su uso y prueba, y su uso se debería verificar mediante la revisión de códigos.

Si el desarrollo es contratado externamente, la organización debería obtener seguridad de que la parte externa cumple estas reglas para un desarrollo seguro (véase el numeral 14.2.7).

Información adicional

El desarrollo también puede ocurrir dentro de las aplicaciones, tales como las aplicaciones de oficina, programación, navegadores y bases de datos.

14.2.2 Procedimientos de control de cambios en sistemas

Control

Los cambios a los sistemas dentro del ciclo de vida de desarrollo se deberían controlar mediante el uso de procedimientos formales de control de cambios.

Guía de implementación

Los procedimientos formales de control de cambios se deberían documentar y hacer cumplir para asegurar la integridad del sistema, las aplicaciones y los productos, desde las primeras etapas de diseño a través de todos los esfuerzos de mantenimiento posteriores.

La introducción de nuevos sistemas y cambios importantes a los sistemas existentes debería seguir un proceso formal de documentación, especificación, pruebas, control de calidad y gestión de la implementación.

Este proceso debería incluir una valoración de riesgos, el análisis de los impactos de los cambios y la especificación de los controles de seguridad necesarios. Este proceso también debería asegurar que los procedimientos de control y de seguridad existentes no se vean comprometidos, que a los programadores de soporte se les permita el acceso solamente a las partes del sistema necesarias para su trabajo, y que se obtiene el acuerdo y la aprobación formal para cualquier cambio.

Siempre que sea viable, se deberían integrar los procedimientos de control de cambios en aplicaciones y en operaciones (véase el numeral 12.1.2). Los procedimientos de control de cambios deberían incluir, entre otros:

- a) llevar un registro de los niveles de autorización acordados;
- b) asegurar que los cambios se presenten a los usuarios autorizados;
- c) revisar los controles y procedimientos de integridad para asegurar que no se vean comprometidos por los cambios;
- d) identificar todo el software, información, entidades de bases de datos y hardware que requieren corrección;
- e) identificar y verificar el código crítico de seguridad para minimizar la posibilidad de debilidades de seguridad conocidas;
- f) obtener aprobación formal para propuestas detalladas antes de que el trabajo comience;
- g) antes de la implementación, asegurar que los usuarios autorizados aceptan los cambios;
- h) asegurar que el conjunto de documentación del sistema está actualizado al completar cada cambio, y que la documentación antigua se archiva, o se dispone de ella;
- i) mantener un control de versiones para todas las actualizaciones de software;
- j) mantener un rastro de auditoría (*Audit Trail*) de todas las solicitudes de cambio;
- k) asegurar que la documentación de la operación (véase el numeral 12.1.1) y los procedimientos de los usuarios experimenten los cambios que les permitan seguir siendo apropiados;
- l) asegurar que la implementación de los cambios ocurre en el momento correcto y no afecta los procesos de negocio involucrados.

Información adicional

El cambio de software puede tener impacto en el ambiente de producción y viceversa.

Las buenas prácticas incluyen probar el nuevo software en un ambiente separado tanto de los ambientes de producción como de desarrollo (véase el numeral 12.1.4). Esto permite tener control sobre el software nuevo y tener protección adicional de la información operacional que se usa para propósitos de pruebas. Esto debería incluir parches, paquetes de servicios y otras actualizaciones.

Cuando se consideran actualizaciones automáticas, el riesgo para la integridad y disponibilidad de sistema se debería sopesar contra el beneficio de un despliegue rápido de las actualizaciones. No se deberían usar actualizaciones automáticas en sistemas críticos, ya que algunas actualizaciones pueden hacer que fallen aplicaciones críticas.

14.2.3 Revisión técnica de las aplicaciones después de cambios en la plataforma de operación

Control

Cuando se cambian las plataformas de operación, se deberían revisar las aplicaciones críticas del negocio, y someter a prueba para asegurar que no haya impacto adverso en las operaciones o seguridad de la organización.

Guía de implementación

Este proceso debería comprender:

- a) revisar los procedimientos de integridad y control de aplicaciones para asegurar que no estén comprometidos debido a los cambios en las plataformas de operaciones;
- b) asegurar que la notificación de los cambios en la plataforma operativa se hace a tiempo para permitir las pruebas y revisiones apropiadas antes de la implementación;
- c) asegurar que se hacen cambios apropiados en los planes de continuidad del negocio (véase el numeral 17).

Información adicional

Las plataformas de operación incluyen sistemas operativos, bases de datos y plataformas de software intermedio (*Middleware Platforms*). El control también se debería aplicar a los cambios en las aplicaciones.

14.2.4 Restricciones en los cambios a los paquetes de software

Control

Se deberían desalentar las modificaciones a los paquetes de software, los cuales se deben limitar a los cambios necesarios, y todos los cambios se deberían controlar estrictamente.

Guía de implementación

En cuanto sea posible y viable, se deberían usar paquetes de software suministrados por el vendedor-proveedor, que no hayan sufrido modificaciones. En donde un paquete de software necesite modificaciones, se deberían considerar los siguientes puntos:

- a) el riesgo de que los procesos de integridad y los controles incluidos se vean comprometidos;
- b) si se debería obtener el consentimiento del vendedor;
- c) la posibilidad de obtener del vendedor los cambios requeridos, a medida que se actualiza el programa estándar;

- d) el impacto, si la organización llega a ser responsable del mantenimiento futuro del software como resultado de los cambios;
- e) la compatibilidad con otro software en uso.

Si los cambios son necesarios, el software original se debería conservar, y los cambios se deberían aplicar a la copia designada. Se debería implementar un proceso de gestión de actualizaciones de software para asegurar que se instalen las actualizaciones de aplicaciones y de parches aprobados más recientes para todo el software autorizado (véase el numeral 12.6.1). Todos los cambios se deberían probar y documentar completamente de manera que se puedan aplicar nuevamente, si es necesario, a futuras actualizaciones de software. Si se requiere, las modificaciones se deberían poner a prueba y validar por un organismo de evaluación independiente.

14.2.5 Principios de construcción de sistemas seguros

Control

Se deberían establecer, documentar y mantener principios para la construcción de sistemas seguros, y aplicarlos a cualquier actividad de implementación de sistemas de información.

Guía de implementación

Se deberían establecer, documentar y aplicar procedimientos de construcción de sistemas de información seguros basados en principios de construcción de seguridad, a actividades de construcción de sistemas de información internos. La seguridad se debería incluir en el diseño de todas las capas de arquitectura (negocio, datos, aplicaciones y tecnología) equilibrando la necesidad de seguridad de información, con la necesidad de accesibilidad. La nueva tecnología se debería analizar para determinar los riesgos para la seguridad, y el diseño se debería revisar contra patrones de ataque conocidos.

Estos principios y los procedimientos de construcción establecidos se deberían revisar con regularidad para asegurar que están contribuyendo efectivamente a mejorar los estándares de seguridad dentro del proceso de construcción. También se deberían revisar regularmente para asegurar que permanezcan actualizados en términos de combatir nuevas amenazas potenciales y seguir siendo aplicables a los avances en las tecnologías y soluciones que se aplican.

Los principios de construcción de seguridad de la información se deberían aplicar, en donde sea pertinente, a sistemas de información contratados externamente, por medio de contratos y otros acuerdos vinculantes entre la organización y el proveedor al que la organización contrata externamente. La organización debería confirmar que el rigor de los principios de construcción de seguridad de los proveedores es comparable con el suyo.

Información adicional

Los procedimientos de desarrollo de aplicaciones deberían aplicar técnicas de construcción seguras en el desarrollo de aplicaciones que tengan interfaces de entrada y de salida. Las técnicas de construcción segura brindan orientación sobre técnicas de autenticación de usuarios, control de sesiones seguras y validación de datos, desinfección y eliminación de códigos de depuración (*Debugging Codes*).

14.2.6 Ambiente de desarrollo seguro

Control

Las organizaciones deberían establecer y proteger adecuadamente los ambientes de desarrollo seguros para las actividades de desarrollo e integración de sistemas que comprendan todo el ciclo de vida de desarrollo de sistemas.

Guía de implementación

Un ambiente de desarrollo seguro incluye personas, procesos y tecnología asociados con el desarrollo e integración de sistemas.

Las organizaciones deberían valorar los riesgos asociados con las labores de desarrollo de sistemas individuales y establecer ambientes de desarrollo seguros para las labores de desarrollo de sistemas específicos, considerando:

- a) el carácter sensible de los datos que el sistema va a procesar, almacenar y transmitir;
- b) los requisitos externos e internos aplicables, por ejemplo, de reglamentaciones o políticas;
- c) los controles de seguridad ya implementados por la organización, que brindan soporte al desarrollo del sistema;
- d) la confiabilidad del personal que trabaja en el ambiente (véase el numeral 7.1.1);
- e) el grado de contratación externa asociado con el desarrollo del sistema;
- f) la necesidad de separación entre diferentes ambientes de desarrollo;
- g) el control de acceso al ambiente de desarrollo;
- h) el seguimiento de los cambios en el ambiente y en los códigos almacenados ahí;
- i) las copias de respaldo se almacenan en lugares seguros fuera del sitio;
- j) el control sobre el movimiento de datos desde y hacia el ambiente.

Una vez que se determine el nivel de protección para un ambiente de desarrollo específico, las organizaciones deberían documentar los procesos correspondientes en procedimientos de desarrollo seguro, y suministrarlos a todos los individuos que los necesiten.

14.2.7 Desarrollo contratado externamente

Control

La organización debería supervisar y hacer seguimiento de la actividad de desarrollo de sistemas contratados externamente.

Guía de implementación:

Cuando el desarrollo del sistema es contratado externamente, se deberían considerar los siguientes puntos en toda la cadena de suministro externa de la organización:

- a) los acuerdos de licenciamiento, propiedad de los códigos y derechos de propiedad intelectual relacionados con el contenido contratado externamente (véase el numeral 18.1.2);
- b) los requisitos contractuales para prácticas seguras de diseño, codificación y pruebas (véase el numeral 14.2.1);
- c) el suministro del modelo de amenaza aprobado, al desarrollador externo;
- d) los ensayos de aceptación para determinar la calidad y exactitud de los entregables;
- e) el suministro de evidencia de que se usaron umbrales de seguridad para establecer niveles mínimos aceptables de calidad de la seguridad y de la privacidad;
- f) el suministro de evidencia de que se han hecho pruebas suficientes para vigilar que no exista contenido malicioso intencional y no intencional en el momento de la entrega;
- g) el suministro de evidencia de que se han hecho pruebas suficientes para proteger contra la presencia de vulnerabilidades conocidas;
- h) certificados de depósito en garantía (*Escrow Arrangements*); por ejemplo, si el código fuente ya no está disponible;
- i) derecho contractual con relación a procesos y controles de desarrollo de auditorías;
- j) documentación eficaz del ambiente de construcción usado para crear entregables;
- k) la organización sigue siendo responsable del cumplimiento con las leyes aplicables y con la verificación de la eficiencia del control.

Información adicional

En la norma ISO/IEC 27036^{[21][22][23]} se puede encontrar información adicional sobre las relaciones con los proveedores.

14.2.8 Pruebas de seguridad de sistemas

Control

Durante el desarrollo se deberían llevar a cabo pruebas de funcionalidad de la seguridad.

Guía de implementación

Tanto los sistemas nuevos como los actualizados requieren pruebas y verificación completas durante los procesos de desarrollo, incluida la preparación de un programa detallado de actividades y entradas de las pruebas y salidas esperadas en una variedad de condiciones. Para desarrollos internos, estas pruebas las debería llevar a cabo inicialmente el equipo de desarrollo. Entonces se deberían llevar a cabo pruebas de aceptación independientes (tanto para desarrollos internos como para los contratados externamente) para asegurar que el sistema trabaja de la forma esperada y únicamente de esta manera (véanse 14.1.1 y 14.1.9). El alcance de la prueba debería ser proporcional a la importancia y naturaleza del sistema.

14.2.9 Prueba de aceptación de sistemas

Control

Para los sistemas de información nuevos, actualizaciones y nuevas versiones, se deberían establecer programas de prueba para aceptación y criterios de aceptación relacionados.

Guía de implementación

Las pruebas de aceptación del sistema deberían incluir las pruebas de requisitos de seguridad de la información (véanse 14.1.1 y 14.1.2) y la adherencia a prácticas de desarrollo seguro de sistemas (véase el numeral 14.2.1). Las pruebas también deberían llevarse a cabo sobre componentes recibidos y sistemas integrados. Las organizaciones pueden hacer uso de herramientas automatizadas, tales como herramientas de análisis de códigos o escáneres de vulnerabilidad, y deberían verificar que se han corregido los defectos relacionados con la seguridad.

Las pruebas se deberían llevar a cabo en un ambiente de pruebas realista, para asegurar que el sistema no introducirá vulnerabilidades al ambiente de la organización, y que las pruebas son confiables.

14.3 DATOS DE PRUEBA

Objetivo: Asegurar la protección de los datos usados para pruebas.

14.3.1 Protección de datos de prueba

Control

Los datos de prueba se deberían seleccionar, proteger y controlar cuidadosamente.

Guía de implementación

Se debería evitar el uso de datos operacionales que contengan información de datos personales o cualquier otra información confidencial para propósitos de prueba. Si esta información de datos personales u otra información confidencial se usa para propósitos de las pruebas, todos los detalles y contenido sensibles se deberían proteger eliminándolos o modificándolos (véase la norma ISO/IEC 29101^[26]).

Las siguientes directrices se deberían aplicar para la protección de los datos operacionales, cuando se usan con propósitos de pruebas:

- a) los procedimientos de control de acceso, que se aplican a los ambientes de producción, se deberían aplicar también a los ambiente de pruebas
- b) debería haber una autorización separada cada vez que se copia información operacional a un ambiente de pruebas;
- c) la información operacional se debería borrar del ambiente de pruebas inmediatamente después de finalizar las pruebas;
- d) el copiado y uso de la información operacional se deberían registrar (*Logged*) para suministrar un rastro de auditoría (*Audit Trail*).

Información adicional

Las pruebas del sistema y de aceptación usualmente requieren volúmenes sustanciales de datos de ensayos que sean lo más cercanos posible a los datos operacionales.

15. RELACIONES CON LOS PROVEEDORES**15.1 SEGURIDAD DE LA INFORMACIÓN EN LAS RELACIONES CON LOS PROVEEDORES**

Objetivo: Asegurar la protección de los activos de la organización que sean accesibles a los proveedores.

15.1.1 Política de seguridad de la información para las relaciones con proveedores*Control*

Los requisitos de seguridad de la información para mitigar los riesgos asociados con el acceso de proveedores a los activos de la organización se deberían acordar con estos y se deberían documentar.

Guía de implementación

La organización debería identificar y exigir controles de seguridad de la información para tener en cuenta en una política específicamente el acceso de los proveedores a la información de la organización. Estos controles deberían tener en cuenta los procesos y procedimientos que va a implementar la organización, al igual que los procesos y procedimientos que la organización debería exigir a sus proveedores que implementara, incluidos:

- a) la identificación y documentación de los tipos de proveedores, por ejemplo, servicios de TI, logísticos, servicios financieros, componentes de la infraestructura de TI, a quienes la organización permitirá acceso a su información;
- b) un proceso y un ciclo de vida normalizado para la gestión de las relaciones con los proveedores;
- c) la definición de los tipos de acceso a la información que se permitirá a diferentes tipos de proveedores, y el seguimiento y el control del acceso;
- d) los requisitos mínimos de seguridad de la información para cada tipo de información y tipo de acceso, que sirvan como base para los acuerdos con proveedores individuales, con base en las necesidades y requisitos del negocio de la organización, y su perfil de riesgo;
- e) los procesos y procedimientos para hacer seguimiento del cumplimiento de los requisitos de seguridad de la información establecidos para cada tipo de proveedor y tipo de acceso, incluida la revisión por una tercera parte y la validación del producto;
- f) los controles de exactitud y completitud, para asegurar la integridad de la información o del procesamiento de la información suministrada por una tercera parte;
- g) los tipos de obligaciones aplicables a los proveedores para proteger la información de la organización;

- h) el manejo de incidentes y contingencias asociadas con el acceso de proveedores, incluidas las responsabilidades tanto de la organización como de los proveedores;
- i) la resiliencia, y si son necesarias, las disposiciones sobre recuperación y contingencias, para asegurar la disponibilidad de la información o el procesamiento de la información suministrada por cualquiera de las partes;
- j) la formación sobre toma de conciencia, para el personal de la organización involucrado en adquisiciones, relativa a políticas, procesos y procedimientos aplicables;
- k) la formación sobre toma de conciencia para el personal de la organización que interactúa con el personal de los proveedores, con respecto a las reglas apropiadas de interacción y comportamiento, con base en el tipo de proveedor, y en el nivel de acceso del proveedor a los sistemas e información de la organización;
- l) las condiciones bajo las cuales los requisitos y controles de seguridad de la información se documentarán en un acuerdo firmado por ambas partes;
- m) la gestión de las transiciones necesarias de información, instalaciones de procesamiento de información y cualquier otra cosa que sea necesario mover, y asegurar que la seguridad de la información se mantiene durante todo el período de transición.

Información adicional

La información puede estar en riesgo cuando los proveedores tienen una gestión de seguridad de la información inadecuada. Se deberían identificar los controles y aplicarlos para administrar el acceso de los proveedores a las instalaciones de procesamiento de información. Por ejemplo, si hay una necesidad especial de confidencialidad de la información, se pueden usar los acuerdos de no divulgación. Otro ejemplo son los riesgos de protección de datos, cuando el acuerdo con los proveedores incluye la transferencia o acceso de información a través de fronteras. La organización necesita tener conciencia de que la responsabilidad legal o contractual con respecto a la protección sigue siendo de la organización.

15.1.2 Tratamiento de la seguridad dentro de los acuerdos con proveedores

Control

Se deberían establecer y acordar todos los requisitos de seguridad de la información pertinentes con cada proveedor que pueda tener acceso, procesar, almacenar, comunicar o suministrar componentes de infraestructura de TI para la información de la organización.

Guía de implementación

Se deberían establecer y documentar acuerdos con los proveedores para asegurar que no haya malos entendidos entre la organización y el proveedor con respecto a las obligaciones de ambas partes con relación al cumplimiento de los requisitos de seguridad de la información pertinentes.

Los siguientes términos se deberían considerar para inclusión en los acuerdos, con el fin de satisfacer los requisitos de seguridad de la información identificados:

- a) una descripción de la información que se va a suministrar o a la que se va a tener acceso, y los métodos para suministrar la información o para acceder a ella;

- b) la clasificación de la información de acuerdo con el esquema de clasificación de la organización (véase el numeral 8.2); si es necesario, también el mapeo entre el propio esquema de clasificación de la organización, y el esquema de clasificación del proveedor;
- c) los requisitos legales y de reglamentación, incluida la protección de datos, los derechos de propiedad intelectual y derechos de autor, y una descripción de cómo se asegurará que se cumplan;
- d) la obligación de cada parte contractual de implementar y acordar un grupo de controles que incluyan controles de acceso, revisión del desempeño, seguimiento, reporte y auditoría;
- e) las reglas de uso aceptable de la información, incluido el uso inaceptable, si es necesario;
- f) una lista explícita de personal del proveedor autorizado para tener acceso a la información de la organización o recibirla de ella, o los procedimientos o condiciones para la autorización, y el retiro de la autorización para el acceso o recibo de información de la organización por parte del personal del proveedor;
- g) las políticas de seguridad de la información pertinentes al contrato específico;
- h) los requisitos y procedimientos de gestión de incidentes (especialmente notificación y colaboración durante la remediación de incidentes);
- i) los requisitos de formación y toma de conciencia para procedimientos específicos, y los requisitos de seguridad de la información, por ejemplo, para respuesta a incidentes, procedimientos de autorización;
- j) las reglamentaciones pertinentes para contratación externa, incluidos los controles que es necesario implementar;
- k) los socios pertinentes en los acuerdos, incluida una persona de contacto, para asuntos de seguridad de la información;
- l) requisitos de selección, si los hay, para el personal del proveedor, incluidas las responsabilidades para la realización de la selección, y los procedimientos de notificación, si la selección no se ha finalizado, o si los resultados son motivo de duda o inquietud;
- m) el derecho de auditar los procesos y controles de los proveedores, relacionados con el acuerdo;
- n) los procesos de solución de defectos y resolución de conflictos;
- o) la obligación de los proveedores de entregar periódicamente un informe independiente sobre la eficacia de los controles y un acuerdo sobre la corrección oportuna de los asuntos pertinentes presentados en el informe;
- p) las obligaciones de los proveedores relativas al cumplimiento de los requisitos de seguridad de la organización.

Información adicional

Los acuerdos pueden variar considerablemente para diferentes organizaciones y entre diferentes tipos de proveedores. Por tanto, se debería prestar atención para incluir todos los requisitos y riesgos de seguridad de la información pertinentes. Los acuerdos con los proveedores también pueden incluir a otras partes (por ejemplo, partes contratadas externamente).

En el acuerdo es necesario considerar los procedimientos para continuar el procesamiento en caso de que el proveedor llegue a ser incapaz de suministrar sus productos o servicios, para evitar cualquier retraso en disponer el reemplazo de productos o servicios.

15.1 3 Cadena de suministro de tecnología de información y comunicaciónControl

Los acuerdos con proveedores deberían incluir requisitos para tratar los riesgos de seguridad de la información asociados con la cadena de suministro de productos y servicios de tecnología de información y comunicación.

Guía de implementación

Los siguientes temas se deberían considerar para inclusión en los acuerdos con los proveedores, concernientes a la seguridad de la cadena de suministro:

- a) definir los requisitos de seguridad de la información para aplicar a la adquisición de productos o servicios de tecnología de la información y de comunicaciones, además de los requisitos generales de seguridad de la información para las relaciones con los proveedores;
- b) para los servicios de tecnología de información y de comunicaciones, exigir que los proveedores divulguen los requisitos de seguridad de la organización a lo largo de la cadena de suministro, si los proveedores contratan externamente partes del servicio de tecnología de la información y comunicaciones que suministran a la organización;
- c) para los productos de tecnología de información y comunicaciones, exigir que los proveedores divulguen prácticas de seguridad adecuadas a lo largo de la cadena de suministro, si estos productos incluyen componentes comprados a otros proveedores;
- d) implementar un proceso de seguimiento y métodos aceptables para validar que los productos y servicios de tecnología de información y comunicación cumplan los requisitos de seguridad establecidos;
- e) implementar un proceso para identificar los componentes de los productos o servicios que son críticos para mantener la funcionalidad, y por tanto, requieren una mayor atención y escrutinio cuando se construyen por fuera de la organización, especialmente si el proveedor en el nivel superior contrata externamente aspectos de componentes de productos o servicios a otros proveedores;
- f) obtener la seguridad de que los componentes críticos y su origen se pueden rastrear a todo lo largo de la cadena de suministro;

- g) obtener seguridad de que los productos de tecnología de información y de comunicación están funcionando en la forma esperada, sin ningún aspecto indeseado o inesperado;
- h) definir reglas para compartir información concerniente a la cadena de suministro y cualquier problema y compromisos entre la organización y los proveedores;
- i) implementar procesos específicos para la gestión del ciclo de vida y la disponibilidad de componentes de tecnología de información y de comunicación, y de los riesgos de seguridad asociados. Esto incluye la gestión de riesgos de componentes que ya no están disponibles debido a que los proveedores ya no están en el negocio o ya no suministran estos componentes debido a que se han hecho avances en la tecnología.

Información adicional

Las prácticas específicas de gestión de riesgos en la cadena de suministro de tecnología de información y de comunicación se desarrollan sobre prácticas generales de construcción de sistemas y de gestión de proyectos, de calidad y seguridad de la información, pero no los reemplazan.

Es conveniente que las organizaciones trabajen con proveedores que comprendan la cadena de suministro de tecnología de información y comunicación y cualquier asunto que tenga un impacto importante sobre los productos y servicios que se suministran. Las organizaciones pueden influir en las prácticas de seguridad de la información de la cadena de suministro de tecnología de información y comunicación, estableciendo en forma clara en los acuerdos con sus proveedores, los temas que deberían tener en cuenta otros proveedores en la cadena de suministro de tecnología de información y comunicación.

La cadena de suministro de tecnología de información y comunicación como se aborda aquí, incluye los servicios de cómputo en la nube.

15.2 GESTIÓN DE LA PRESTACIÓN DE SERVICIOS DE PROVEEDORES

Objetivo: Mantener el nivel acordado de seguridad de la información y de prestación del servicio en línea con los acuerdos con los proveedores.

15.2.1 Seguimiento y revisión de los servicios de los proveedores

Control

Las organizaciones deberían hacer seguimiento, revisar y auditar con regularidad la prestación de servicios de los proveedores.

Guía de implementación

El seguimiento y la revisión de los servicios de los proveedores deberían asegurar que los términos y condiciones de seguridad de la información de los acuerdos se cumplan, y que los incidentes y problemas de seguridad de la información se gestionen apropiadamente.

Esto debería involucrar un proceso de relacionamiento para la gestión del servicio entre la organización y el proveedor para:

- a) hacer seguimiento de los niveles de desempeño de servicio para verificar el cumplimiento de los acuerdos;

- b) revisar los reportes de servicio elaborados por el proveedor, y concertar reuniones de avance regulares, según se exija en los acuerdos;
- c) llevar a cabo auditorías de los proveedores, junto con la revisión de reportes de auditores independientes, si están disponibles, y seguimiento a las cuestiones identificadas;
- d) suministrar información acerca de incidentes de seguridad de la información y revisar esta información según se exija en los acuerdos y en cualquier directriz y procedimiento de soporte;
- e) revisar los rastros de auditoría (*Audit Trails*) del proveedor, y los registros de eventos de seguridad de la información, problemas operacionales, fallas, rastreo de fallas e interrupciones relacionadas con el servicio entregado;
- f) resolver y gestionar cualquier problema identificado;
- g) revisar los aspectos de seguridad de la información de las relaciones de los proveedores con sus propios proveedores;
- h) asegurar que el proveedor mantenga una capacidad de servicio suficiente, junto con planes ejecutables destinados a asegurar que se mantienen los niveles de continuidad del servicio acordados, después de fallas considerables en el servicio, o después de un desastre (véase el numeral 17).

La responsabilidad de la gestión de las relaciones con los proveedores se debería asignar a un individuo o equipo de gestión de servicio designado. Además, la organización debería asegurar que los proveedores asignen responsabilidades para la revisión de la conformidad y velen por el cumplimiento de los requisitos de los acuerdos. Debería haber disponibles suficientes recursos y habilidades técnicas para hacer seguimiento del cumplimiento de los requisitos del acuerdo, en particular, los requisitos de seguridad de la información. Se deberían tomar las acciones apropiadas cuando se observen deficiencias en la entrega del servicio.

La organización debería mantener suficiente control y visibilidad general sobre todos los aspectos de seguridad para la información sensible o crítica o para las instalaciones de procesamiento de información a las que se tiene acceso, procesadas o gestionadas por un proveedor. La organización debería mantener visibilidad en áreas de seguridad tales como gestión de cambios, identificación de vulnerabilidades y reporte y respuesta de incidentes de seguridad de la información, a través de un proceso de reporte definido.

15.2.2 Gestión de cambios en los servicios de los proveedores

Control

Se deberían gestionar los cambios en el suministro de servicios por parte de los proveedores, incluido el mantenimiento y la mejora de las políticas, procedimientos y controles de seguridad de la información existentes, teniendo en cuenta la criticidad de la información, sistemas y procesos del negocio involucrados, y la revaloración de los riesgos.

Guía de implementación

Se deberían considerar los siguientes aspectos:

- a) los cambios en los acuerdos con los proveedores;

- b) los cambios hechos por la organización para implementar:
 - 1) las mejoras a los servicios ofrecidos en la actualidad;
 - 2) el desarrollo de nuevas aplicaciones y sistemas;
 - 3) las modificaciones o actualizaciones a las políticas y procedimientos de la organización;
 - 4) los controles nuevos o modificados para resolver incidentes de seguridad de la información y mejorar la seguridad;
- c) los cambios en los servicios de los proveedores para implementar:
 - 1) cambios y mejoras en las redes;
 - 2) el uso de nuevas tecnologías;
 - 3) la adopción de nuevos productos o versiones/ediciones más recientes;
 - 4) nuevas herramientas y ambientes de desarrollo;
 - 5) cambios en las ubicaciones físicas de las instalaciones de servicio;
 - 6) cambio de proveedores;
 - 7) contratación externa de otros proveedores.

16. GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

16.1 GESTIÓN DE INCIDENTES Y MEJORAS EN LA SEGURIDAD DE LA INFORMACIÓN

Objetivo: Asegurar un enfoque coherente y eficaz para la gestión de incidentes de seguridad de la información, incluida la comunicación sobre eventos de seguridad y debilidades.

16.1.1 Responsabilidades y procedimientos

Control

Se deberían establecer las responsabilidades y procedimientos de gestión para asegurar una respuesta rápida, eficaz y ordenada a los incidentes de seguridad de la información.

Guía de implementación

Se deberían considerar las siguientes directrices para responsabilidades y procedimientos de gestión con relación a la gestión de incidentes de seguridad de la información:

- a) se deberían establecer las responsabilidades de gestión, para asegurar que los siguientes procedimientos se desarrollan y comunican adecuadamente dentro de la organización:
 - 1) los procedimientos para la planificación y preparación de respuesta a incidentes;

- 2) los procedimientos para seguimiento, detección, análisis y reporte de eventos e incidentes de seguridad de la información;
 - 3) procedimientos para registrar (*Logging*) las actividades de gestión de incidentes;
 - 4) procedimientos para el manejo de evidencia forense;
 - 5) los procedimientos para la valoración y toma de decisiones sobre eventos de seguridad de la información y la valoración de debilidades de seguridad de la información;
 - 6) los procedimientos para respuesta, incluyendo aquellos para llevar el asunto a una instancia superior (escalamiento), recuperación controlada de un incidente y comunicación a personas u organizaciones internas y externas;
- b) los procedimientos establecidos deberían asegurar que:
- 1) personal competente maneje las cuestiones relacionadas con incidentes de seguridad de la información dentro de la organización;
 - 2) se implemente un punto de contacto para la detección y reporte de incidentes de seguridad;
 - 3) se mantengan contactos apropiados con las autoridades, grupos de interés o foros externos que manejen las cuestiones relacionadas con incidentes de seguridad de la información;
- c) los procedimientos de reporte deberían incluir:
- 1) la preparación de formatos de reporte de eventos de seguridad de la información para apoyar la acción de reporte y ayudar a la persona que reporta a recordar todas las acciones necesarias en caso de un evento de seguridad de la información;
 - 2) el procedimiento que se va a seguir en el caso de un evento de seguridad de la información, por ejemplo, tomar nota inmediatamente de todos los detalles, tales como el tipo de no conformidad o violación, mal funcionamiento, mensajes en la pantalla y reporte inmediato al punto de contacto y realizar solamente acciones coordinadas;
 - 3) referencia a un proceso disciplinario formal establecido para ocuparse de los empleados que cometen violaciones a la seguridad;
 - 4) los procesos de retroalimentación adecuados para asegurar que las personas que reportan eventos de seguridad de la información sean notificadas de los resultados después de que la cuestión haya sido tratada y cerrada.

Los objetivos de la gestión de incidentes de seguridad de la información se deberían acordar con la dirección, y se debería asegurar que los responsables de la gestión de incidentes de seguridad de la información comprenden las prioridades de la organización para el manejo de incidentes de seguridad de la información.

Información adicional

Los incidentes de seguridad de la información podrían trascender las fronteras organizacionales y nacionales. Para responder a estos incidentes hay una necesidad creciente de coordinar las respuestas y compartir información acerca de estos incidentes con las organizaciones externas, según el caso.

Para orientación detallada sobre la gestión de incidentes de seguridad de la información, véase la GTC-ISO/IEC 27035^[20].

16.1.2 Reporte de eventos de seguridad de la información*Control*

Los eventos de seguridad de la información se deberían informar a través de los canales de gestión apropiados, tan pronto como sea posible.

Guía de implementación

Todos los empleados y contratistas deberían tomar conciencia de su responsabilidad de reportar eventos de seguridad de la información tan pronto como sea posible. También deberían ser conscientes del procedimiento para reportar eventos de seguridad de la información y el punto de contacto al que se deberían reportar los eventos.

Las situaciones que se deberían considerar para el reporte de eventos de seguridad de la información incluyen:

- a) un control de seguridad ineficaz;
- b) violación de la integridad, confidencialidad o expectativas de disponibilidad de la información;
- c) errores humanos;
- d) no conformidades con políticas o directrices;
- e) violaciones de acuerdos de seguridad física;
- f) cambios no controlados en el sistema;
- g) mal funcionamiento en el software o hardware;
- h) violaciones de acceso.

Información adicional

El mal funcionamiento u otro comportamiento anómalo del sistema puede ser un indicador de un ataque a la seguridad o una violación real a la seguridad, y por lo tanto se debería reportar siempre como un evento de seguridad de la información.

16.1.3 Reporte de debilidades de seguridad de la información**Control**

Se debería exigir a todos los empleados y contratistas que usan los servicios y sistemas de información de la organización, que observen y reporten cualquier debilidad de seguridad de la información observada o sospechada en los sistemas o servicios.

Guía de implementación

Todos los empleados y contratistas deberían reportar estos asuntos al punto de contacto lo más pronto posible, para evitar incidentes de seguridad de la información. El mecanismo de reporte debería ser lo más sencillo, accesible y disponible posible.

Información adicional

Se debería advertir a empleados y contratistas que no intenten poner a prueba las debilidades de seguridad sospechadas. Esto podría ser interpretado como un mal uso potencial del sistema y podría causar daño al sistema o servicio de información y derivar en responsabilidad legal para el individuo que haga estas pruebas.

16.1.4 Evaluación de eventos de seguridad de la información y decisiones sobre ellos**Control**

Los eventos de seguridad de la información se deberían evaluar y se debería decidir si se van a clasificar como incidentes de seguridad de la información.

Guía de implementación

El punto de contacto debería evaluar cada evento de seguridad de la información usando la escala acordada de clasificación de eventos e incidentes de seguridad de la información y decidir si el evento se debería clasificar como un incidente de seguridad de la información. La clasificación y priorización de incidentes puede ayudar a identificar el impacto y la extensión de un incidente.

En los casos en que la organización cuente con un equipo de respuesta a incidentes de seguridad de la información (ERISI), la evaluación y la decisión se pueden enviar al ERISI para confirmación o revaloración.

Los resultados de la evaluación y la decisión se deberían registrar en detalle para referencia y verificación futuras.

16.1.5 Respuesta a incidentes de seguridad de la información**Control**

Se debería dar respuesta a los incidentes de seguridad de la información de acuerdo con procedimientos documentados.

Guía de implementación

Un punto de contacto designado y otras personas pertinentes de la organización o partes externas deberían responder a los incidentes de seguridad de la información (véase el numeral 16.1.1)

La respuesta debería incluir lo siguiente:

- a) recolectar evidencia lo más pronto posible después de que ocurra el incidente;
- b) Llevar a cabo análisis forense de seguridad de la información, según se requiera (véase el numeral 16.1.7);
- c) Llevar el asunto a una instancia superior (escalar), según se requiera;
- d) Asegurarse de que todas las actividades de respuesta involucradas se registren (*Logged*) adecuadamente para análisis posterior;
- e) comunicar la existencia del incidente de seguridad de la información o de cualquier detalle pertinente a él, al personal interno o externo a las organizaciones que necesitan saberlo;
- f) tratar las debilidades de seguridad de información que se encontraron que causan o contribuyen al incidente;
- g) una vez que el incidente se haya tratado exitosamente, cerrarlo formalmente y hacer un registro de esto.

Se debería llevar a cabo un análisis posterior al incidente, según sea necesario, para identificar su origen.

Información adicional

La primera meta de la respuesta a incidentes es reanudar el “nivel de seguridad normal” e iniciar la recuperación necesaria.

16.1.6 Aprendizaje obtenido de los incidentes de seguridad de la informaciónControl

El conocimiento adquirido al analizar y resolver incidentes de seguridad de la información se debería usar para reducir la posibilidad o el impacto de incidentes futuros.

Guía de implementación

Se debería contar con mecanismos que permitan cuantificar y hacer el seguimiento de todos los tipos, volúmenes y costos de incidentes de seguridad de la información. La información obtenida de la evaluación de incidentes de seguridad de la información se debería usar para identificar los incidentes recurrentes o con impacto alto.

Información adicional

La evaluación de los incidentes de seguridad de la información puede indicar la necesidad de controles adicionales o mejorados para limitar la frecuencia, daño y costo de futuros sucesos, o

ser tomada en cuenta en el proceso de revisión de la política de seguridad (véase el numeral 5.1.2).

Prestando la debida atención a los aspectos de confidencialidad, las anécdotas de los incidentes de seguridad de la información reales se pueden usar en la formación de toma de conciencia (véase el numeral 7.2.2) como ejemplos de lo que podría ocurrir, cómo responder a estos incidentes y cómo evitarlos en el futuro.

16.1.7 Recolección de evidencia

Control

La organización debería definir y aplicar procedimientos para la identificación, recolección, adquisición y preservación de información que pueda servir como evidencia.

Guía de implementación

Se deberían desarrollar y seguir procedimientos internos cuando se trata con evidencia para propósitos de acciones legales y disciplinarias.

En general, estos procedimientos para evidencia deberían suministrar procesos de identificación, recolección, adquisición y preservación de evidencia de acuerdo con los diferentes tipos de medios, dispositivos y estado de los dispositivos, por ejemplo, encendidos o apagados. Los procedimientos deberían tener en cuenta:

- a) la cadena de custodia;
- b) la seguridad de la evidencia;
- c) la seguridad del personal;
- d) los roles y responsabilidades del personal involucrado;
- e) la competencia del personal;
- f) la documentación;
- g) las sesiones informativas.

Cuando esté disponible, se debería buscar una certificación u otro medio pertinente de calificación del personal y herramientas, para fortalecer el valor de la evidencia preservada.

La evidencia forense puede trascender los límites organizacionales o jurisdiccionales. En estos casos, se debería asegurar que la organización esté autorizada para recolectar la información requerida como evidencia forense. Los requisitos de las diferentes jurisdicciones también se deberían considerar para maximizar las oportunidades de admisión a través de las jurisdicciones pertinentes.

Información adicional

La identificación es el proceso que involucra la búsqueda, reconocimiento y documentación de evidencia potencial. Recolección es el proceso de reunir elementos físicos que pueden contener evidencia potencial.

Adquisición es el proceso de crear una copia de los datos dentro de un grupo definido. Preservación es el proceso de mantener y salvaguardar la integridad y la condición original de la evidencia potencial.

Cuando se detecta por primera vez un evento de seguridad de la información, tal vez no sea obvio si el evento dará como resultado una acción judicial. Por tanto, existe el peligro de que la evidencia necesaria se destruya intencional o accidentalmente antes de darse cuenta de la gravedad del incidente. Es recomendable involucrar a un abogado o a la policía al comienzo de cualquier acción legal contemplada, y aceptar asesoría acerca de la evidencia requerida.

La norma ISO/IEC 27037^[24] proporciona directrices para la identificación, recolección, adquisición y preservación de evidencia digital.

17. ASPECTOS DE SEGURIDAD DE LA INFORMACIÓN DE LA GESTIÓN DE CONTINUIDAD DE NEGOCIO

17.1 CONTINUIDAD DE SEGURIDAD DE LA INFORMACIÓN

Objetivo: La continuidad de seguridad de la información se debería incluir en los sistemas de gestión de la continuidad de negocio de la organización.

17.1.1 Planificación de la continuidad de la seguridad de la información

Control

La organización debería determinar sus requisitos para la seguridad de la información y la continuidad de la gestión de la seguridad de la información en situaciones adversas, por ejemplo, durante una crisis o desastre.

Guía de implementación

Una organización debería determinar si la continuación de la seguridad de la información se ha incluido dentro del proceso de gestión de continuidad de negocio o dentro del proceso de gestión para recuperación de desastres. Los requisitos de seguridad de la información se deberían determinar cuándo se planifican la continuidad de negocio y la recuperación en caso de desastres.

En ausencia de una planificación formal de continuidad de negocio y recuperación de desastres, la dirección de seguridad de la información debería suponer que los requisitos de seguridad de la información siguen siendo los mismos en situaciones adversas, en comparación con las condiciones operacionales normales. Como alternativa, una organización puede llevar a cabo un análisis de impacto en el negocio de los aspectos de seguridad de la información, para determinar los requisitos de seguridad de la información aplicables a situaciones adversas.

Información adicional

Con el fin de reducir el tiempo y el esfuerzo que implica un análisis “adicional” del impacto en el negocio de la seguridad de la información, se recomienda capturar los aspectos de seguridad de la información dentro de la gestión normal de la continuidad de negocio, o el análisis de impacto en el negocio de la recuperación de desastres. Esto implica que los requisitos de continuidad de seguridad de la información se formulan explícitamente en los procesos de continuidad de negocio o de gestión de recuperación de desastres.

La información sobre la gestión de la continuidad de negocio se puede encontrar en las normas ISO/IEC 27031^[14] ISO 22313^[9] e ISO 22301^[8].

17.1.2 Implementación de la continuidad de la seguridad de la información

Control

La organización debería establecer, documentar, implementar y mantener procesos, procedimientos y controles para asegurar el nivel de continuidad requerido para la seguridad de la información durante una situación adversa.

Guía de implementación

Una organización debería asegurar que:

- a) se cuente con una estructura de gestión adecuada para prepararse, mitigar y responder a un evento perturbador usando personal con la autoridad, experiencia y competencia necesarias.
- b) se nombre personal de respuesta a incidentes con la responsabilidad, autoridad y competencia necesarias para manejar un incidente y mantener la seguridad de la información.
- c) se desarrollen y aprueben planes, procedimientos de respuesta y recuperación documentados, en los que se especifique en detalle como la organización gestionará un evento perturbador y mantendrá su seguridad de la información en un nivel predeterminado, con base en los objetivos de continuidad de seguridad de la información aprobados por la dirección (véase el numeral 17.1.1).

De acuerdo con los requisitos de continuidad de la seguridad de la información, la organización debería establecer, documentar, implementar y mantener:

- a) los controles de la seguridad de la información dentro de procesos de continuidad de negocio o recuperación de desastres, y sistemas y herramientas de apoyo;
- b) los cambios en los procesos, procedimientos e implementación, para mantener los controles de seguridad de la información existentes, durante una situación adversa;
- c) los controles de compensación para los controles de seguridad de la información que no se pueden mantener durante una situación adversa.

Información adicional

Dentro del contexto de continuidad de negocio o recuperación de desastres, se pueden haber definido procesos y procedimientos específicos. Se debería proteger la información que es manejada dentro de estos procesos y procedimientos, o dentro de sistemas de información dedicados que los apoyan. Por tanto, una organización debería involucrar especialistas en seguridad de la información cuando se establecen, implementan y mantienen procesos y procedimientos de continuidad de negocio o de recuperación de desastres.

Los controles de seguridad de la información que se han implementado deberían continuar operando durante una situación adversa. Si los controles de seguridad no están en capacidad de seguir brindando seguridad a la información, se deberían establecer, implementar y mantener otros controles para mantener un nivel aceptable de seguridad de la información.

17.1.3 Verificación, revisión y evaluación de la continuidad de la seguridad de la información

Control

La organización debería verificar a intervalos regulares los controles de continuidad de la seguridad de la información establecidos e implementados, con el fin de asegurar que son válidos y eficaces durante situaciones adversas.

Guía de implementación

Los cambios organizacionales, técnicos, procedimentales y de los procesos, ya sea en un contexto operacional o de continuidad, pueden conducir a cambios en los requisitos de continuidad de la seguridad de la información. En estos casos, la continuidad de los procesos, procedimientos y controles para seguridad de la información se debería revisar contra los requisitos que han sufrido cambios.

Las organizaciones deberían verificar la continuidad de la gestión de la seguridad de su información:

- a) ejercitando y poniendo a prueba la funcionalidad de los procesos, procedimientos y controles de continuidad de la seguridad de la información, para asegurar que son coherentes con los objetivos de continuidad de la seguridad de la información;
- b) ejercitando y poniendo a prueba el conocimiento y rutina para operar los procesos, procedimientos y controles de continuidad de la seguridad de la información, para asegurar que su desempeño es coherente con los objetivos de continuidad de la seguridad de la información;
- c) revisando la validez y la eficacia de las medidas de continuidad de la seguridad de la información cuando cambian los sistemas de información, los procesos, procedimientos y controles de seguridad de la información, o los procesos y soluciones de gestión de continuidad de negocio/recuperación de desastres.

Información adicional

La verificación de los controles de continuidad de la seguridad de la información es diferente de las pruebas y verificación generales de seguridad de la información, y se debería llevar a cabo aparte de las pruebas que se llevan a cabo cuando hay cambios. Si es posible, es preferible integrar la verificación de los controles de continuidad de negocio de seguridad de la información con las pruebas de continuidad de negocio y recuperación de desastres de la organización.

17.2 REDUNDANCIAS

Objetivo: Asegurar la disponibilidad de instalaciones de procesamiento de información.

17.2.1 Disponibilidad de instalaciones de procesamiento de información.

Control

Las instalaciones de procesamiento de información se deberían implementar con redundancia suficiente para cumplir los requisitos de disponibilidad.

Guía de implementación

Las organizaciones deberían identificar los requisitos del negocio para la disponibilidad de los sistemas de información. Cuando no se puede garantizar disponibilidad usando la arquitectura de los sistemas existentes, se deberían considerar componentes o arquitecturas redundantes.

Cuando sea aplicable, los sistemas de información redundante se deberían poner a prueba para asegurar que después de una falla, la conmutación (*Failover*) de un componente a otro funcione de la forma prevista.

Información adicional

La implementación de las redundancias puede introducir riesgos a la integridad o confidencialidad de la información y de los sistemas de información, y es necesario considerarla cuando se diseñan sistemas de información.

18. CUMPLIMIENTO**18.1 CUMPLIMIENTO DE REQUISITOS LEGALES Y CONTRACTUALES**

Objetivo: Evitar el incumplimiento de las obligaciones legales, estatutarias, de reglamentación o contractuales relacionadas con seguridad de la información, y de cualquier requisito de seguridad.

18.1.1 Identificación de la legislación aplicable y de los requisitos contractualesControl

Todos los requisitos estatutarios, reglamentarios y contractuales pertinentes, y el enfoque de la organización para cumplirlos, se deberían identificar y documentar explícitamente y mantenerlos actualizados para cada sistema de información y para la organización.

Guía de implementación

Además, se deberían documentar los controles y las responsabilidades individuales específicas para cumplir estos requisitos.

Los gerentes deberían identificar toda la legislación aplicable a su organización para cumplir los requisitos para su tipo de negocio. Si la organización hace negocios en otros países, los gerentes deberían considerar el cumplimiento en todos los países pertinentes.

18.1.2 Derechos de propiedad intelectualControl

Se deberían implementar procedimientos apropiados para asegurar el cumplimiento de los requisitos legislativos, de reglamentación y contractuales relacionados con los derechos de propiedad intelectual y el uso de productos de software patentados.

Guía de implementación

Las siguientes directrices se deberían considerar para la protección de cualquier material que se pueda considerar propiedad intelectual:

- a) publicar una política de cumplimiento de derechos de propiedad intelectual que defina el uso legal del software y de productos informáticos;
- b) adquirir software solo a través de fuentes conocidas y confiables, para asegurar que no se violan los derechos de autor;
- c) mantener conciencia de las políticas para proteger los derechos de propiedad intelectual y notificar la intención de tomar acciones disciplinarias contra el personal que las incumpla;
- d) mantener los registros de activos apropiados, e identificar todos los activos con requisitos para proteger los derechos de propiedad intelectual;
- e) mantener prueba y evidencia de la propiedad de las licencias, discos maestros, manuales, etc.
- f) implementar controles para asegurar que no se exceda ningún número máximo de usuarios permitido dentro de la licencia;
- g) llevar a cabo revisiones acerca de que solo hay instalados software autorizado y productos con licencia;
- h) suministrar una política para mantener las condiciones de licencia apropiadas;
- i) suministrar una política para disposición o transferencia de software a otros;
- j) cumplir con los términos y condiciones para el software y la información obtenida de las redes públicas;
- k) no duplicar, convertir a otro formato o extraer de registros comerciales (video, audio) más allá de lo que permita la ley de derechos de autor;
- l) no copiar total ni parcialmente libros, artículos, reportajes u otros documentos diferentes de los permitidos por la ley de derechos de autor.

Información adicional

Los derechos de propiedad intelectual incluyen derechos de autor de software o de documentos, derechos de diseño, marcas registradas, patentes y licencias de códigos fuente.

Los productos de software patentados usualmente se suministran bajo un acuerdo de licencia que especifica los términos y condiciones de la licencia, por ejemplo, limitar el uso de productos a máquinas especificadas, o limitar la copia únicamente a la creación de copias de respaldo. La importancia de los derechos de propiedad intelectual y la toma de conciencia sobre estos se debería comunicar al personal, para el software desarrollado por la organización.

Los requisitos legislativos, de reglamentación y contractuales pueden poner restricciones al copiado de material patentado. En particular, pueden exigir que solamente se use material desarrollado por la organización o que tenga licencia del desarrollador o haya sido suministrado por éste. La violación de los derechos de autor puede conducir a acciones legales que pueden involucrar multas y procesos penales.

18.1.3 Protección de registros

Control

Los registros se deberían proteger contra pérdida, destrucción, falsificación, acceso no autorizado y liberación no autorizada, de acuerdo con los requisitos legislativos, de reglamentación, contractuales y de negocio.

Guía de implementación

Cuando se decide proteger los requisitos específicos de la organización, se debería considerar su clasificación correspondiente, basada en el esquema de clasificación de la organización. Los registros se deberían clasificar por tipos de registros, por ejemplo, registros contables, registros de bases de datos, registros de transacciones (*Logs*), registros de auditoría (*Audit Logs*) y procedimientos operacionales, cada uno con detalles de los períodos de retención y tipo de medio de almacenamiento permisible, por ejemplo, papel, microfichas, medios magnéticos, medios ópticos. Cualquier llave criptográfica y programas relacionados asociados con archivos cifrados o firmas digitales (véase el numeral 10), también se deberían almacenar para permitir el descifrado de los registros durante el tiempo en que están retenidos.

Se debería considerar la posibilidad de deterioro de los medios usados para el almacenamiento de registros. Se deberían implementar procedimientos de almacenamiento y manejo, de acuerdo con las recomendaciones de los fabricantes.

Cuando se escogen medios de almacenamiento electrónico, se deberían establecer procedimientos para acceder a los datos (legibilidad de medios y de formatos) durante todo el período de retención, para proteger contra pérdida debidos a cambios futuros en la tecnología.

Se deberían escoger sistemas de almacenamiento de datos de manera que los datos requeridos se puedan recuperar en un tiempo y formato aceptables, dependiendo de los requisitos que se deben cumplir.

El sistema de almacenamiento y manejo debería asegurar la identificación de los registros y de su período de retención, como se define en la legislación o reglamentaciones nacionales o regionales. Este sistema debería permitir la destrucción apropiada de registros después de ese período, si la organización ya no los necesita.

Para cumplir estos objetivos de salvaguarda de registros, se deberían realizar los siguientes pasos dentro de la organización:

- a) se deberían emitir directrices acerca de la retención, almacenamiento, manejo y disposición de registros e información;
- b) se debería elaborar un programa de retención que identifique los registros y el período de tiempo durante el cual se deberían retener;
- c) se debería llevar un inventario de fuentes de información clave.

Información adicional

Puede ser necesario retener en forma segura algunos registros, para cumplir con requisitos estatutarios, de reglamentación o contractuales, al igual que para brindar apoyo a actividades de negocio esenciales. Algunos ejemplos incluyen registros que se pueden solicitar como evidencia de que una organización opera dentro de las disposiciones estatutarias o de

reglamentación, para asegurar la defensa contra acciones civiles o criminales potenciales, o para confirmar el estado financiero de una organización a los accionistas, partes interesadas y auditores. Las leyes o reglamentaciones nacionales pueden ajustar el período de tiempo y el contenido de los datos para retención de información.

En la norma NTC-ISO/IEC 15489-1^[5] se puede encontrar información adicional sobre gestión de registros de la organización.

18.1.4 Privacidad y protección de información de datos personales.

Control

Se deberían asegurar la privacidad y la protección de la información de datos personales, como se exige en la legislación y la reglamentación pertinentes, cuando sea aplicable.

Guía de implementación

Se debería desarrollar e implementar una política relativa a datos de la organización, para la privacidad y la protección de datos personales. Esta política se debería comunicar a todas las personas involucradas en el procesamiento de información de datos personales.

El cumplimiento de esta política y de toda la legislación y reglamentación pertinente concerniente a la protección de la privacidad de las personas y a la protección de los datos personales requiere una estructura y control de gestión apropiados. Con frecuencia, la mejor manera de lograrlo es nombrando una persona responsable, como por ejemplo el funcionario encargado de la privacidad, quien debería brindar orientación a los gerentes, usuarios y proveedores de servicios acerca de sus responsabilidades individuales y de los procedimientos específicos que se deberían seguir. La responsabilidad por el manejo de información sobre datos personales y por asegurar la toma de conciencia sobre los principios de privacidad se debería abordar de acuerdo con la legislación y las reglamentaciones pertinentes. Se deberían implementar medidas técnicas y organizacionales para proteger la información de datos personales.

Información adicional

La ISO/IEC 29100^[25] presenta un marco de referencia de alto nivel para la protección de información de datos personales dentro de los sistemas de tecnología de la información y de la comunicación. Varios países han introducido legislación que establece controles sobre la recolección, procesamiento y transmisión de información de datos personales (generalmente información sobre individuos vivos que pueden ser identificados a partir de esa información). Dependiendo de la legislación nacional respectiva, estos controles pueden imponer deberes a quienes recolectan, procesan y divulgan información de datos personales, y pueden también restringir la capacidad de transferir información de datos personales a otros países.

18.1.5 Reglamentación de controles criptográficos

Control

Se deberían usar controles criptográficos, en cumplimiento de todos los acuerdos, legislación y reglamentación pertinentes.

Guía de implementación

Se deberían considerar los siguientes aspectos para el cumplimiento con los acuerdos, leyes y reglamentaciones:

- a) las restricciones sobre importación o exportación de hardware y software, para la realización de funciones criptográficas;
- b) las restricciones sobre importación o exportación de hardware y software que está diseñado para la adición de funciones criptográficas;
- c) las restricciones sobre el uso de criptografía;
- d) los métodos obligatorios o discrecionales de acceso por parte de las autoridades de los países a información cifrada mediante software o hardware para brindar confidencialidad al contenido.

Se debería buscar asesoría legal para asegurar el cumplimiento con la legislación y las reglamentaciones pertinentes. Antes de que la información cifrada o los controles criptográficos atraviesen fronteras jurisdiccionales, también se debería buscar asesoría legal.

18.2 REVISIONES DE SEGURIDAD DE LA INFORMACIÓN

Objetivo: Asegurar que la seguridad de la información se implemente y opere de acuerdo con las políticas y procedimientos organizacionales.

18.2.1 Revisión independiente de la seguridad de la información

Control

El enfoque de la organización para la gestión de la seguridad de la información y su implementación (es decir, los objetivos de control, los controles, las políticas, los procesos y los procedimientos para seguridad de la información) se deberían revisar independientemente a intervalos planificados o cuando ocurran cambios significativos.

Guía de implementación

La dirección debería dar inicio a una revisión independiente. Esta revisión independiente es necesaria para asegurar la conveniencia, la adecuación y la eficacia continuas del enfoque de la organización para gestionar la seguridad de la información. Esta revisión debería incluir la valoración de las oportunidades de mejora y la necesidad de efectuar cambios en el enfoque hacia la seguridad, incluyendo la política y los objetivos de control.

Esta revisión la deberían llevar a cabo individuos independientes del área que se revisa, por ejemplo, la función de auditoría interna, un gerente independiente o una parte externa de la organización que se especializa en estas revisiones. Los individuos que llevan a cabo estas revisiones deberían contar con las habilidades y experiencia apropiadas.

Los resultados de la revisión independiente se deberían registrar y reportar a la dirección que dio inicio a la revisión. Se deberían mantener estos registros.

Si la revisión independiente identifica que el enfoque y la implementación de la organización para la gestión de la seguridad de la información son inadecuados, por ejemplo, no se cumplen los objetivos y requisitos documentados, o no cumplen con la orientación sobre seguridad de la

información establecida en las políticas de seguridad de la información (véase el numeral 5.1.1), la dirección debería considerar acciones correctivas.

Información adicional

La norma ISO/IEC 27007^[12], “Guidelines for Information Security Management Systems Auditing” e ISO/IEC TR 27008^[13], “Guidelines for Auditors on Information Security Controls” también suministran orientación para llevar a cabo la revisión independiente.

18.2.2 Cumplimiento con las políticas y normas de seguridad

Control

Los gerentes deberían revisar con regularidad el cumplimiento del procesamiento y procedimientos de información dentro de su área de responsabilidad, con las políticas y normas de seguridad apropiadas, y cualquier otro requisito de seguridad.

Guía de implementación

Los gerentes deberían identificar cómo revisar que se cumplen los requisitos de seguridad de la información definidos en las políticas, normas y otras reglamentaciones aplicables. Para una revisión eficiente, se debería considerar herramientas automáticas para medición y reporte.

Si se encuentra alguna no conformidad como resultado de la revisión, los gerentes deberían:

- a) identificar las causas de la no conformidad, y
- b) evaluar la necesidad de acciones para lograr cumplimiento:
- c) implementar las acciones correctivas apropiadas;
- d) revisar la acción correctiva tomada, para verificar su eficacia e identificar cualquier deficiencia o debilidad.

Los resultados de las revisiones y de las acciones correctivas realizadas por la dirección, deberían ser registradas y estos registros se deberían mantener. Los gerentes deberían reportar los resultados a las personas que llevan a cabo revisiones independientes (véase el numeral 18.2.1) cuando se realiza una revisión independiente en su área de responsabilidad.

Información adicional

En el numeral 12.4 se trata sobre el seguimiento operacional del uso del sistema.

18.2.3 Revisión del cumplimiento técnico

Control

Los sistemas de información se deberían revisar periódicamente para determinar el cumplimiento con las políticas y normas de seguridad de la información.

Guía de implementación

El cumplimiento técnico se debería revisar, preferiblemente con la ayuda de herramientas automáticas que generan informes técnicos para la interpretación posterior por un especialista

técnico. Como alternativa, un ingeniero de sistemas experimentado puede llevar a cabo revisiones manuales (si es necesario, con el apoyo de herramientas de software apropiadas).

Si se usan pruebas de penetración (*Penetration Test*) o valoraciones de vulnerabilidad, es necesario tener precaución, ya que estas actividades pueden comprometer la seguridad del sistema. Estas pruebas se deberían planificar, documentar, y deberían ser repetibles.

Cualquier revisión de cumplimiento técnico solo lo deberían llevar a cabo personas competentes autorizadas, o bajo la supervisión de dichas personas.

Información adicional

Las revisiones del cumplimiento técnico involucran examinar los sistemas operacionales para asegurar que los controles de hardware y de software se han implementado correctamente. Este tipo de revisión de cumplimiento requiere pericia técnica especializada.

Las revisiones de cumplimiento también deberían comprender, por ejemplo, las pruebas de penetración (*Penetration Test*) y las valoraciones de vulnerabilidad, que se podrían llevar a cabo por expertos independientes contratados específicamente para este propósito. Esto puede ser útil para detectar vulnerabilidades en el sistema y para examinar la eficacia de los controles para evitar el acceso no autorizado debido a estas vulnerabilidades.

Las pruebas de penetración (*Penetration Test*) y las valoraciones de vulnerabilidad dan un panorama inmediato de un sistema en un estado específico, en un momento específico. Este panorama está limitado a las porciones del sistema sometidas a pruebas realmente durante el(los) intento(s) de penetración. Las pruebas de penetración (*Penetration Test*) y las valoraciones de vulnerabilidad no son un sustituto de la valoración de riesgos.

La ISO/IEC TR 27008^[13] suministra orientación específica sobre revisiones de cumplimiento técnico.

BIBLIOGRAFÍA

- [1] ISO/IEC Directives, Part 2.
- [2] ISO/IEC 11770-1, *Information Technology Security Techniques. Key Management. Part 1: Framework.*
- [3] ISO/IEC 11770-2, *Information Technology. Security Techniques. Key Management. Part 2: Mechanisms Using Symmetric Techniques.*
- [4] ISO/IEC 11770-3, *Information Technology. Security Techniques. Key management. Part 3: Mechanisms Using Asymmetric Techniques.*
- [5] NTC-ISO 15489-1, Información y documentación. Gestión de documentos. Parte 1. Generalidades
- [6] NTC-ISO/IEC 20000-1, Tecnología de la información. Gestión del servicio. Parte 1: requisitos del sistema de gestión del servicio.
- [7] ISO/IEC 20000-2¹, *Information Technology. Service Management. Part 2: Guidance on the Application of Service Management Systems.*
- [8] ISO 22301, *Societal Security. Business Continuity Management Systems. Requirements.*
- [9] ISO 22313, *Societal Security. Business Continuity Management Systems. Guidance.*
- [10] NTC-ISO/IEC 27001, Tecnología de la información. Técnicas de seguridad. Sistemas de gestión de la seguridad de la información. Requisitos.
- [11] ISO/IEC 27005, *Information Technology. Security Techniques. Information Security Risk Management.*
- [12] ISO/IEC 27007, *Information Technology. Security Techniques. Guidelines for Information Security Management Systems Auditing.*
- [13] ISO/IEC TR 27008, *Information Technology. Security Techniques. Guidelines for Auditors on Information Security Controls.*
- [14] ISO/IEC 27031, *Information Technology. Security Techniques. Guidelines for Information and Communication Technology Readiness for Business Continuity.*
- [15] ISO/IEC 27033-1, *Information Technology. Security Techniques. Network Security. Part 1: Overview and Concepts.*
- [16] ISO/IEC 27033-2, *Information Technology. Security Techniques. Network Security. Part 2: Guidelines for the Design and Implementation of Network Security.*
- [17] ISO/IEC 27033-3, *Information Technology. Security Techniques. Network Security. Part 3: Reference Networking Scenarios. Threats, Design Techniques and Control Issues.*

¹ La ISO/IEC 20000-2:2005, fue cancelada y reemplazada por la ISO/IEC 20000-2:2012, Information Technology. Service Management. Part 2: Guidance on the application of Service Management Systems.

- [18] ISO/IEC 27033-4, *Information Technology. Security Techniques. Network Security. Part 4: Securing Communications Between Networks Using Security Gateways.*
- [19] ISO/IEC 27033-5, *Information Technology. Security Techniques. Network security. Part 5: Securing Communications Across Networks Using Virtual Private Network (VPNs).*
- [20] GTC-ISO/IEC 27035, *Tecnología de la información. Técnicas de seguridad. Gestión de incidentes de seguridad de la información.*
- [21] ISO/IEC 27036-1, *Information Technology. Security Techniques. Information Security for Supplier Relationships. Part 1: Overview and Concepts.*
- [22] ISO/IEC 27036-2, *Information Technology. Security techniques. Information Security for Supplier Relationships. Part 2: Common Requirements.*
- [23] ISO/IEC 27036-3, *Information Technology. Security Techniques. Information Security for Supplier Relationships. Part 3: Guidelines for ICT Supply Chain Security.*
- [24] ISO/IEC 27037, *Information Technology. Security Techniques. Guidelines for Identification, Collection, Acquisition and Preservation of Digital Evidence.*
- [25] ISO/IEC 29100, *Information Technology. Security Techniques. Privacy Framework.*
- [26] ISO/IEC 29101, *Information Technology. Security Techniques. Privacy Architecture Framework.*
- [27] NTC-ISO 31000, *Gestión del riesgo. Principios y directrices.*

DOCUMENTO DE REFERENCIA

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. *Information Technology. Security Techniques. Code of Practice for Information Security Controls*. Geneva: ISO, 2013, 90 p. (ISO/IEC 27002:2013 (E) + Technical Corrigendum 1: 2014).